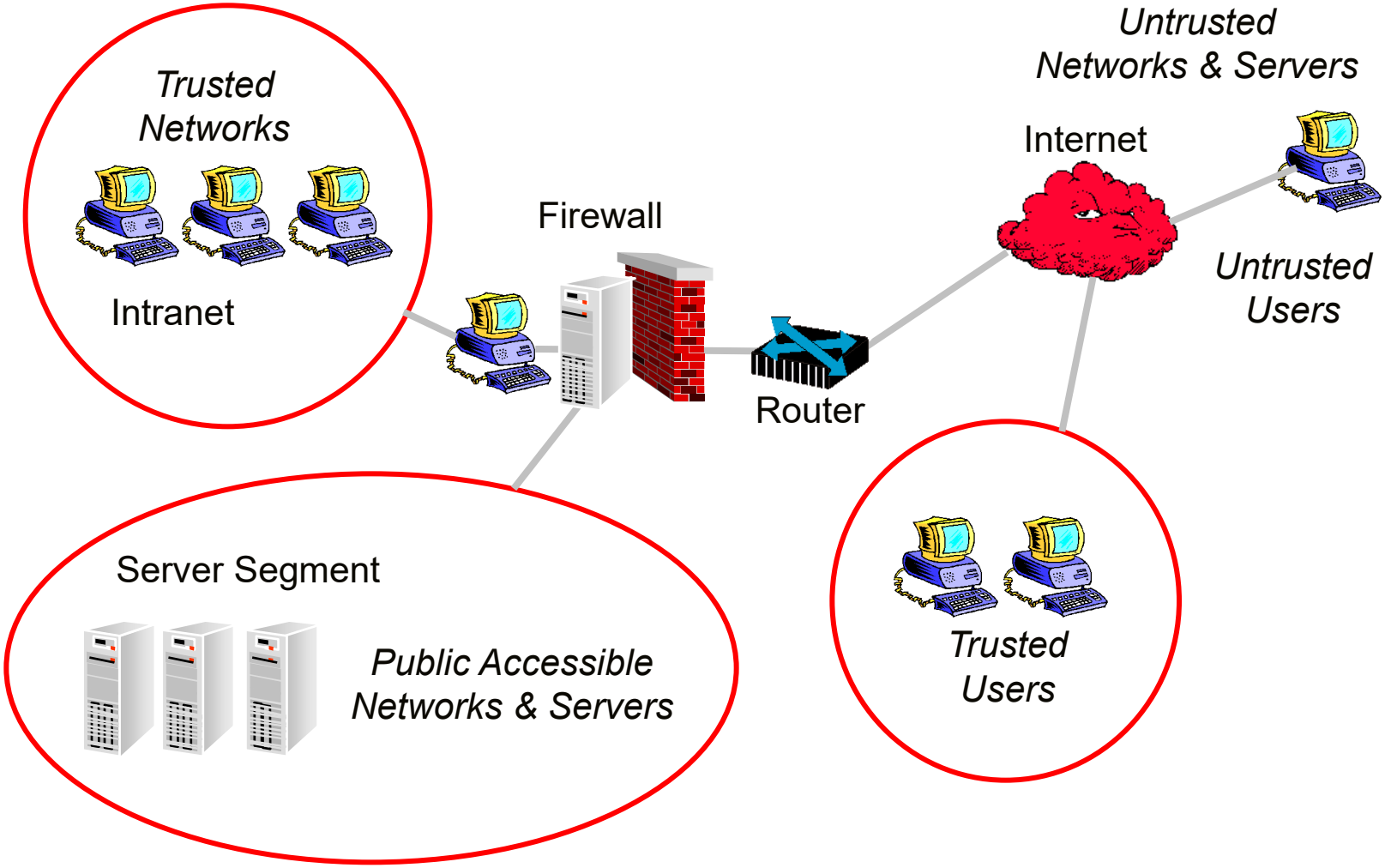
网络空间安全技术

第7章

防火墙技术及其发展

本章主要内容

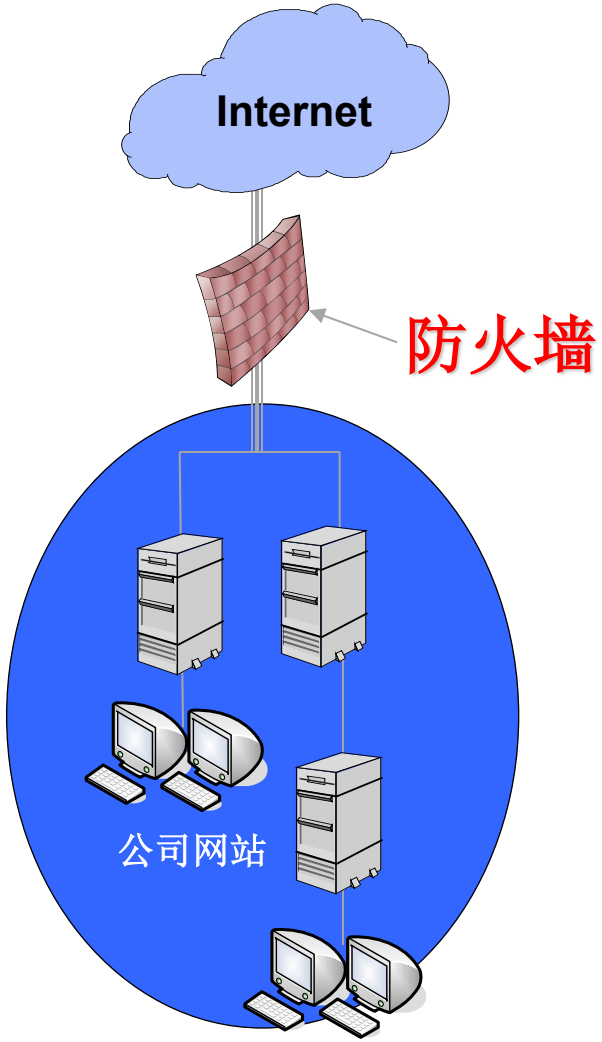
- 7.1 防火墙基本概念
- 7.2 防火墙发展历程
- 7.3 防火墙核心技术
- 7.4 防火墙体系结构
- 7.5 防火墙功能与原理
- 7.6 防火墙的接入方式
- 7.7 防火墙的典型应用
- 7.8 防火墙性能
- 7.9 防火墙局限性
- 7.10 防火墙的两个争议
- 7.11 WAF技术


Trusted
Networks
Intranet
Firewall
Router
Untrusted
Networks & Servers
Internet
Untrusted
Users
Server Segment
Public Accessible
Networks & Servers
Trusted
Users

7.1 防火墙的基本概念

防火墙（FireWall）定义：

- 在网络间（内部/外部网络、不同信息级别）提供**安全连接**的设备；
- 用于**实现和执行**网络之间通信的**安全策略**



5 防火墙描述

防火墙的目的是在不同的安全域之间建立安全控制点，根据预先定义的访问控制策略和安全防护策略，解析和过滤经过防火墙的数据流，实现向被保护的安全域提供访问可控的服务请求。此外，适用于下一代互联网网络环境的防火墙的协议栈除支持 IPv4 技术外，还能够支持 IPv6、IPv4/IPv6 过渡技术。

防火墙保护的资产是受安全策略保护的网络服务和资源等，此外，防火墙本身及其内部的重要数据也是受保护的资产。防火墙通常以路由模式或透明模式运行，且一般将网络划分为若干个安全域，通过安全策略实现对不同安全域间服务和访问的审计和控制。

图 1 是防火墙的一个典型运行环境。它将网络分为内部网络、外部网络和 DMZ 三个区域。内部网络是一个可信区域，外部网络是一个不可信区域，DMZ 中的服务器可以向外部网络和内部网络用户提供应用服务。

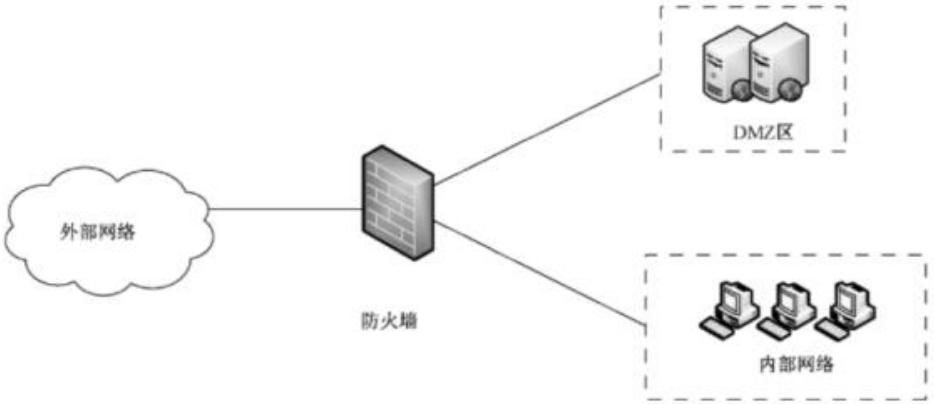
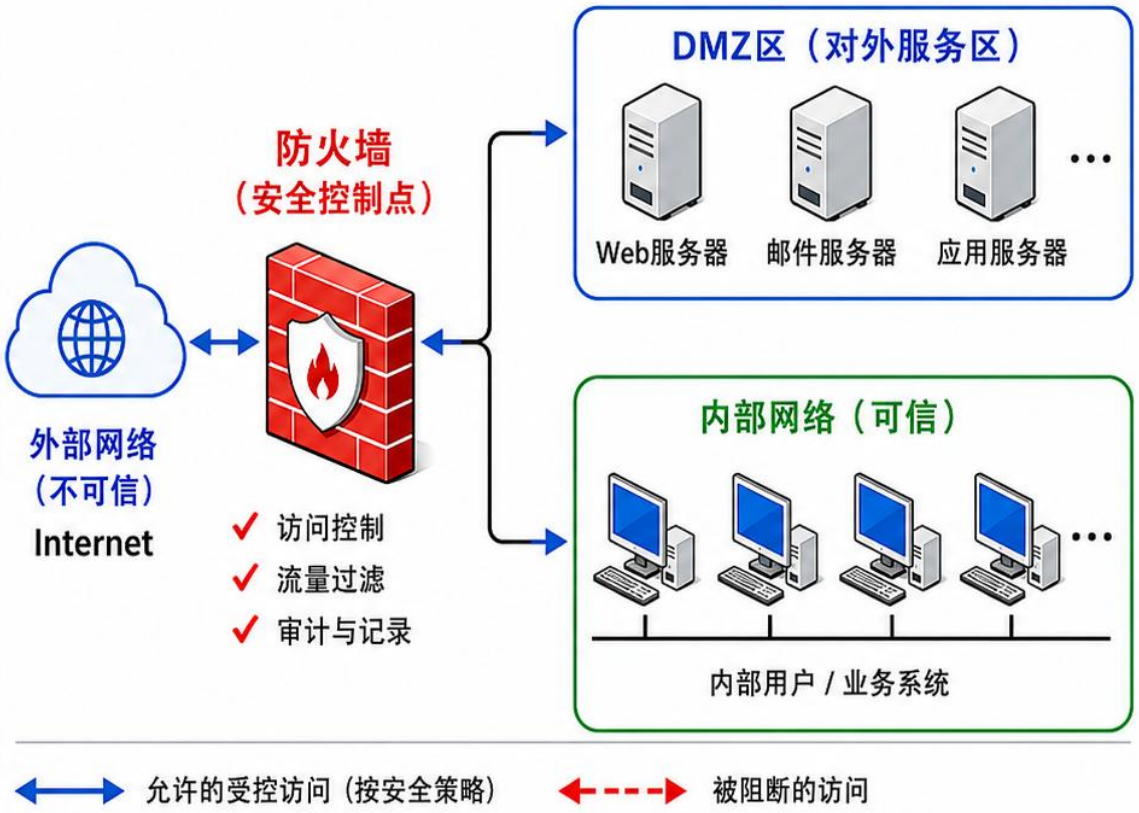


图 1 防火墙典型运行环境

防火墙的典型运行环境与基本作用

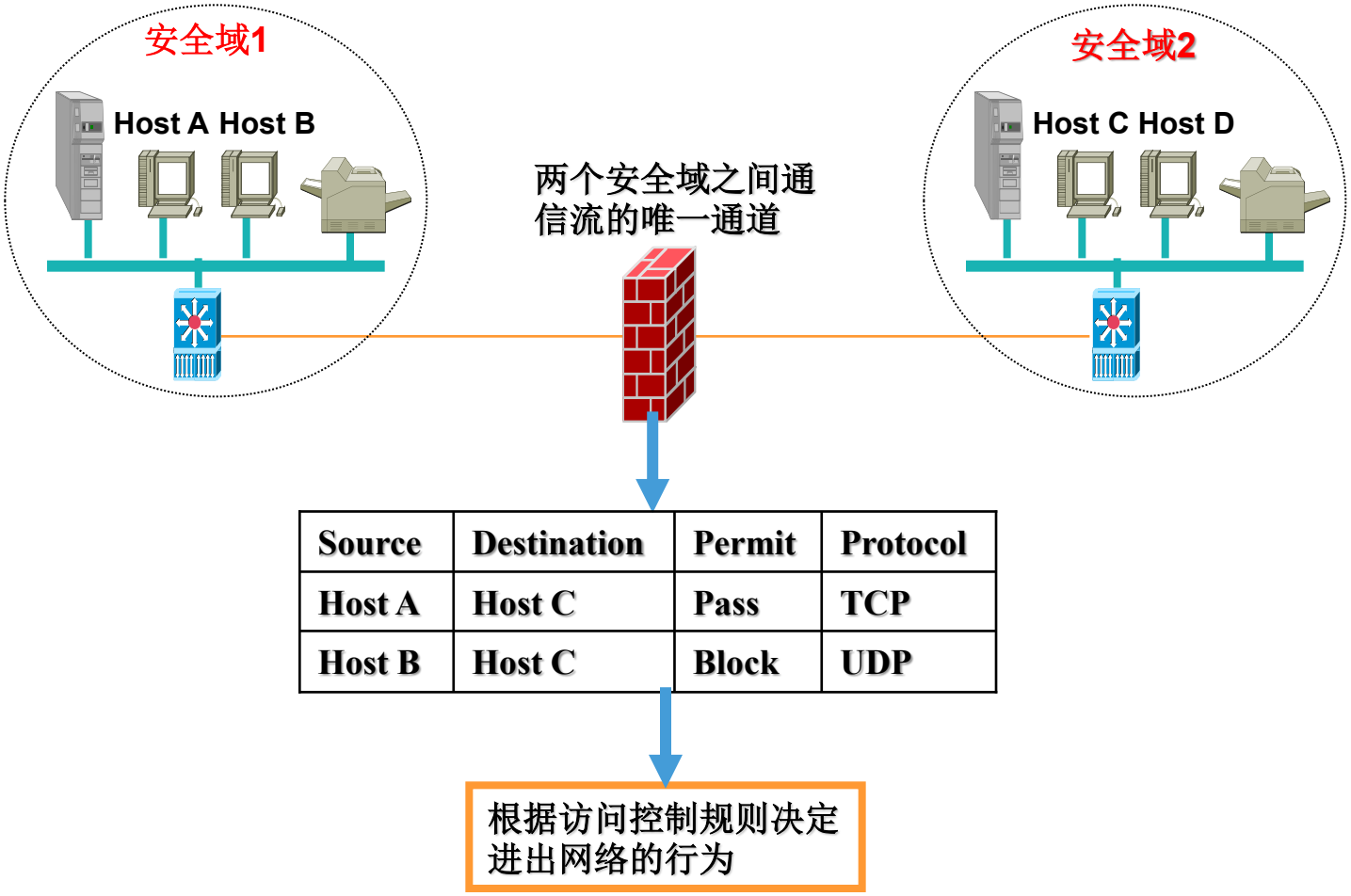
核心要点

- 在不同安全域之间建立**安全控制点**
- 依据安全策略对进出流量进行**过滤、审计与访问控制**
- 将网络划分为**外部网络、DMZ区和内部网络**
- DMZ中的服务器可向外部与内部用户提供**受控服务**



一句话理解

防火墙的本质，是在**可信网络**与**不可信网络**之间实施**策略控制**与**安全隔离**。



Source	Destination	Permit	Protocol
Host A	Host C	Pass	TCP
Host B	Host C	Block	UDP

根据访问控制规则决定进出网络的行为

防火墙（FireWall）定义：一种高级访问控制设备，置于不同网络安全域之间，它通过相关的安全策略来控制（允许、拒绝、监视、记录）进出网络的访问行为。

为什么需要防火墙?

城门失火，殃及池鱼。

- 阻止来自不可信网络的攻击
- 保护关键数据的完整性
- 维护客户对企业或机构的信任

随着互联网的不断发展，许多企业和机构的业务都逐渐变得与互联网密切相关，为什么他们需要一个防火墙。有三个关键原因：

1、最重要的原因是防火墙可以阻止来自不可信网络的攻击。在过去十几年中，网络攻击的数量在不断递增。

2、因为防火墙可以保护内部网络的信息，如客户的个人资料或研发数据等不被窃取、篡改或删除。

3、随着越来越多的网络失泄密事件的不断发生，对于一些如银行、证券等机构，通过部署防火墙等网络安全设备，可以很大程度地减少由于攻击而造成的信誉受损的风险。

为什么需要防火墙？

城门失火，殃及池鱼。

防火墙的价值：让外部访问可控，让内部系统更安全。

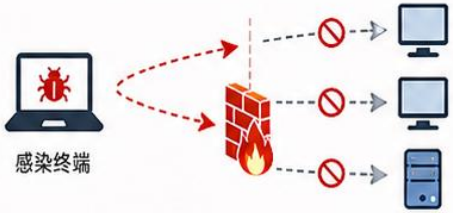
阻止来自不可信网络的攻击 | **保护**关键数据的完整性 | **维护**客户对企业或机构的信任

例1：学校官网可以开放，但教务数据库不能暴露

- 允许外部用户访问学校官网（80/443端口）
- 禁止外部直接访问数据库端口（如3306）
- 既保证业务可访问，又保护成绩和个人信息

对应：阻止攻击 + 保护关键数据

例2：一台终端中毒，不能让整个内网都被感染



- 教师或学生误点钓鱼邮件，电脑感染木马
- 若无防火墙/隔离策略，攻击可能横向扩散
- 通过限制异常连接，阻断对核心系统的继续攻击

这就是“城门失火，殃及池鱼”的网络安全含义

例3：银行、医院、政务系统必须保护核心数据与信任

- 外部用户可访问业务入口，如网上银行、挂号平台、政务服务
- 核心账户、病历、审批等数据应放在内部受保护区域
- 防止数据泄露、篡改和机构公信力受损

对应：维护客户/公众信任

一句话理解

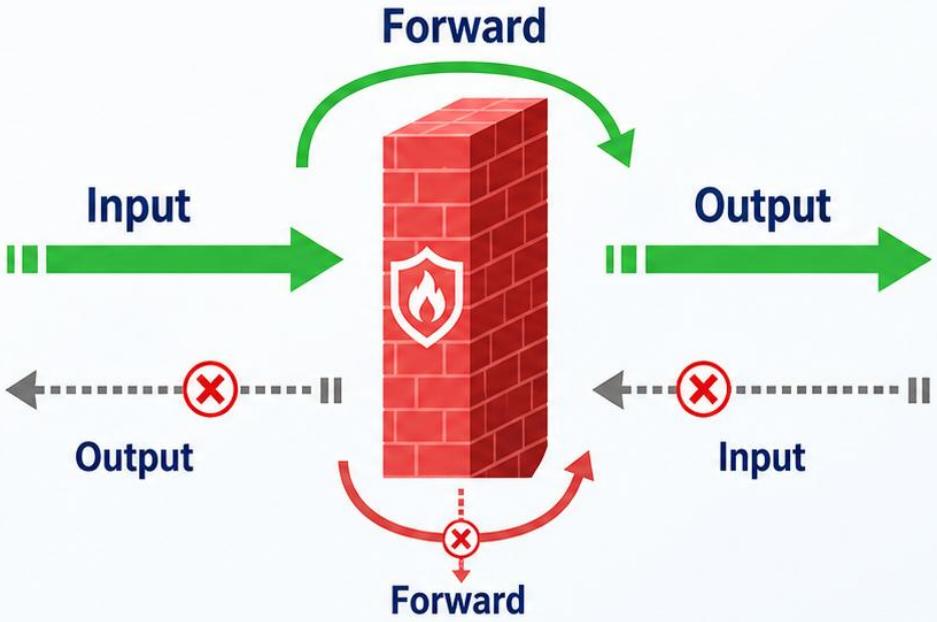
防火墙不是简单地“把网络断开”，而是在 **允许业务访问** 和 **阻断非法访问** 之间建立 **安全边界**。

防火墙做什么？

过滤！过滤！过滤！

防火墙过滤的核心作用

- 实现一个公司的安全策略
- 创建一个阻塞点
- 记录 Internet 活动
- 限制网络暴露



本质： 通过对进出网络的数据流进行过滤与控制，实现安全策略落地。

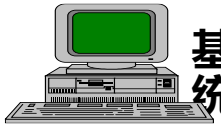
7.2 防火墙发展历程

基于路由器的防火墙

- 在路由器中通过ACL规则来实现对数据包的控制；
- 过滤判断依据：地址、端口号、协议号等特征

防火墙工具套

- 软件防火墙的初级形式，具有审计和告警功能
- 对数据包的访问控制过滤通过专门的软件实现
- 与第一代防火墙相比，安全性提高了，价格降低了



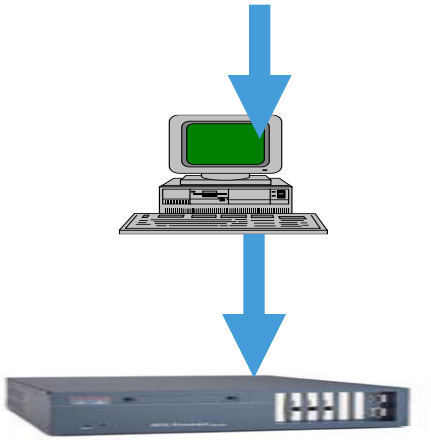
基于通用操作系统的防火墙

- 是批量上市的专用软件防火墙产品
- 安装在通用操作系统之上
- 安全性依靠软件本身和操作系统本身的整体安全

基于安全操作系统的防火墙

- 防火墙厂商具有操作系统的源代码，并可实现安全内核
- 功能强大，安全性很高
- 易于使用和管理
- 是目前广泛应用的防火墙产品

7.2 防火墙发展历程



- 20世纪80年代，最早的防火墙几乎与路由器同时出现，第一代防火墙主要基于包过滤（Packet filter）技术，是依附于路由器的包过滤功能实现的防火墙；随着网络安全重要性和性能要求的提高，防火墙渐渐发展为一个独立结构的、有专门功能的设备。
- 到1989年，贝尔实验室最早推出了第二代防火墙，即电路层防火墙；到20世纪90年代初，开始推出第三代防火墙，即应用层防火墙（或者叫做代理防火墙）；
- 到1992年，USC信息科学院开发出了基于动态包过滤（Dynamic packet filter）技术的，后来演变为目前所说的状态检测（Stateful inspection）技术。 1994年，市面上出现了第四代防火墙，即以色列的CheckPoint公司推出的基于这种技术的商业化产品；
- 到1998年，NAI公司推出一种自适应代理（Adaptive proxy）技术，并在其产品Gauntlet Firewall for NT中得以实现，给代理类型的防火墙赋予了全新的意义，可以称之为第五代防火墙。这种类型的防火墙采用动态设置包过滤规则的方法，避免静态包过滤所具有的问题。采用这种技术的防火墙对通过其建立的每一个连接都进行跟踪，并且根据需要可动态地在过滤规则中增加或更新条目。

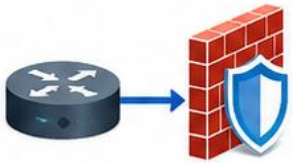
西南交通大学 Southwest Jiaotong University

7.2 防火墙发展历程

从包过滤到自适应代理，防火墙不断向更智能、更精细的安全控制演进

20世纪80年代

第一代防火墙



包过滤（Packet Filter）

- 最早的防火墙几乎与路由器同时出现
- 依附于路由器的包过滤功能实现
- 特点：结构简单，但规则较静态

1989年

第二代防火墙

电路层防火墙

- 贝尔实验室最早推出
- 开始从简单过滤走向连接层控制

20世纪90年代初

第三代防火墙

应用层防火墙 / 代理防火墙

- 能够面向应用层进行控制
- 也被称为代理防火墙
- 安全控制粒度进一步提升

1992–1994年

第四代防火墙

动态包过滤 → 状态检测

- 1992年 USC 信息科学院提出动态包过滤
- 后来演变为状态检测（Stateful Inspection）技术
- 1994年 Check Point 推出基于该技术的商业化产品

1998年

第五代防火墙

自适应代理（Adaptive Proxy）

- NAI 推出自适应代理技术
- 在 Gauntlet Firewall for NT 中得到实现
- 可跟踪每个连接，并动态增删过滤规则

演进主线

核心 takeaway

防火墙的发展，本质上是从“**粗粒度阻断**”走向“**面向连接、状态与应用的精细化安全控制**”。

防火墙执行的标准

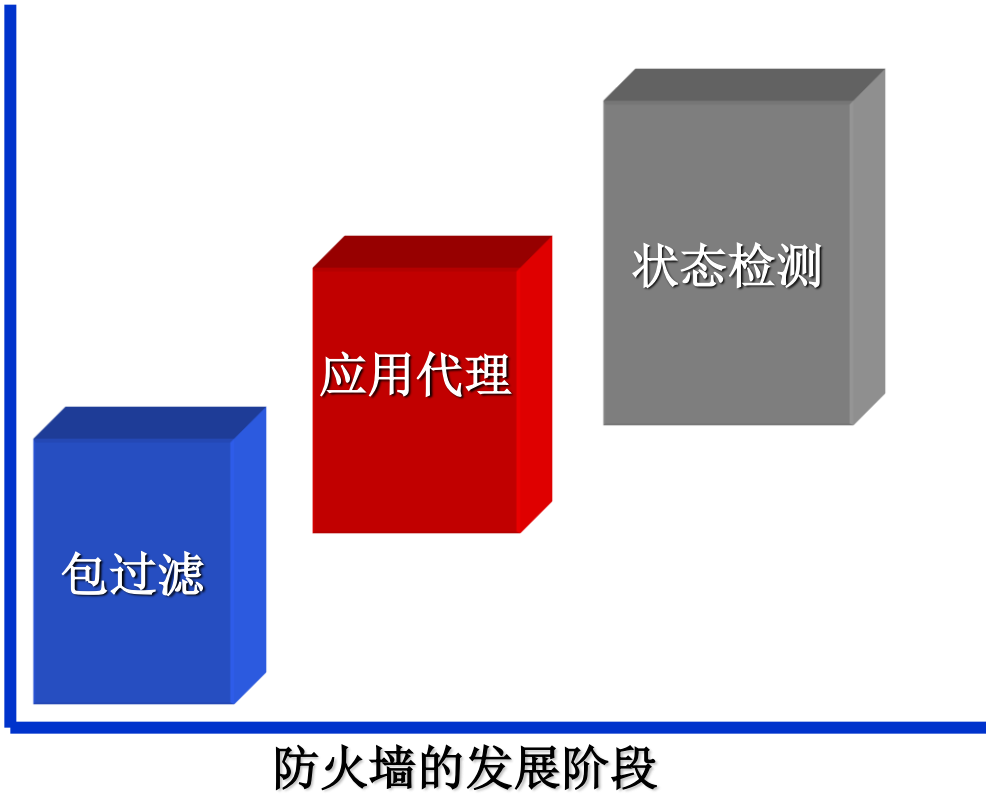
- GB/T 18019-1999 信息技术包过滤防火墙安全技术要求
- GB/T 18020-1999 信息技术应用级防火墙安全技术要求
- GB/T 18336-2001 信息技术安全性评估准则
- GB/T 17900-1999 网络代理服务器的安全技术要求
- GB/T 18018-1999 路由器安全技术要求

这些标准从安全环境、安全目标、安全要求、基本原理等方面对防火墙的各种指标进行了规定。

7.3 防火墙的核心技术

防火墙的分类

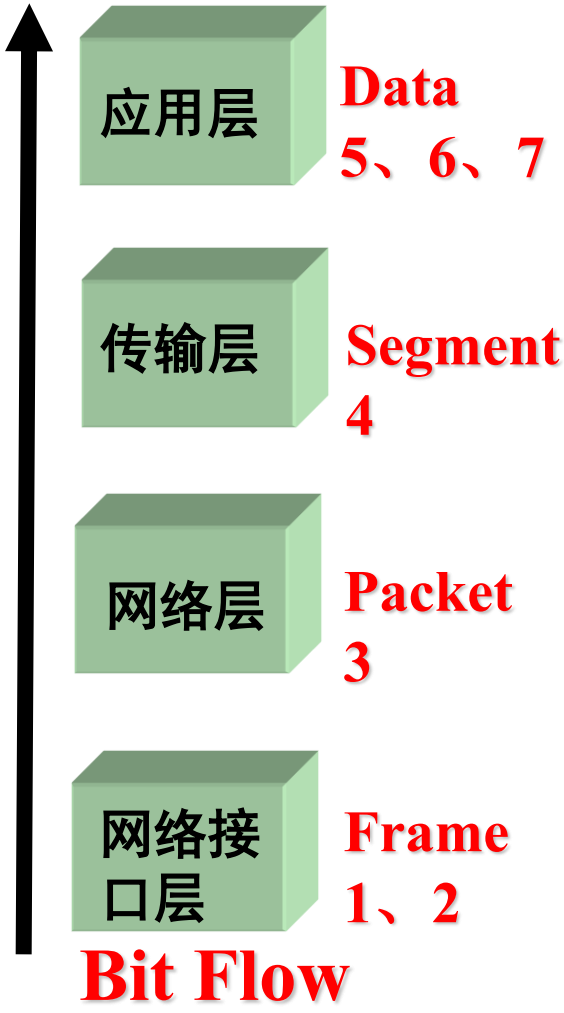
- 防火墙从实现方式上来分，可分为硬件防火墙和软件防火墙两类。硬件防火墙通常部署在内、外部网络之间，通过软、硬件结合的方式来达到隔离内、外部网络的目的；软件防火墙可以在一个独立的机器上运行，通过一定的规则来达到限制非法用户访问的目的。
- 从技术发展阶段来看，防火墙可分为包过滤、应用代理和状态检测等几大类型。



防火墙的相关技术

- 包过滤技术
- 应用代理技术
- 状态检测技术

防火墙的检测与过滤技术



- 包过滤（Packet Filtering）：工作在网络层，仅根据数据包头中的IP地址、端口号、协议类型等标志确定是否允许数据包通过。
- 应用代理（Application Proxy）：工作在应用层，通过编写不同的应用代理程序，实现对应用层数据的检测和分析。
- 状态检测（Stateful Inspection）：工作在2~4层，访问控制方式与1同，但处理的对象不是单个数据包，而是整个连接，通过规则表和连接状态表，综合判断是否允许数据包通过。
- 完全内容检测（Compelete Content Inspection）：工作在2~7层，不仅分析数据包头信息、状态信息，而且对应用层协议进行还原和内容分析，有效防范混合型安全威胁。

防火墙技术--包过滤（Packet Filter）

- 在网络层检查数据包
- 简单的拒绝或接受策略模型
- 无法识别更高层协议

包过滤防火墙的工作原理

- 简单包过滤防火墙不检查数据区
- 简单包过滤防火墙不建立连接状态表
- 前后报文无关
- 应用层控制很弱

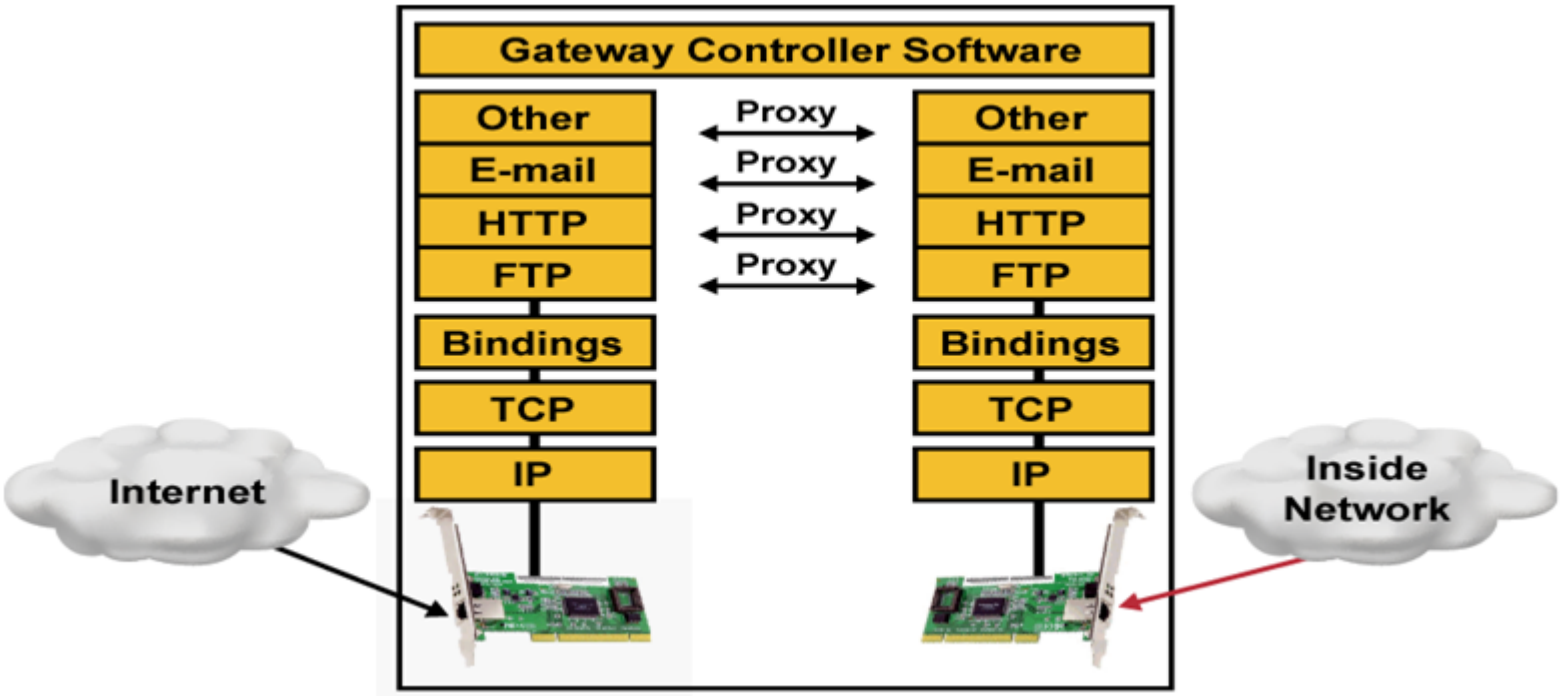
包过滤技术（Packet Filter）

包过滤防火墙具有以下特点：

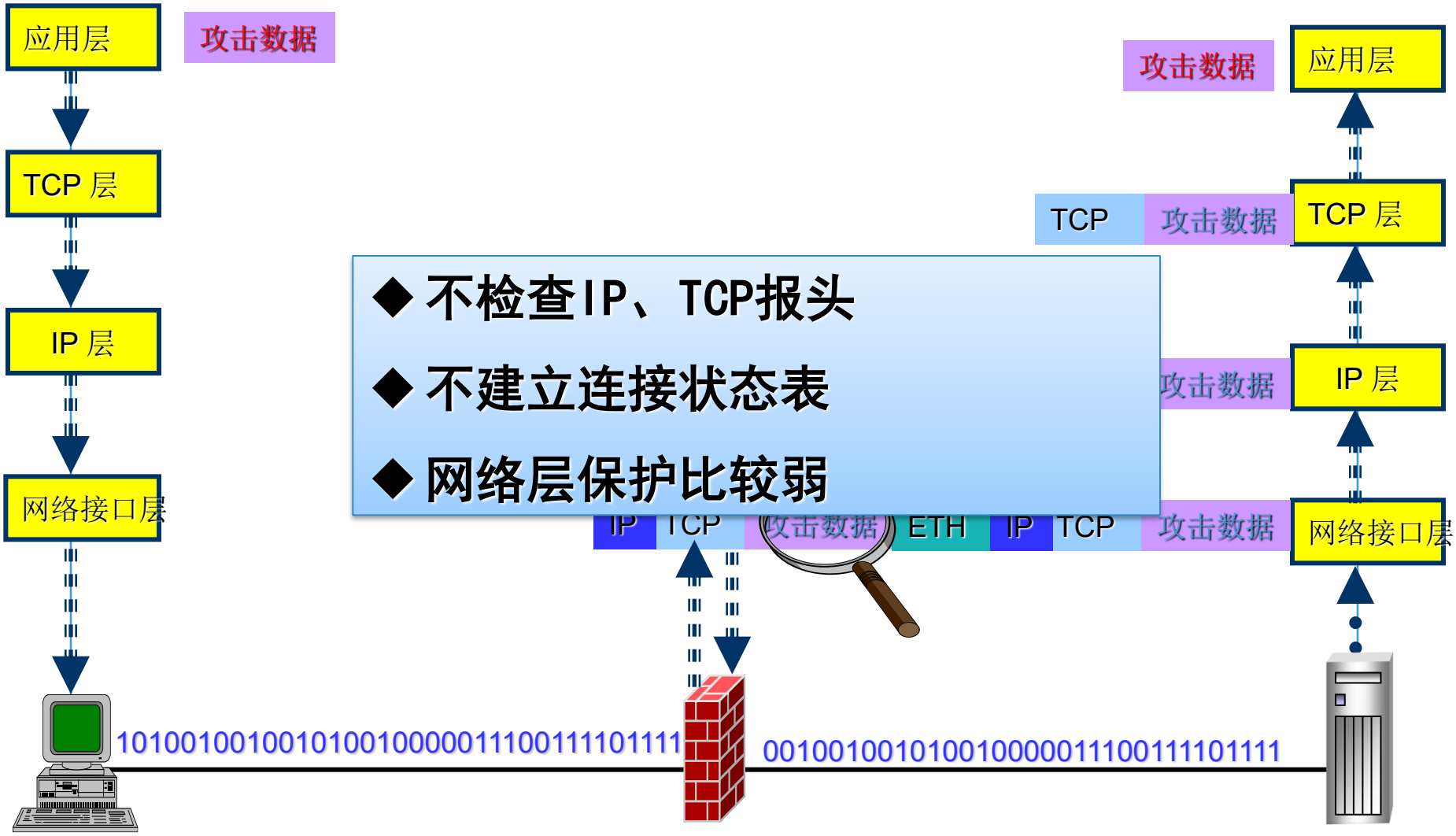
- 优点：
  - 只对数据包的 IP 地址、 TCP/UDP 协议和端口进行分析，规则简单，处理速度较快
  - 易于配置
  - 对用户透明-用户访问时不需要提供额外的密码或使用特殊的命令
- 缺点：
  - 检查和过滤器只在网络层-不能识别应用层协议或维持连接状态
  - 安全性薄弱-不能防止IP欺骗等
  - 静态策略可能成为漏洞

应用网关或代理（Application Gateway or Proxy）

- 在应用层检查数据包
- 能够对应用或内容进行过滤 – 如：禁止FTP的 “put”命令



应用代理防火墙的工作原理



应用网关或代理（Application Gateway or Proxy）

应用代理或网关防火墙具有以下特点：

- **优点：**
  - 可以检查应用层、传输层和网络层的协议特征，对数据包的检测能力比较强
  - 提供良好的安全性 - 所有数据的有效负载都在应用层进行检查
- **缺点：**
  - 支持的应用数量有限，无法很好的支持新的应用、技术和协议
  - 对用户不透明
  - 性能表现欠佳

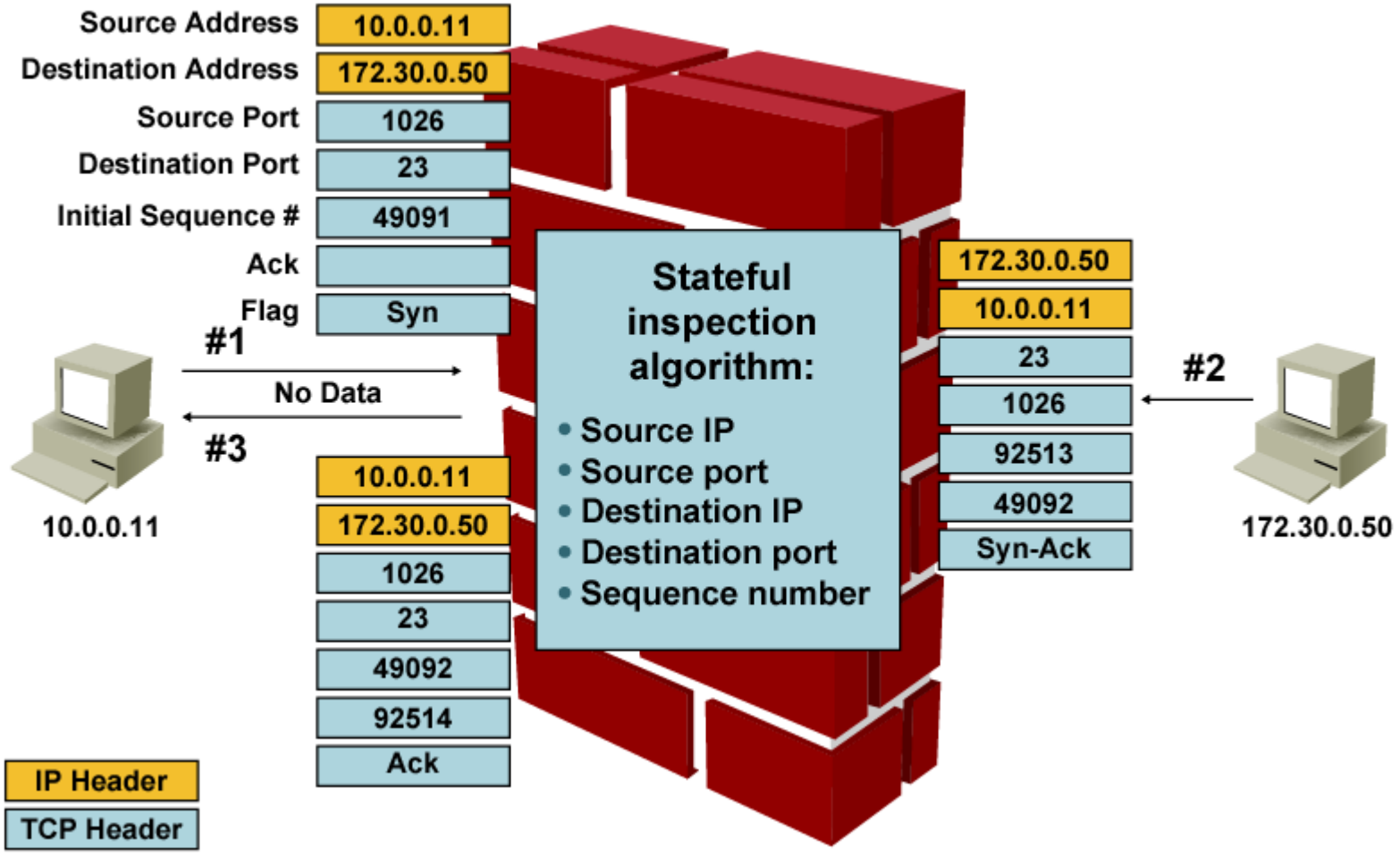
但是，自适应代理技术的出现让应用代理防火墙技术出现了新的转机，它结合了代理防火墙的安全性和包过滤防火墙的高速度等优点，在不损失安全性的基础上大大提高了代理防火墙的性能。

状态检测防火墙（Stateful Inspection）

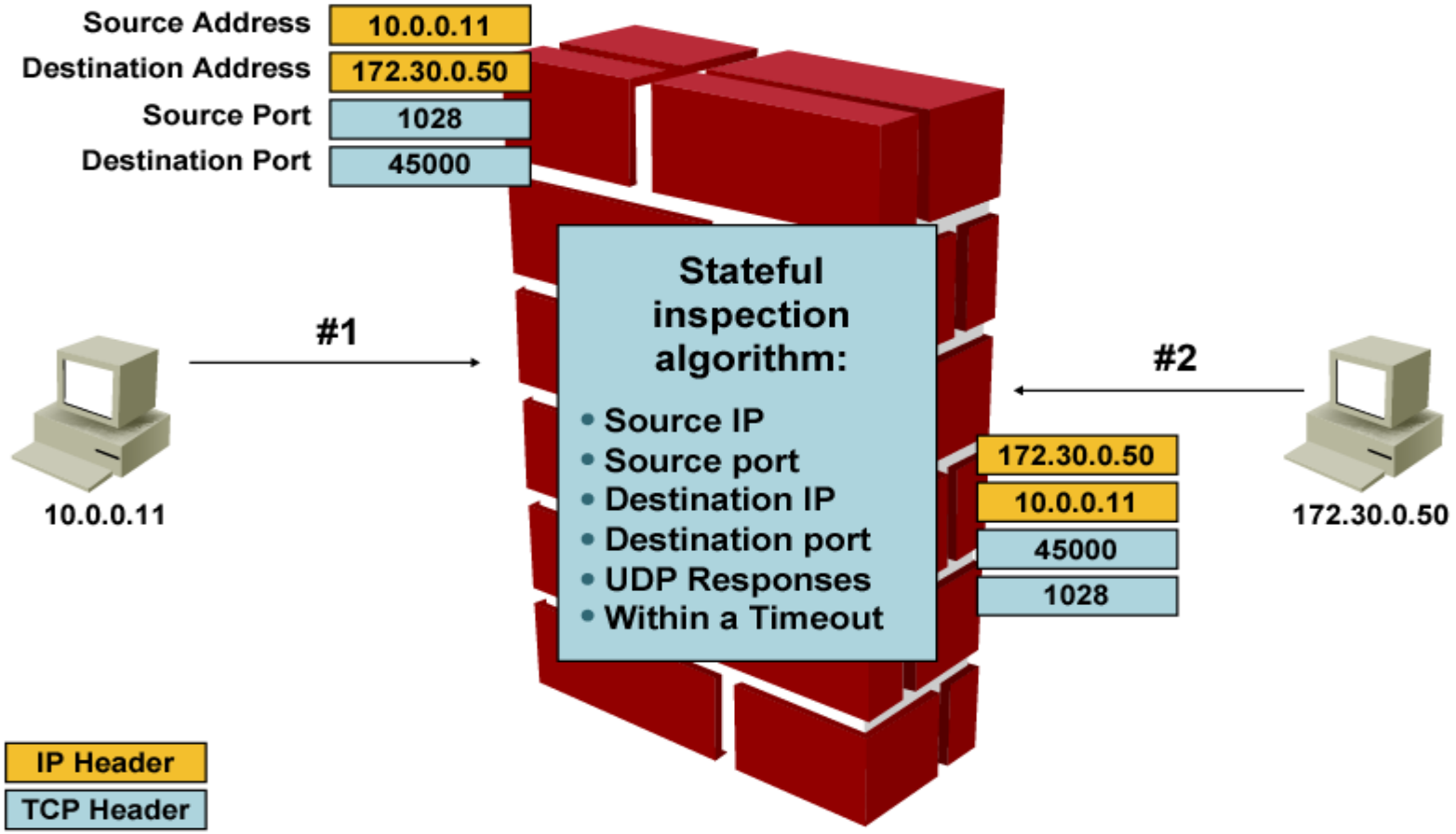
- 内置TCP/IP协议状态机，创建状态表用于维护连接上下文，检查每个会话连接的合法性（是否符合TCP/IP通信原理和特征）。
- 能够识别和监听常用动态端口应用的协商过程，从而自动为动态应用建立通过防火墙的安全连接。

状态检测防火墙摒弃了包过滤防火墙仅考查数据包的 IP 地址等几个参数，而不关心数据包连接状态变化的缺点，在防火墙的核心部分建立状态连接表，并将进出网络的数据当成一个个的会话，利用状态表跟踪每一个会话状态。状态监测对每一个包的检查不仅根据规则表，更考虑了数据包是否符合会话所处的状态，因此提供了完整的对传输层的控制能力。

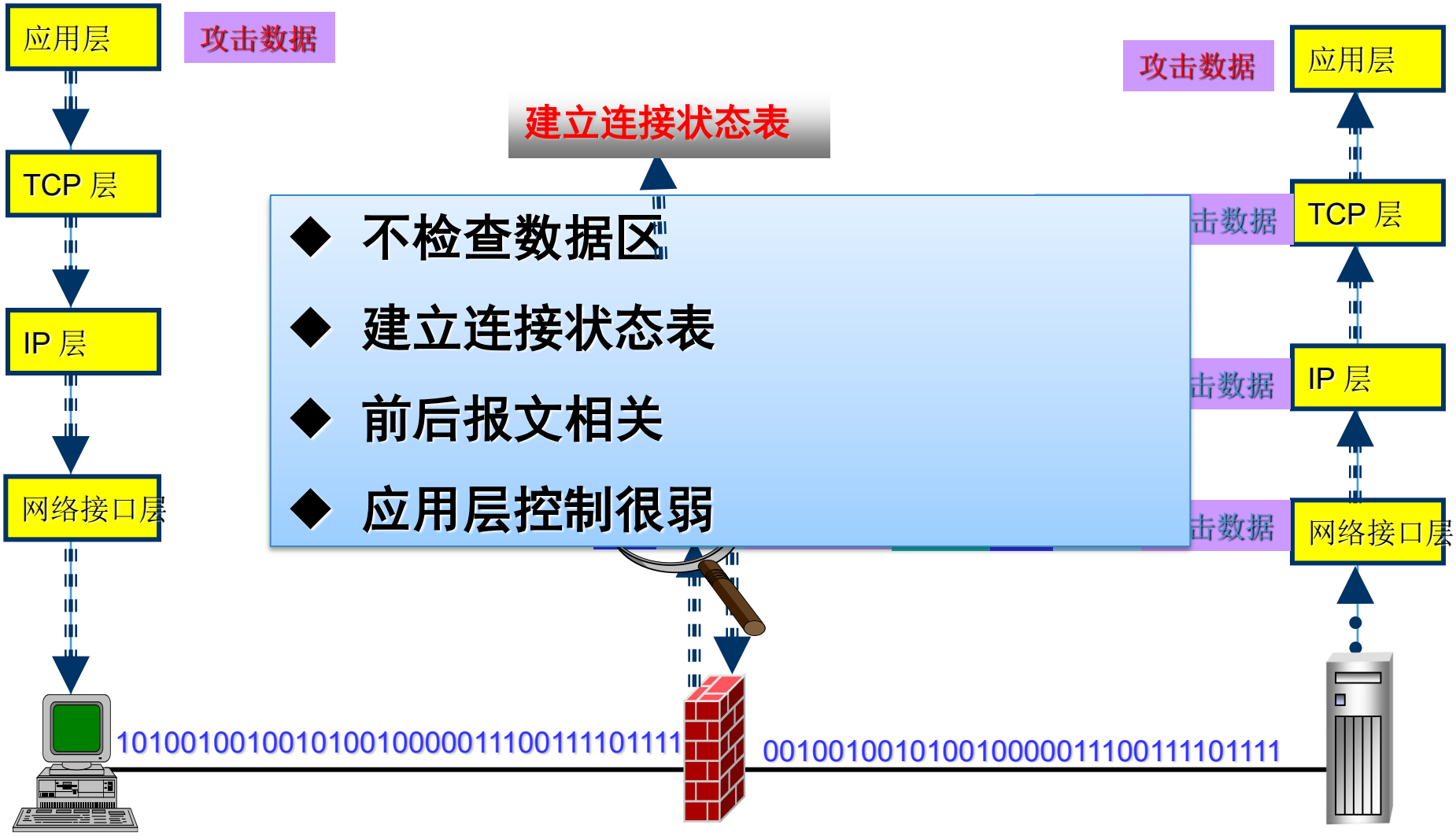
状态检测防火墙对TCP的状态处理



状态检测防火墙对UDP的状态处理



状态检测防火墙的工作原理



状态检测防火墙究竟检查哪些状态？

不是只看单个数据包，而是判断它是否属于一段合法会话

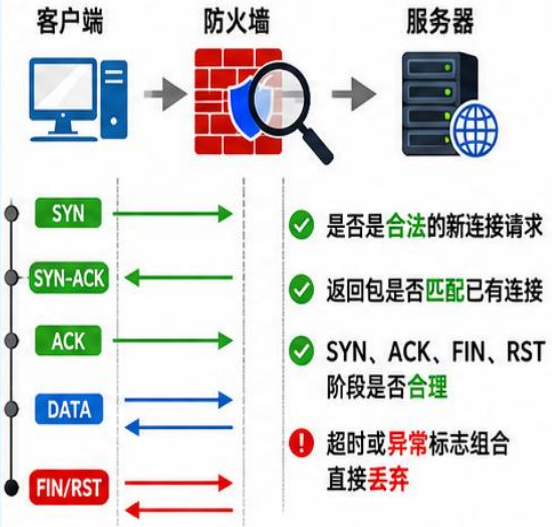
1. 状态表：先记住一条合法会话

源IP	目的IP	源端口	目的端口	协议	方向	状态	超时
10.0.0.11	172.30.0.50	53000	80	TCP	内→外	ESTABLISHED	60s

核心依据：五元组 + 方向 + 状态 + 超时

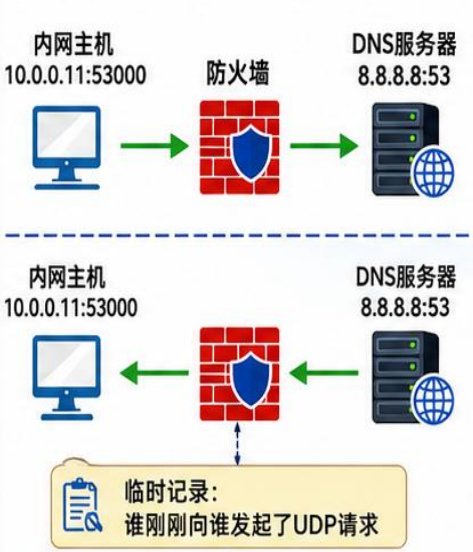
首包严查，合法后写入状态表

2. TCP：检查连接走到哪一步



TCP重点：连接阶段 + 返回流量 + 异常行为

3. UDP：没有握手，但可以建立临时状态



UDP重点：请求-响应关系 + 短超时

一句话理解

状态检测防火墙检查的不是“包本身”，而是“这个包是否属于合法会话”：TCP看连接阶段，UDP看请求响应与超时。

状态检测防火墙（Stateful Inspection）

状态检测防火墙具有以下特点：

- 性能大大提高
- 支持大量应用
- 在内核级实现检测过滤
  - 在所有接口对进/出的数据包进行状态检查
- 支持应用层协议检查
  - 在动态状态表中存储连接状态
  - 检查对外的连接并预先计算出将返回的连接

状态检测技术在大为提高安全防范能力的同时，也改进了流量处理速度。状态监测技术采用了一系列优化技术，使防火墙性能大幅度提升，能应用在各类网络环境中，尤其是在一些规则复杂的大型网络上。

从 2000 年开始，国内的著名防火墙公司都开始采用这一新的体系架构。

三类防火墙的形象化对比

为什么状态检测防火墙在保证安全性的同时，性能通常更优？

1 包过滤防火墙

每个数据包都单独检查

- 只看源/目的IP、端口、协议
- 不理解连接上下文
- 规则简单，但每包都要重复匹配

安全理解：低到中　　性能：中

2 状态检测防火墙

主流方案

首包严格检查，后续快速查表

建立状态表（State Table）

IP	端口	状态	超时
10.0.0.2	52344	ESTABLISHED	60s
192.168.1.5	80	ESTABLISHED	60s
10.0.0.3	443	ESTABLISHED	60s
...		...	

快速查表匹配 → 允许

- 识别会话/连接上下文
- 自动放行合法返回流量
- 减少重复规则匹配
- 安全性与性能较均衡

安全理解：中到高　　性能：高

3 代理防火墙（应用层）

由防火墙代替双方通信

- 深入到应用层检查
- 可以解析协议与内容
- 安全控制最细
- 但处理开销大、速度较慢

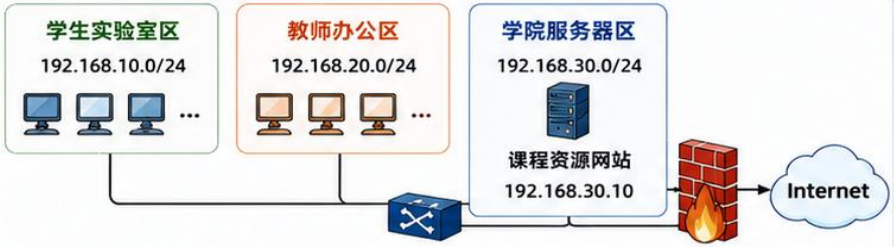
安全理解：高　　性能：较低

对比维度	包过滤防火墙（1）	状态检测防火墙（2）	代理防火墙（应用层）（3）	趋势（从左到右）
检查粒度	粗粒度（仅网络层/传输层头部）	中等粒度（基于连接和状态信息）	最细粒度（深入到应用层内容）	粗 → 细
是否理解连接	无连接上下文	理解连接（会话/状态）	理解连接且理解应用层会话	无 → 有且深入
安全性	低到中	中到高（平衡最好）	高	低 → 高
性能	中	高	较低	高 ← 低

状态检测防火墙的优势在于：把“每包重复检查”变成“首包严查 + 后续查表”，因此比代理防火墙更轻量，又比简单包过滤更智能。

应用案例题：某学院网络出口防火墙选型

某高校计算机学院准备对网络出口进行安全改造，学院网络包括三个区域，需要满足不同区域的访问需求，并解决当前遇到的安全问题。



对外服务	学院对外提供一个课程资源网站，服务器地址为 192.168.30.10，只允许外部用户通过 HTTPS 访问。
教师办公区需求	需要访问外部网站、下载论文和登录学校业务系统，并记录访问的网址，阻止上传含有“身份证号、成绩单、学生名单”等敏感内容的文件。
学生实验室区需求	只允许访问课程网站和常用学习网站，不允许访问游戏、代理、网盘上传类网站。

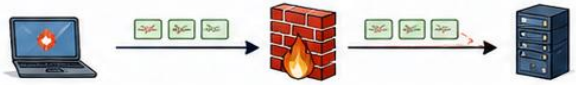
⚠ 最近学院遇到以下问题

1. 外部主机频繁扫描学院服务器区的 22、23、3389 等端口。
2. 学生实验室中有主机伪造连接报文，试图绕过简单访问控制规则。
3. 教师访问外部网站时，需要记录访问的网址，并阻止上传含有“身份证号、成绩单、学生名单”等敏感内容的文件。
4. 课程资源网站访问量较大，不能因为防火墙检查过深而明显降低访问速度。
5. 学院希望对不同流量采用不同防护方式，而不是所有流量都使用同一种防火墙。

问题

1. 对于外部端口扫描，应优先采用哪一类防火墙？为什么？

2. 对于“伪造连接报文绕过规则”的问题，包过滤防火墙为什么容易存在不足？状态检测防火墙如何改进？



3. 对于教师办公区访问外部网站并进行网址审计、敏感文件上传阻断，应采用哪一类防火墙？为什么？

4. 对于课程资源网站的大量 HTTPS 访问流量，是否适合全部交给代理防火墙处理？为什么？

5. 请为学院设计一个简要防火墙部署方案，说明哪些流量适合使用包过滤，哪些流量适合使用状态检测，哪些流量适合使用代理防火墙。

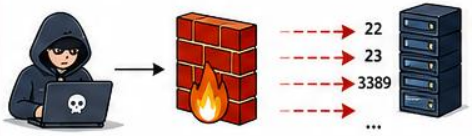
提示：包过滤防火墙、状态检测防火墙、代理防火墙各有特点，结合场景选择合适的防护方案，兼顾安全性与性能。

参考答案：不能让一种防火墙干所有活

本案例采用“三层分工，协同防护”的防火墙部署方案：外层快速挡住明显非法流量，中间检查连接是否合法，内层对敏感应用内容做细致审计。

1 外部端口扫描：优先用包过滤防火墙

端口扫描主要是访问不允许的 IP 和端口，规则明确，包过滤可以快速拦截。



策略示例

- ✅ 只允许外部访问 192.168.30.10 的 443 端口
- ❌ 禁止外部访问 22、23、3389 等管理端口
- ✅ 禁止访问不对外开放的服务器地址和端口

2 伪造连接报文：用状态检测防火墙

包过滤只看单个数据包，容易被伪造报文绕过；状态检测防火墙维护连接状态表，只有合法会话的后续报文才允许通过。

作用

- ✅ 维护连接状态表
- ✅ 只允许属于合法会话的报文通过
- ✅ 有效防止伪造连接报文、异常返回流量

3 网址审计与敏感内容阻断：用代理防火墙

需要理解应用层内容（URL、文件内容等），因此使用代理防火墙深入检查和控制。

主要功能

- ✅ 记录访问网址，审计访问行为
- ✅ URL 分类过滤（如游戏、代理、网盘等）
- ✅ 阻止上传含身份证号、成绩单等敏感文件
- ✅ 识别并阻断恶意网站和不安全内容

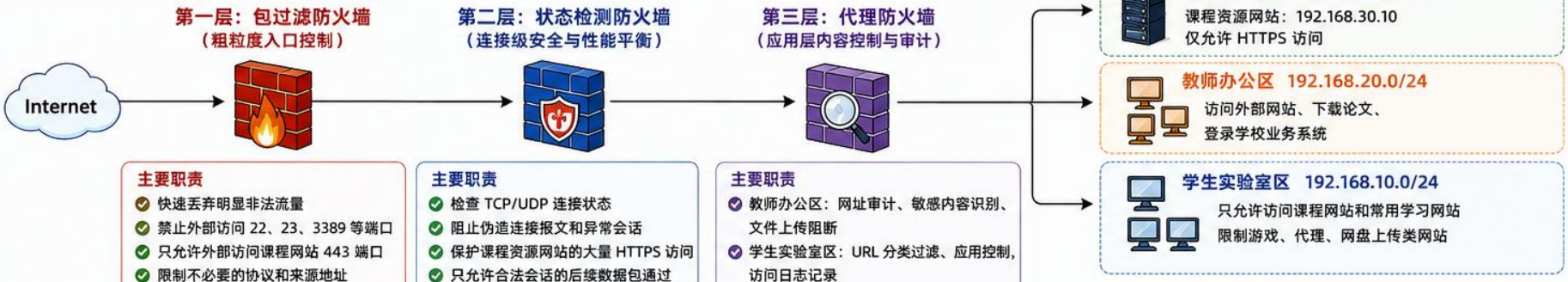
4 大量 HTTPS 访问：不宜全部交给代理防火墙

代理防火墙检查最细，但性能开销大；大量 HTTPS 访问主要交给状态检测防火墙处理，更适合保障安全与性能平衡。

原因

- ✅ 只需检查连接状态和目标端口是否合法
- ✅ 不需要逐个分析应用内容，性能更好
- ✅ 保证网站访问速度和系统可用性

5 简要部署方案：三层防护，分工明确



第一层：包过滤防火墙

- ✅ 快速丢弃明显非法流量
- ✅ 禁止外部访问 22、23、3389 等端口
- ✅ 只允许外部访问课程网站 443 端口
- ✅ 限制不必要的协议和来源地址

第二层：状态检测防火墙

- ✅ 检查 TCP/UDP 连接状态
- ✅ 阻止伪造连接报文和异常会话
- ✅ 保护课程资源网站的大量 HTTPS 访问
- ✅ 只允许合法会话的后续数据包通过

第三层：代理防火墙

- ✅ 教师办公区：网址审计、敏感内容识别、文件上传阻断
- ✅ 学生实验室区：URL 分类过滤、应用控制，访问日志记录

总结

包过滤防火墙
负责“先把明显不该来的挡住”

状态检测防火墙
负责“确认连接是不是真的”

代理防火墙
负责“看清访问内容到底在干什么”

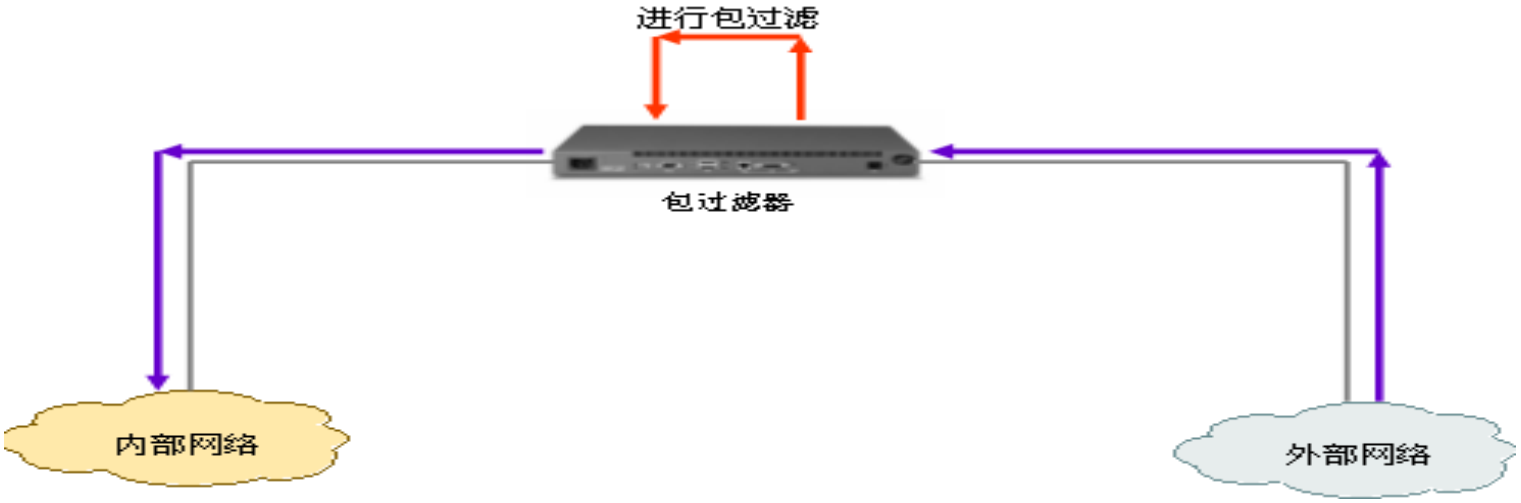
三者不是互相替代，而是分层配合，共同保障安全与效率！

完全内容检测防火墙的工作原理

7.4 防火墙体系结构

- 过滤路由器
- 多宿主主机
- 被屏蔽主机
- 被屏蔽子网

过滤路由器



❖ 过滤路由器（Filtering Router）

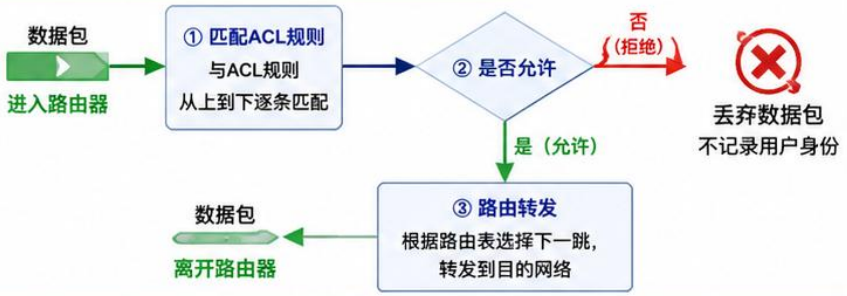
- 过滤路由器作为内外网连接的唯一通道，通过ACL策略要求所有的报文都必须在此通过检查，实现报文过滤功能。
- 它的缺点是一旦被攻陷后很难发现，而且不能识别不同的用户（没有日志记录）。

过滤路由器（Filtering Router）

过滤路由器是内外网络连接的唯一通道，通过 ACL（访问控制列表）策略对所有进出数据包进行检查和过滤。

1. 位置与作用

2. 工作流程（每个进出数据包都要经过检查）



3. ACL规则示例（从上到下匹配）

序号	规则	源地址	目的地址	协议	动作	说明
1	permit	192.168.1.0/24	any	tcp 80	允许	允许内网访问外部Web
2	permit	192.168.1.0/24	any	tcp 443	允许	允许内网访问外部HTTPS
3	deny	any	any	any	拒绝	拒绝其他所有访问
implicit deny		any	any	any	拒绝	默认隐式拒绝

匹配到第一条规则即停止匹配并执行动作！

4. 两个核心特点

检查所有报文

无论是从内部发往外部，还是从外部发往内部，都必须经过ACL检查后才能通过。

不能识别用户（无日志记录）

只能根据报文的五元组（源/目的IP、端口、协议）进行判断，**无法知道是哪个用户在访问，也不会记录用户行为日志。**

5. 优缺点对比

优点

- 结构简单，部署容易
- 性能高，转发速度快
- 成本低，适合边界入口控制
- 能有效阻止大部分非法访问

缺点

- 无法识别用户身份
- 无法记录用户行为日志
- 应用层检查能力有限
- 安全性弱于状态检测防火墙

6. 总结一句话

过滤路由器就像“网络大门的守卫”，只看数据包的“身份证”，按规则放行或拒绝，但不知道“谁在进出”。

过滤路由器通过 ACL 策略实现报文过滤，是最基础的网络安全防护手段，广泛用于企业和组织的边界防护。

多宿主主机

❖双宿主主机

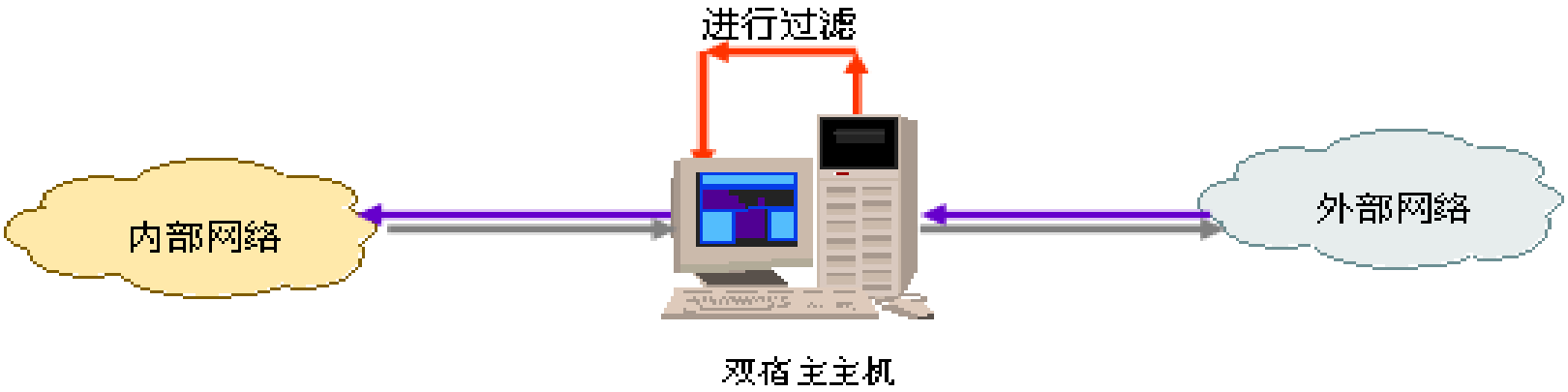
双宿主主机位于内部网和Internet之间，一般来说，是用一台装有两块网卡的堡垒主机做防火墙。

这两块网卡各自与受保护网和外部网相连，分别属于内外两个不同的网段。堡垒主机上运行着防火墙软件，可以转发应用程序，提供服务等。

堡垒主机的系统软件可用于维护系统日志。

双宿主主机这种体系结构非常简单，一般通过代理(Proxy) 来实现，或者通过用户直接登录到该主机来提供服务。

多宿主主机



❖双宿主主机（Dual Homed Gateway）

- ◆双宿主主机优于过滤路由器的地方是：堡垒主机的系统软件可用于维护系统日志。
- ◆它的致命弱点是：一旦入侵者侵入堡垒主机，则无法保证内部网络的安全。

双宿主主机（Dual Homed Gateway）

多宿主主机中的典型防护结构

⚠ 所有内外网络通信必须先到达堡垒主机，由其代理/应用服务处理后再转发，内网与外网之间不直接通信。

工作原理

1. 位于内网与外网之间，拥有两块网络接口
2. 所有访问先到堡垒主机，再由代理服务转发
3. 通过系统日志与代理机制实现访问控制和审计

核心特点

- 内外网物理隔离更清晰
- 可提供代理、鉴别与日志记录能力
- 比单纯包过滤更容易审计用户行为

优点与局限

优点

- 结构清晰
- 安全边界明显
- 便于管理与记录日志

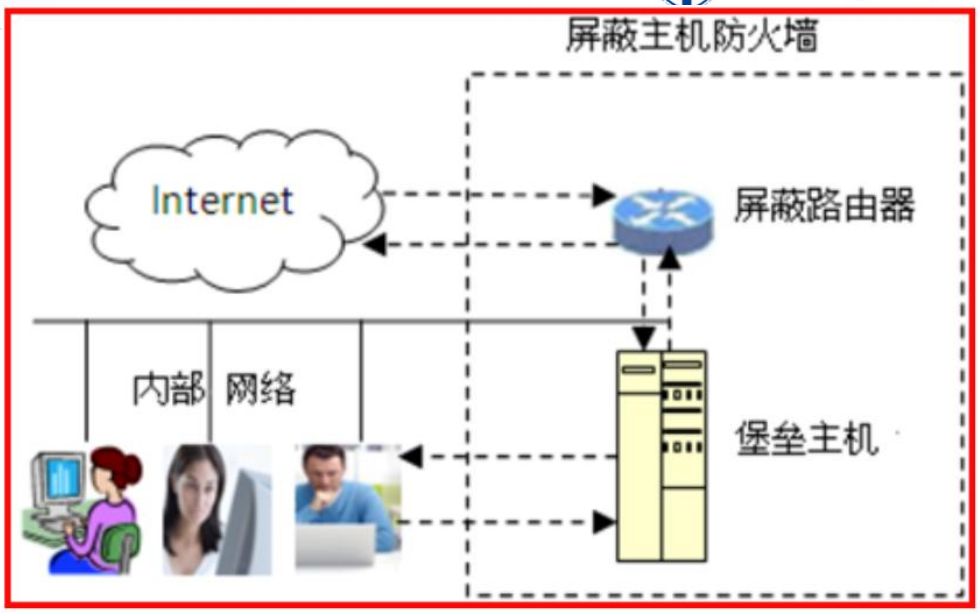
局限

- 性能可能成为瓶颈
- 对堡垒主机依赖强
- 一旦堡垒主机被攻陷，内网安全可能受到威胁

一句话理解

双宿主主机就是用一台具有两块网卡的堡垒主机，充当内外网络之间的**受控中介**。

被屏蔽主机



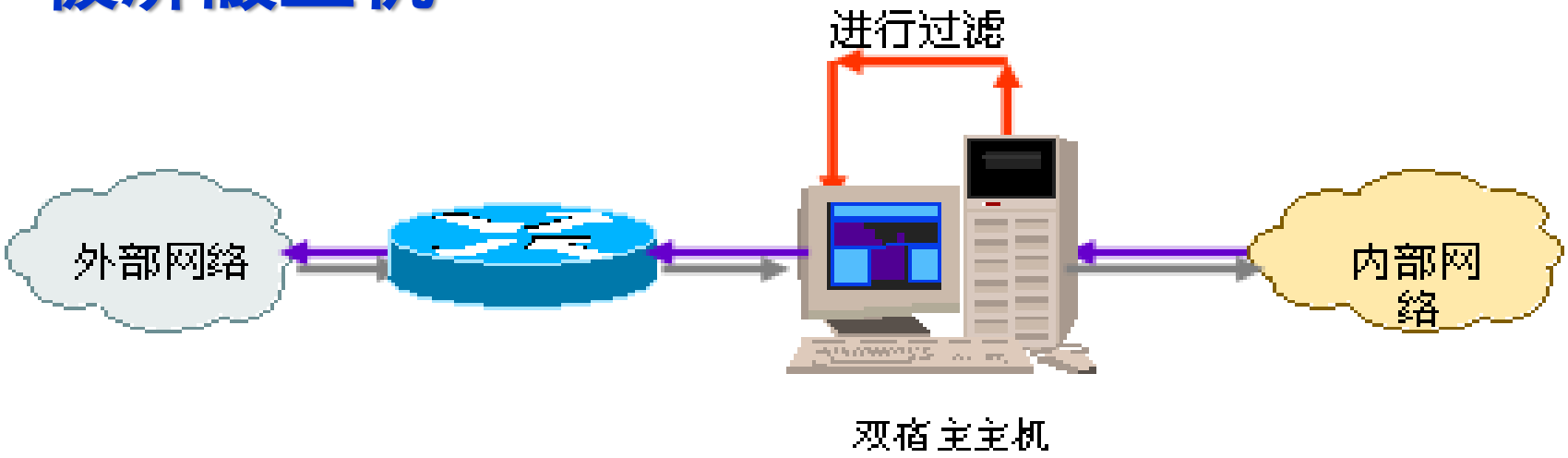
被屏蔽主机体系结构是指，通过一个单独的路由器和内部网络上的堡垒主机共同构成防火墙，主要通过数据包过滤技术实现内、外网络的隔离和对内网的保护。

在被屏蔽主机体系结构中，有两道屏障：屏蔽路由器、堡垒主机。

屏蔽路由器位于网络最边缘，负责与外网实施连接，参与外网的路由计算。屏蔽路由器仅提供路由和数据包过滤功能，因此屏蔽路由器本身较为安全。由于屏蔽路由器的存在，堡垒主机不再是直接与外网互连的双宿主主机，增加了系统的安全性。

堡垒主机连接内部网络，是唯一可以连接到外部网络系统的主机，也是外部用户访问内部网络资源必须经过的主机设备。堡垒主机通过数据包过滤，实现对内部网络的防护，并且仅仅允许通过特定的服务连接。堡垒主机可以提供代理功能，内部用户只能通过应用代理访问外部网络，堡垒主机成为外部用户唯一可以访问的内部主机。

被屏蔽主机

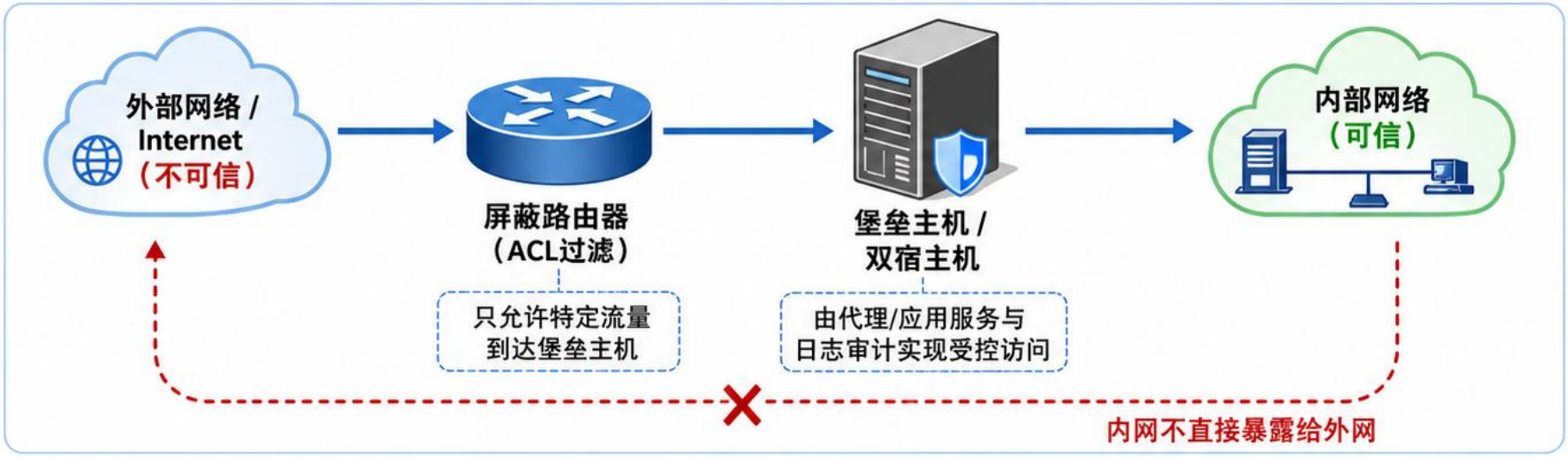


❖被屏蔽主机（Screened Host Gateway）

- ◆通常在路由器上设立ACL过滤规则，并通过堡垒主机进行数据转发，来确保内部网络的安全。
- ◆弱点：如果攻击者进入屏蔽主机内，内网就会受到很大威胁；这与双宿主主机受攻击时的情形差不多。

被屏蔽主机（Screened Host Gateway）

过滤路由器 + 堡垒主机的典型边界防护结构



工作原理

1. 屏蔽路由器位于边界，先按ACL规则过滤报文
2. 外部访问通常先到堡垒主机，再由其代理或转发服务
3. 堡垒主机可提供认证、日志记录和审计能力

核心特点

- 过滤路由器负责第一道包过滤
- 堡垒主机是对外提供服务的受控入口
- 内网主机一般不直接暴露给外网
- 比单纯包过滤更容易管理和记录访问行为

优点

- 安全边界更清晰
- 可结合代理、认证与日志审计
- 能减少内部网络被直接暴露的风险

局限

- 仍依赖堡垒主机的安全性
- 堡垒主机可能成为性能瓶颈
- 一旦堡垒主机被攻陷，内网可能受到较大威胁

一句话理解：被屏蔽主机 = 用屏蔽路由器**先过滤**，再由堡垒主机充当内外网之间的**受控中介**。

Target 2013 数据泄露案例

一个第三方供应商账号，如何一路进入支付系统并导致大规模数据泄露

攻击路径

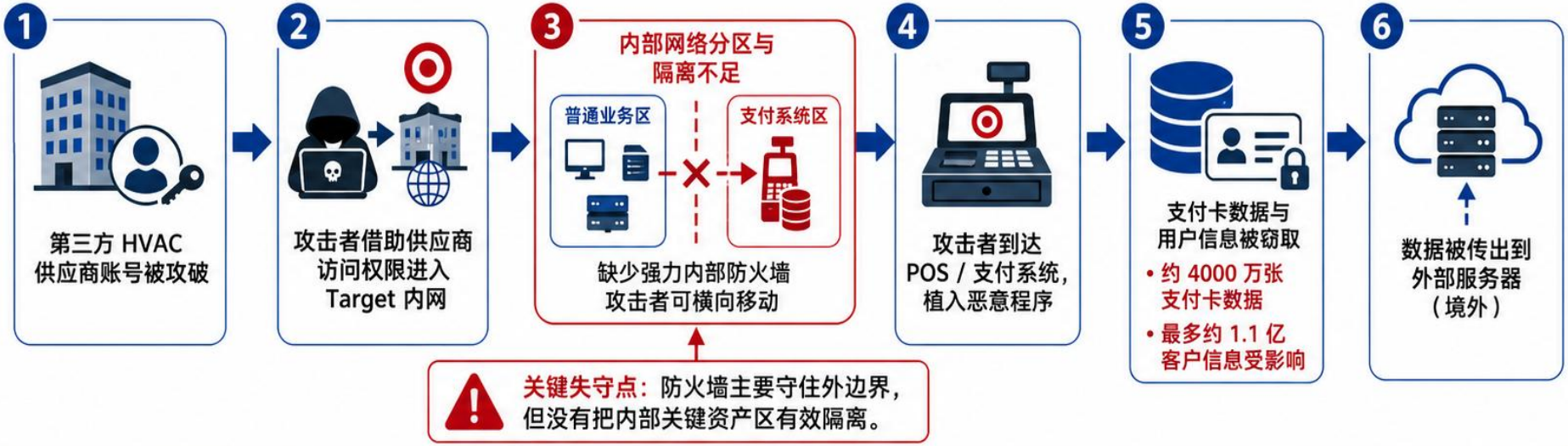
事件后果

- 约 4000 万张支付卡数据泄露
- 最多约 1.1 亿客户信息受影响
- 数据被传至境外服务器

这起事件最值得关注的，不只是攻击者从外部进来，而是进入内网后还能继续到达支付系统。

案例1：Target 2013 数据泄露

只有边界防火墙，不足以阻止内网横向移动

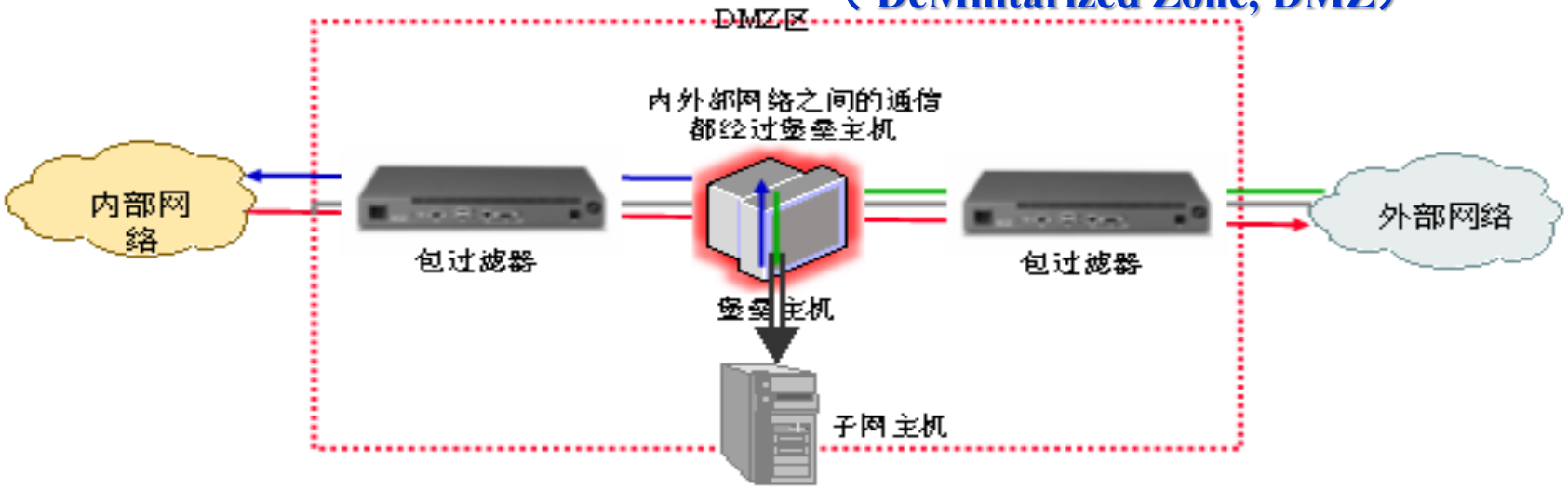


核心启示

1. 只有边界防火墙，不够。
2. 关键系统必须做内网分区与东西向访问控制。
3. 支付系统等高价值资产要与普通网络严格隔离。

被屏蔽子网

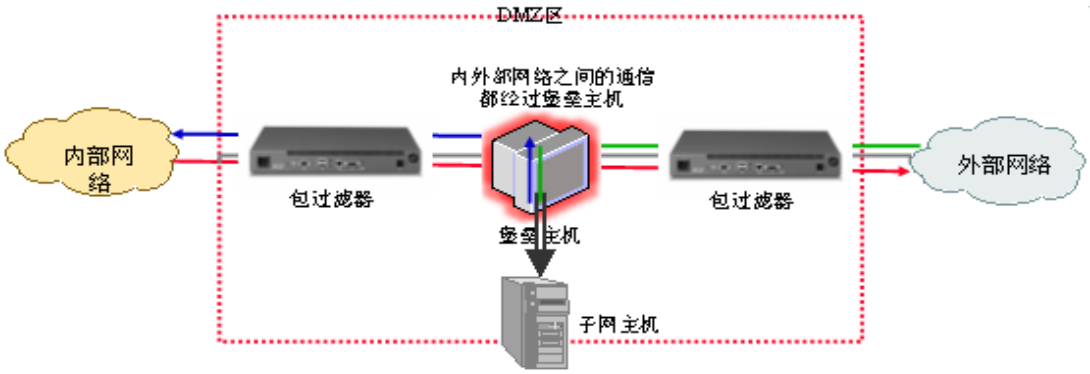
（DeMilitarized Zone, DMZ）



❖ 被屏蔽子网 （Screened Subnet）

- ◆ 这种结构是在内部网络和外部网络之间建立一个被隔离的子网，用两台过滤路由器分别与内部网络和外部网络连接，中间通过堡垒主机进行数据转发。
- ◆ 特点：如果攻击者试图进入内网或者子网，他必须攻破过滤路由器和双宿主主机，然后才可以进入子网主机，整个过程中将引发警报机制。

被屏蔽子网

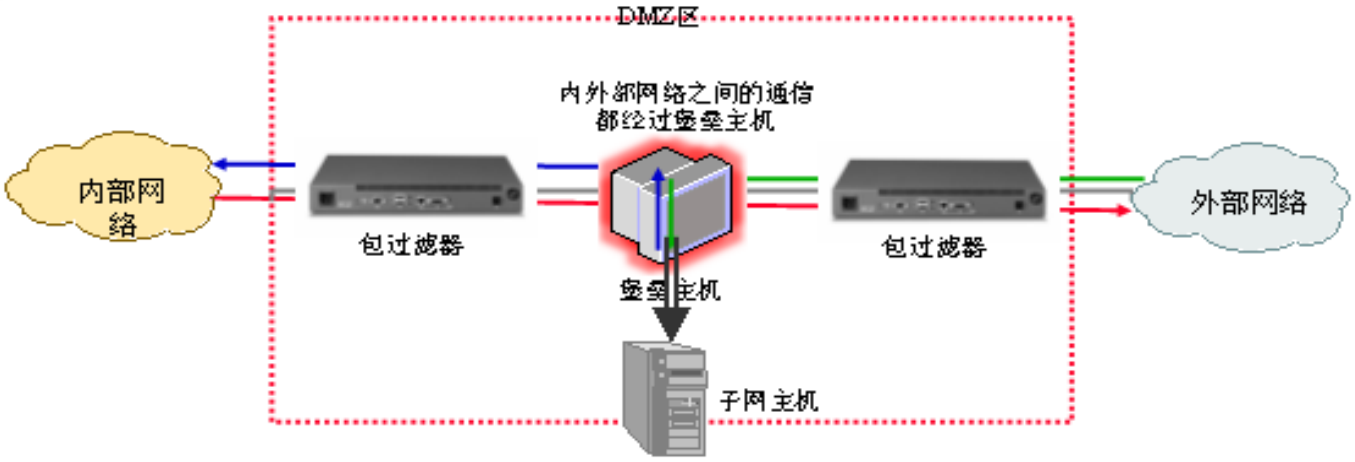


在双宿主主机体系结构和被屏蔽主机体系结构中，主机是最主要的安全缺陷，一旦主机被入侵，则整个内部网络都处于威胁之中，为解决这种安全隐患，出现了被屏蔽子网体系结构。

被屏蔽子网体系结构将防火墙的概念扩充至一个由两台路由器包围起来的特殊网络，即周边网络，并且将堡垒主机都置于周边网络中。

被屏蔽子网体系结构防火墙比较复杂，主要包括四个部件：**周边网络、外部路由器、内部路由器和堡垒主机**。

被屏蔽子网

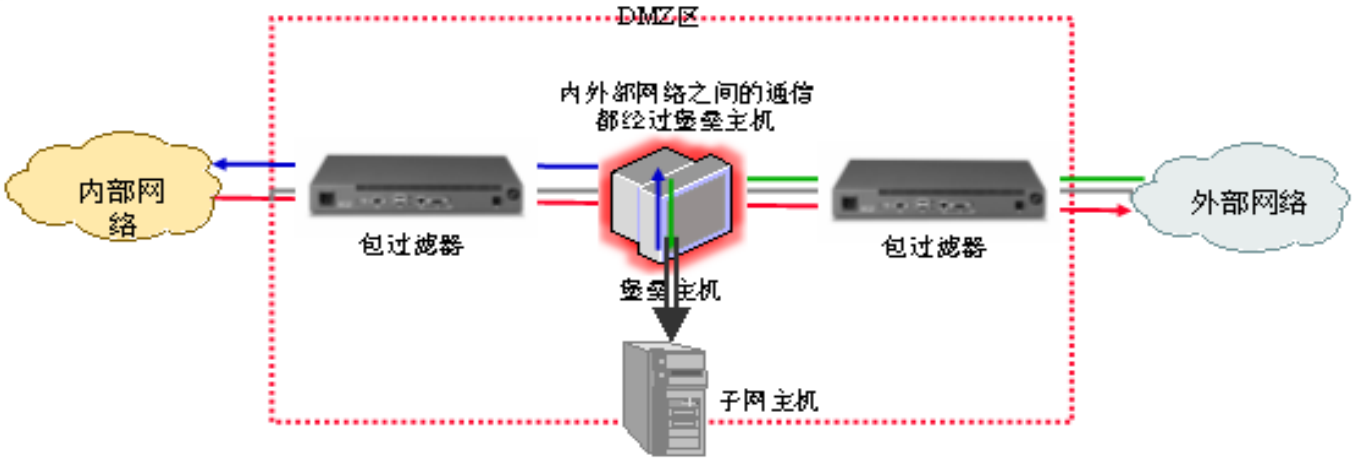


❖ 周边网络

周边网络是位于不可信外部网络与可信内部网络之间的一个附加网络。周边网络与外部网络、周边网络与内部网络之间通过屏蔽路由器实现逻辑隔离，因此外部用户必须穿越两道屏蔽路由器才能访问内部网络。

一般情况下，外部用户不能访问内部网络，仅能够访问周边网络中的资源，由于内部用户间通信的数据包不通过屏蔽路由器传递至周边网络，外部用户即使入侵了周边网络中的堡垒主机，也无法监听到内部网络的信息。

被屏蔽子网



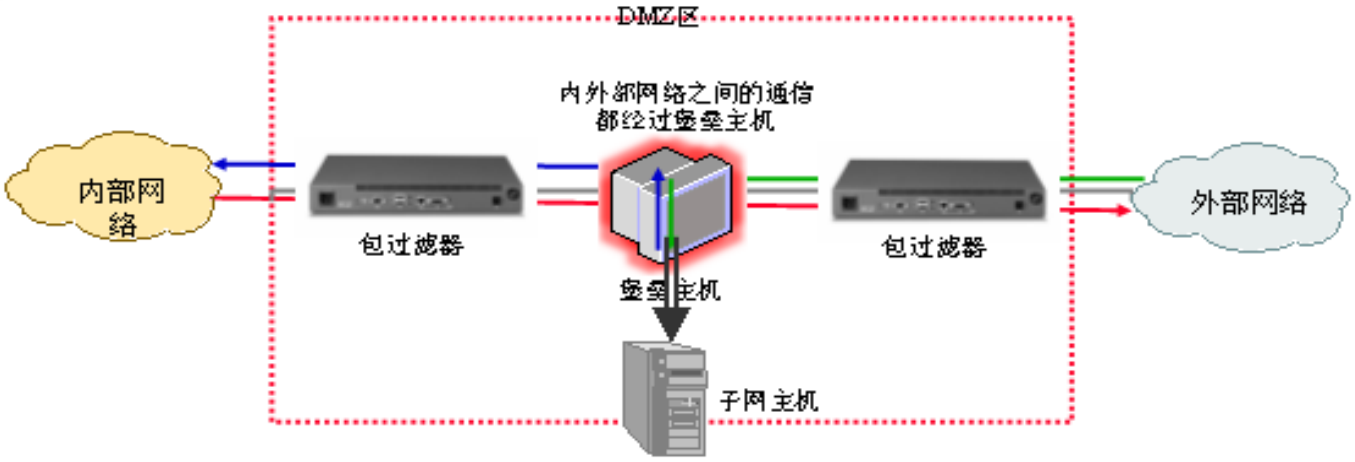
❖ 外部路由器

外部路由器的主要作用在于保护周边网络和内部网络，是屏蔽子网体系结构的第一道屏障。在其上设置了针对外网用户对周边网络和内部网络访问的过滤规则。

例如，限制外网用户仅能访问周边网络不能访问内部网络，或者仅能访问内部网络中的部分主机。

外部路由器不过滤周边网络内发出的数据包，因为数据包来自于堡垒主机或内部路由器过滤后的内部主机数据包。

被屏蔽子网



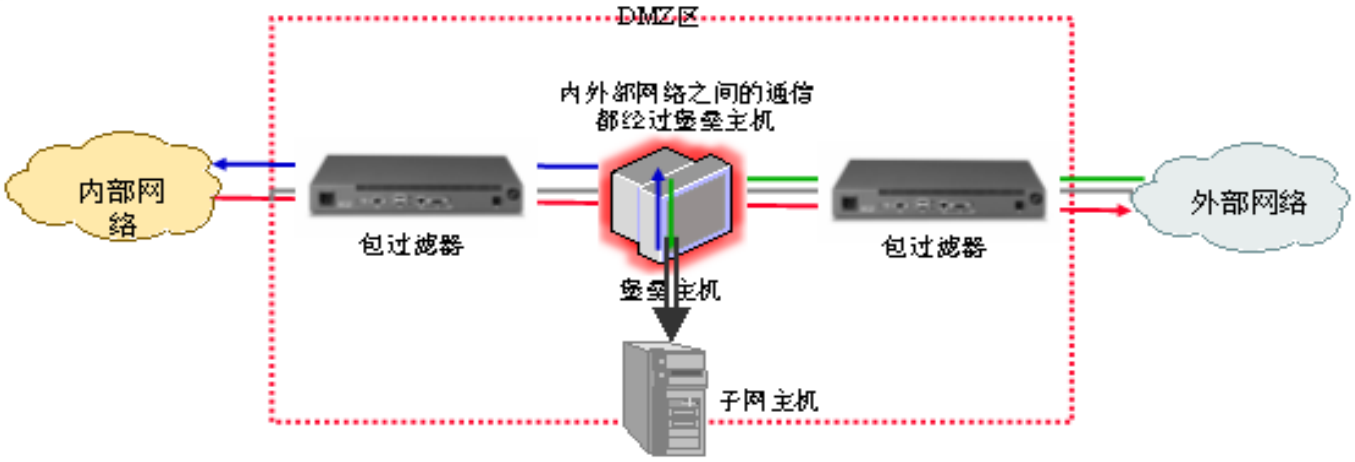
❖ 内部路由器

内部路由器用于隔离周边网络和内部网络，是屏蔽子网体系结构的第二道屏障。在其上设置了针对内部用户对周边网络和外部网络访问的过滤规则。

例如，部分内部网络用户只能访问周边网络不能访问外部网络等。

内部路由器复制了外部路由器上的内网过滤规则，以防止外部路由器过滤功能失效而造成的严重后果。内部路由器还要限制周边网络的堡垒主机和内部网络之间的访问，减少堡垒主机被入侵后可以影响的内部主机数量和服务数量。

被屏蔽子网



❖ 堡垒主机

在被屏蔽子网结构中，堡垒主机位于周边网络，向外部用户提供WWW、FTP等服务，接受外部网络用户的服务资源访问谓求，同时堡垒主机也向内部网络用户提供DNS、WWW代理、FTP代理等服务，提供内部网络用户访问外部资源的接口。

被屏蔽子网 结构与原理一图讲清

在内部网络和外部网络之间，增加一个由**两台过滤路由器**保护的**周边网络(被屏蔽子网)**，并把**堡垒主机**放在其中，
使内外通信必须经过：**外部过滤路由器 → 堡垒主机 → 内部过滤路由器** 的多级控制。

四个核心概念

1. 周边网络（被屏蔽子网）

- 位于不可信外部网络与可信内部网络之间的一个附加网络。
- 外部用户可以访问周边网络中的资源（通常只能访问堡垒主机），但不能直接访问内部网络。
- 即使周边网络中的主机被攻陷，攻击者也无法直接进入内部网络。

2. 外部过滤路由器

- 位于外部网络与周边网络之间，是第一道安全屏障。
- 根据预先定义的过滤规则，只允许外部用户访问周边网络中被允许的服务器（通常是堡垒主机或少量服务）。
- 阻止外部用户直接访问内部网络。

3. 堡垒主机

- 放在周边网络中，是内外通信的核心节点。
- 对外：可以提供必要的服务（如 WWW、FTP 等），接收外部请求。
- 对内：只能通过堡垒主机按规则访问内部网络资源，不能随意访问内网。
- 记录日志、进行身份认证、代理转发，实现审计与安全控制。

4. 内部过滤路由器

- 位于周边网络与内部网络之间，是第二道安全屏障。
- 控制周边网络访问内部网络的流量，只允许必要的、最小化的访问。
- 防止被攻陷的堡垒主机或周边主机横向渗透内部网络。

与前两种结构的比较

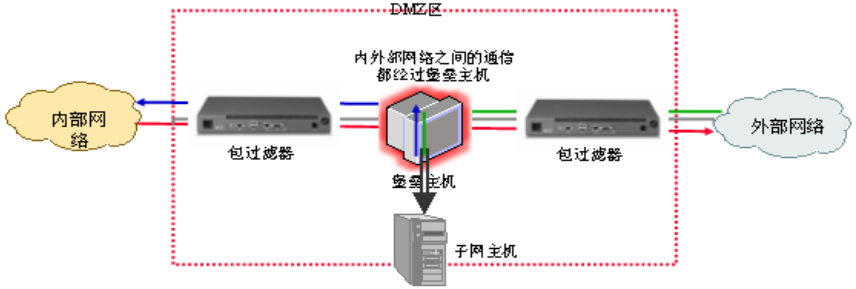
双宿主主机	一台主机同时连接内网和外网。 一旦被攻陷，攻击者可能直接进入内网，风险极大。	**问题** 完全依赖单台主机，安全性最低。
被屏蔽主机	外部网络先经过一个过滤路由器，再访问堡垒主机。 比双宿主主机安全，但仍然过于依赖堡垒主机。	堡垒主机被攻陷后，内部网络仍面临较大威胁。
被屏蔽子网	引入周边网络，并用两台过滤路由器夹在中间。 攻击者需要连续突破两道路由器和堡垒主机，才能进入内网。	**优势** 分层隔离，多级防护，整体安全性最高。

典型通信流程（外访问内部资源）

1. 外部用户向堡垒主机发送请求（例如访问内部的数据库或文件服务）
   - 外部过滤路由器检查：
     - 是否允许访问堡垒主机
3. 堡垒主机验证身份、记录日志，根据策略向内部发起请求
   - 内部过滤路由器检查：
     - 是否允许堡垒主机访问内部资源
5. 内部资源返回数据 → 经过内部路由器 → 堡垒主机 → 外部路由器 → 外部用户

一句话总结：被屏蔽子网是用“两道过滤路由器 + 一个周边网络 + 堡垒主机”构成的分层防护体系，将对外服务与内部网络隔离，从而实现：外部不能直接访问内部，即使前线被攻破，内网仍有第二道防线。

被屏蔽子网



❖ 优点

外部路由器和内部路由器构成双层防护体系，入侵者难以突破；

外部用户访问服务资源时无需进入内部网络，在保证服务的情况下提高了内部网络的安全性；

外部路由器和内部路由器过滤规则复制，避免由于某台路由器失效产生的安全隐患；

堡垒主机由外部路由器的过滤规则和本机安全机制共同防护，用户只能访问它提供的服务；

即使入侵者通过堡垒主机的服务缺陷控制了堡垒主机，由于内部路由器将内部网络和周边网络隔离，入侵者无法通过监听周边网络获取内部网络信息。

❖ 缺点

构建被屏蔽子网体系结构的成本较高；

被屏蔽子网体系结构的配置较为复杂，容易出现配置错误导致的安全隐患。

7.5 防火墙的功能

防火墙需具备五个基本功能：

- 过滤进、出网络的数据；
- 管理进、出网络的访问行为；
- 封堵某些禁止的业务；
- 记录通过防火墙的信息内容和活动；
- 对网络攻击的检测和告警

防火墙的功能

防火墙的其它功能：

- 控制进出网络的信息流向和数据包，过滤不安全的服务；
- 隐藏内部IP地址及网络结构的细节；
- 提供使用流量日志和审计的功能；
- 部署NAT（Network Address Translation，网络地址转换）；
- 可连接到一个单独网段上，从逻辑上和内部网段隔开，对外提供WEB和FTP；
- 安全规则可在整个内部网络中执行，实现集中的安全管理；
- 提供VPN功能。

防火墙的功能总结

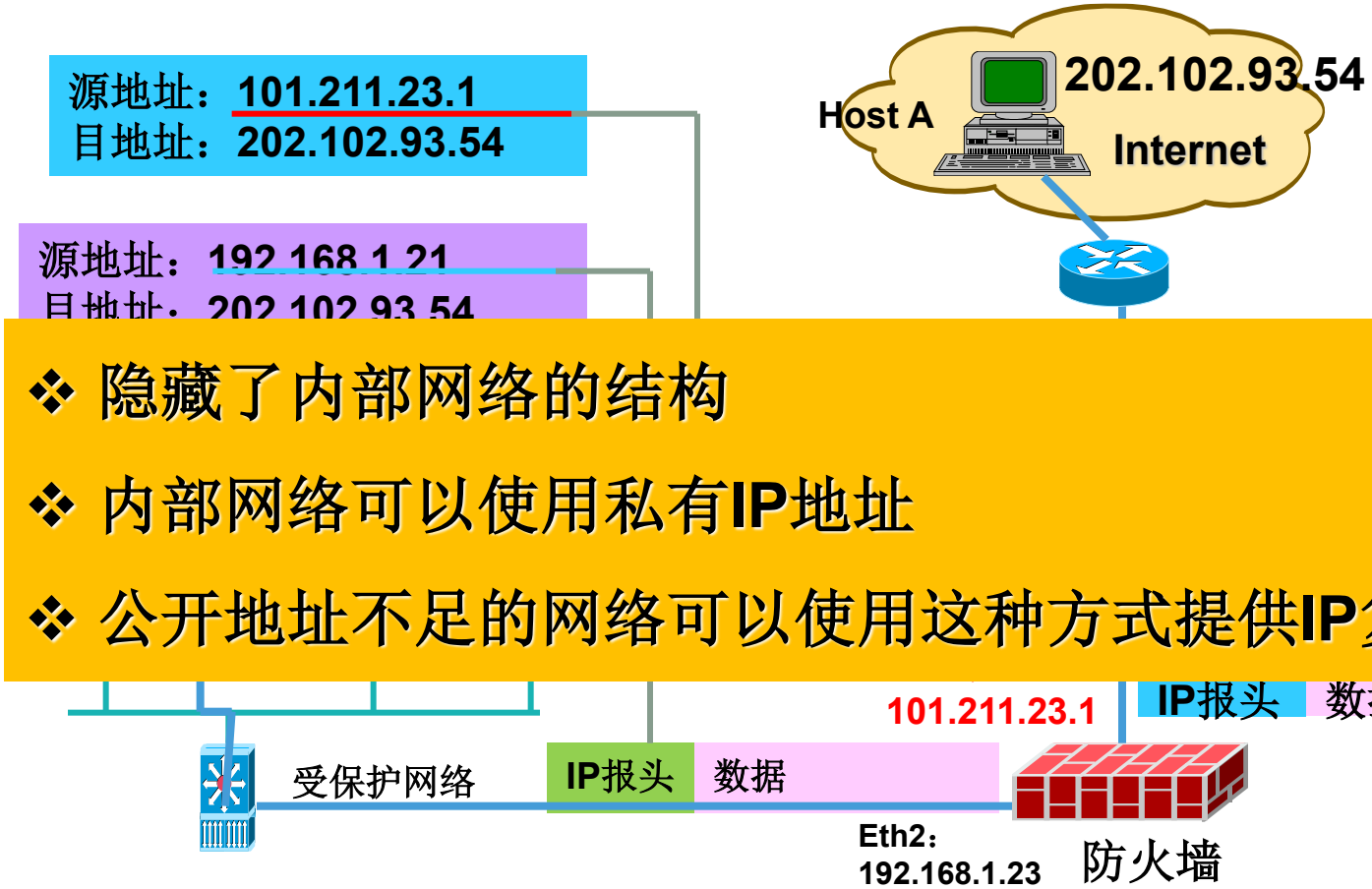
常见功能

- 地址转换
- 访问控制
- VLAN支持
- 带宽管理（QoS）
- 入侵检测和攻击防御
- 用户认证
- IP/MAC绑定
- 动态IP环境支持
- 数据库长连接应用支持
- 路由支持
- ADSL拨号功能
- SNMP网管支持
- 日志审计
- 高可用性

扩展功能

- 防病毒
- VPN
  - IPSEC VPN
  - PPTP/L2TP

地址转换（NAT）

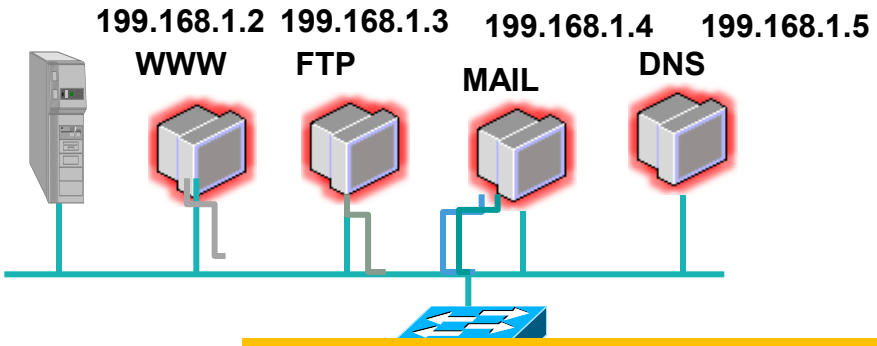


- 隐藏了内部网络的结构
- 内部网络可以使用私有IP地址
- 公开地址不足的网络可以使用这种方式提供IP复用功能

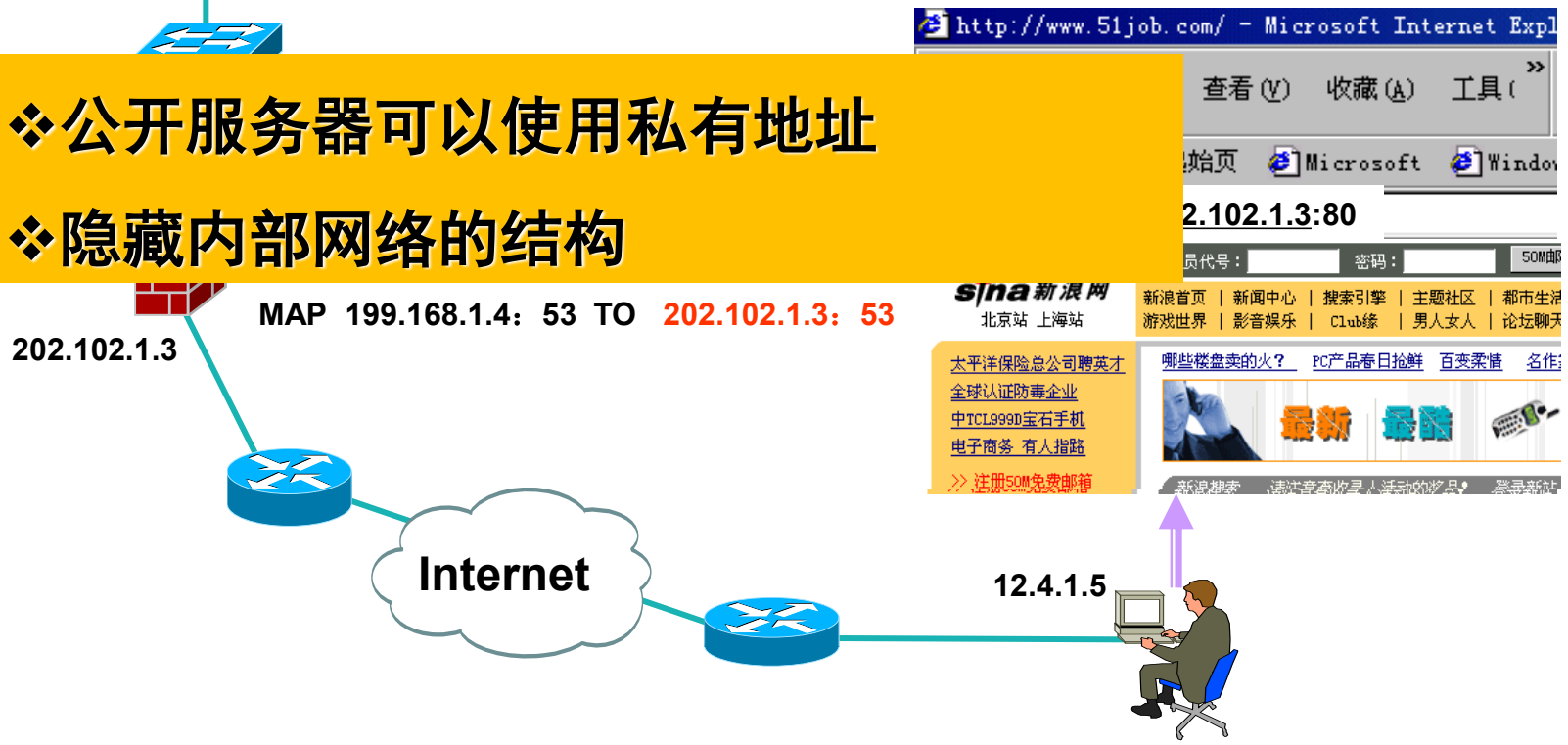
如果没做NAT，ping 101.211.23.2 会是什么情况？

类似邮局、快递封装

MAP(地址/端口映射)



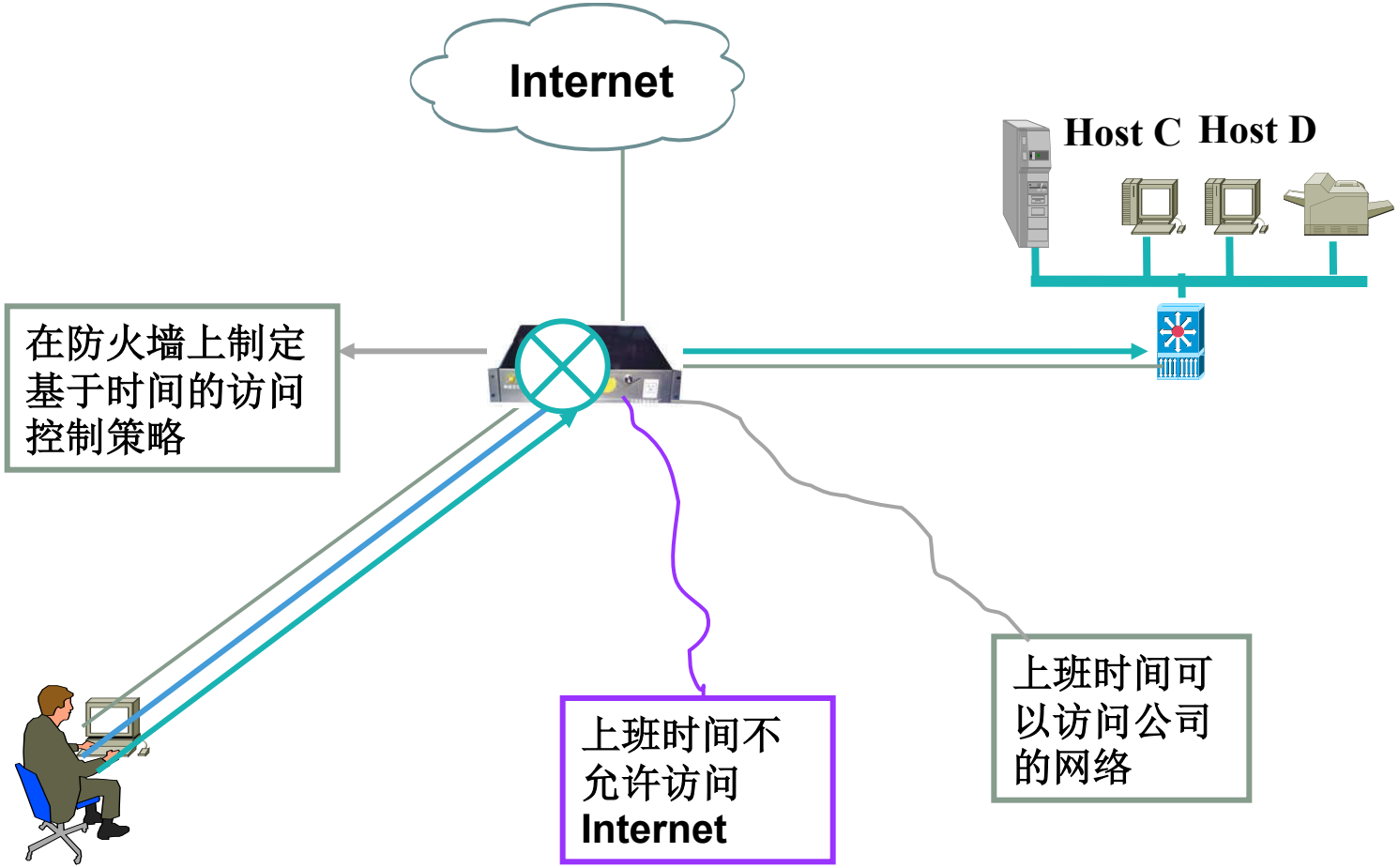
- ❖公开服务器可以使用私有地址
- ❖隐藏内部网络的结构



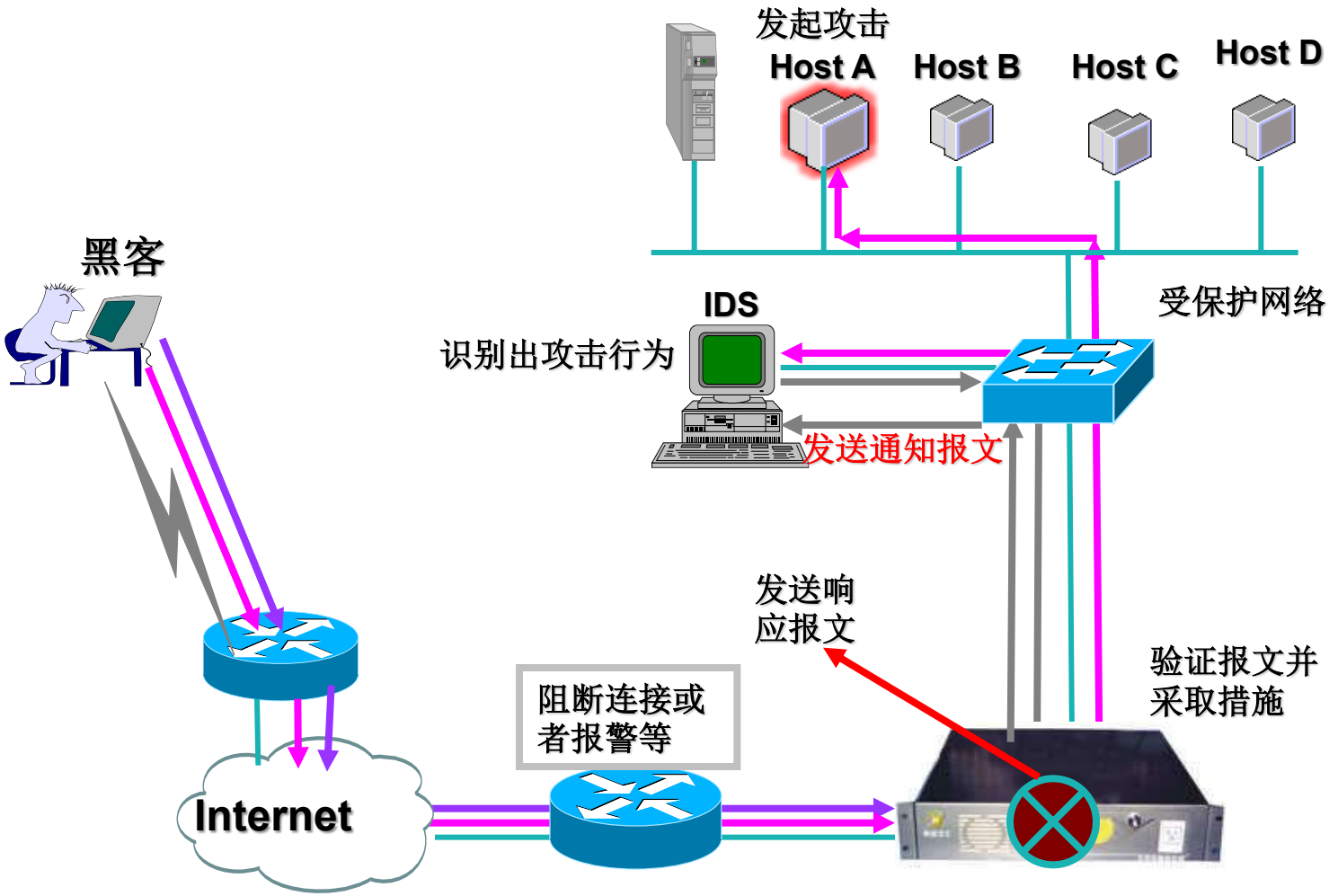
基本访问控制功能

- 基于源IP地址
- 基于目的IP地址
- 基于源端口
- 基于目的端口
- 基于时间
- 基于用户
- 基于流量
- 基于文件
- 基于网址
- 基于MAC地址

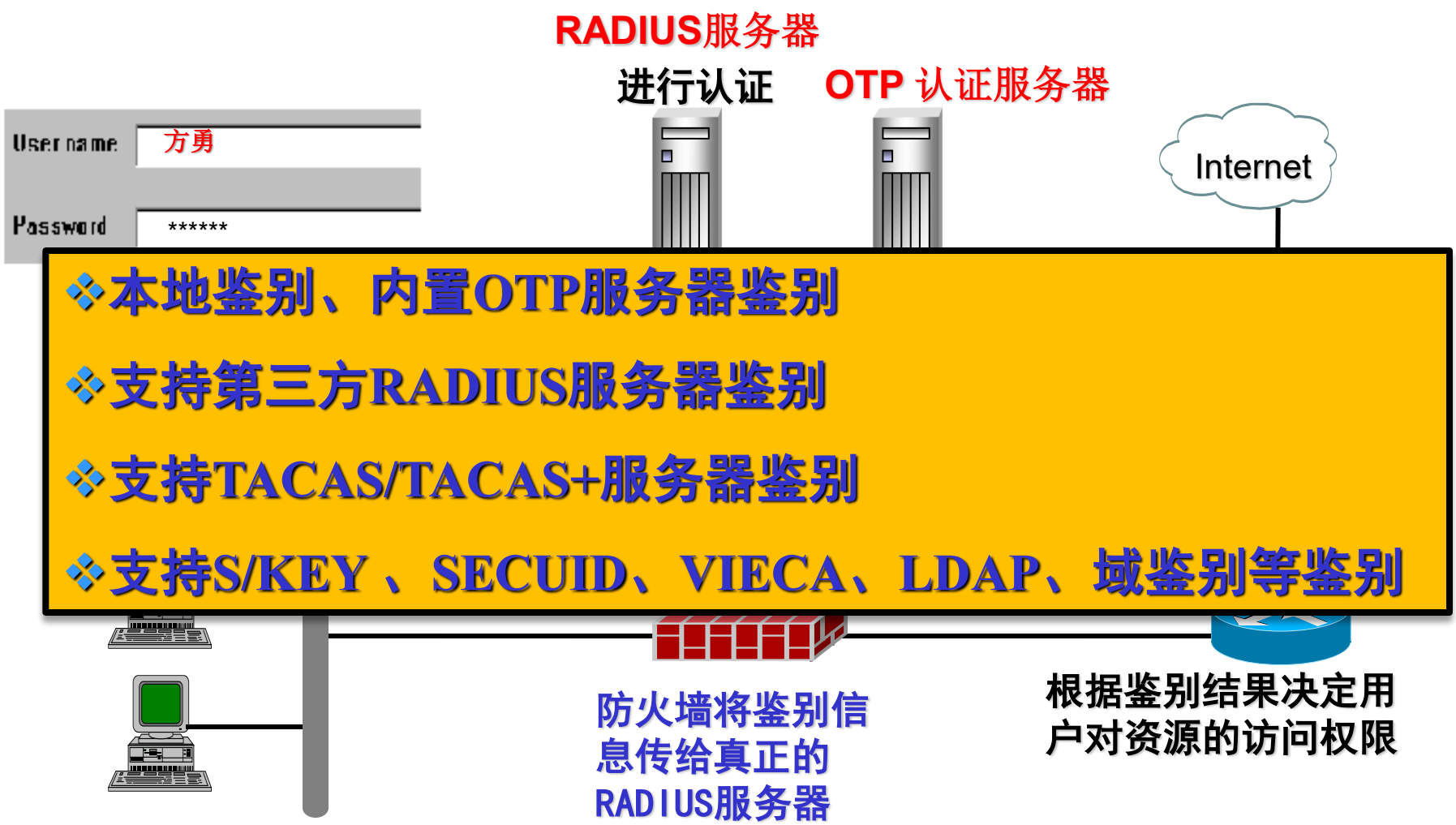
访问控制策略举例：时间控制策略



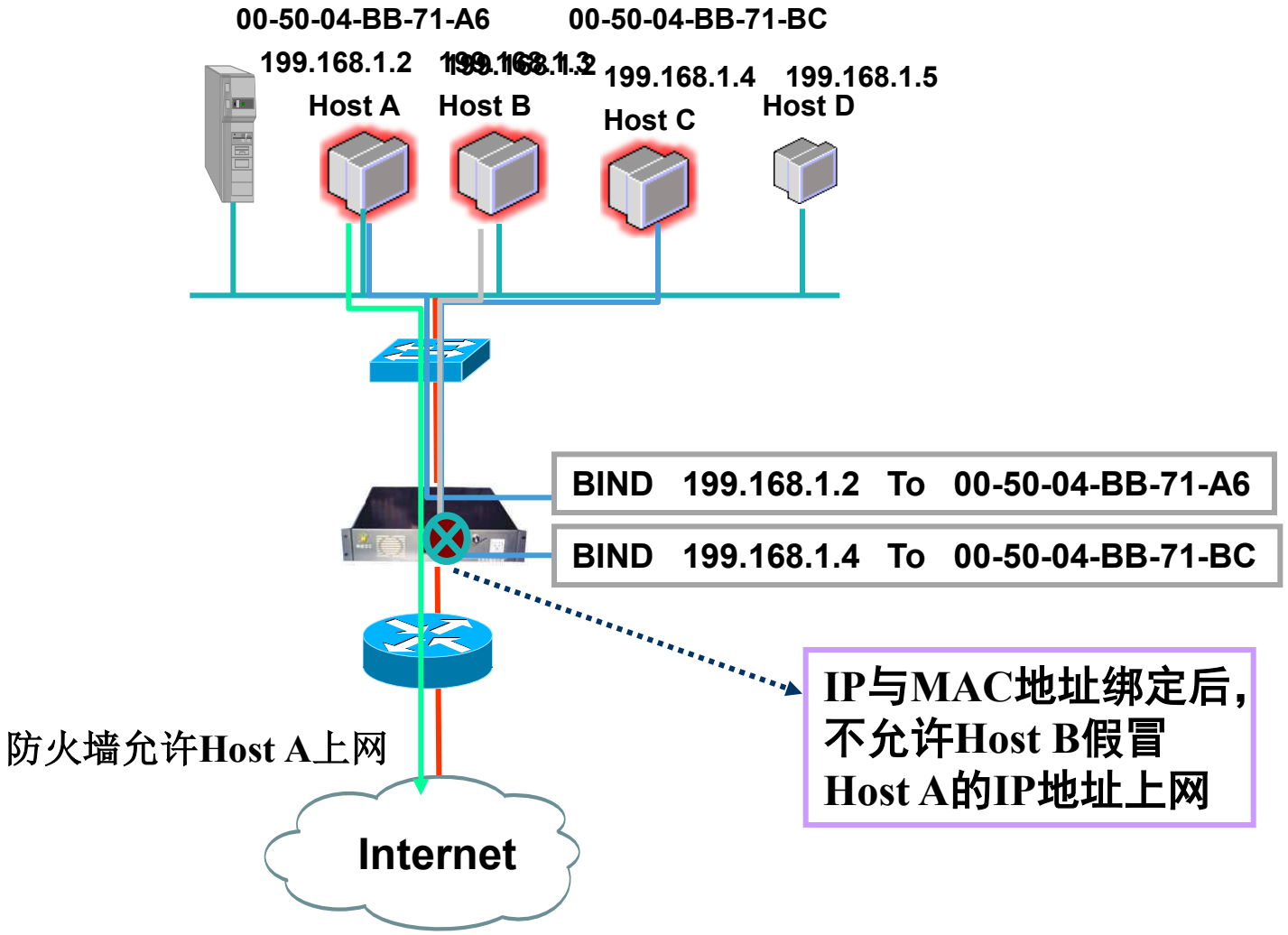
与IDS的安全联动


发起攻击
Host A
Host B
Host C
Host D
黑客
IDS
识别出攻击行为
受保护网络
发送通知报文
发送响
应报文
验证报文并
采取措施
阻断连接或
者报警等
Internet

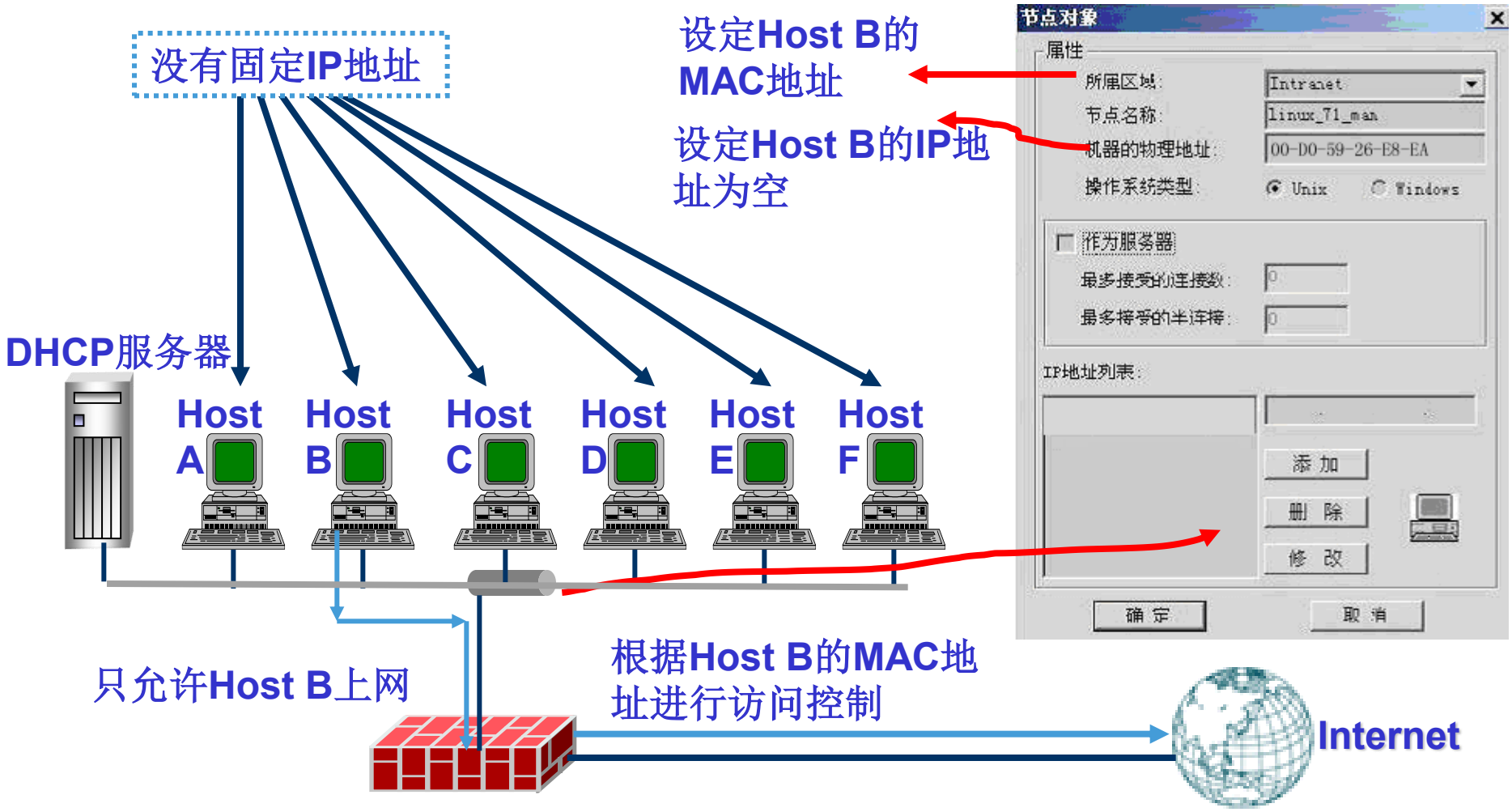
多种鉴别方式和第三方鉴别



IP与MAC（用户）绑定


00-50-04-BB-71-A6
00-50-04-BB-71-BC
199.168.1.2
199.168.1.3
199.168.1.4
199.168.1.5
Host A
Host B
Host C
Host D
BIND 199.168.1.2 To 00-50-04-BB-71-A6
BIND 199.168.1.4 To 00-50-04-BB-71-BC
IP与MAC地址绑定后，
不允许Host B假冒
Host A的IP地址上网
防火墙允许Host A上网
Internet

对DHCP应用环境的支持（动态主机配置协议）

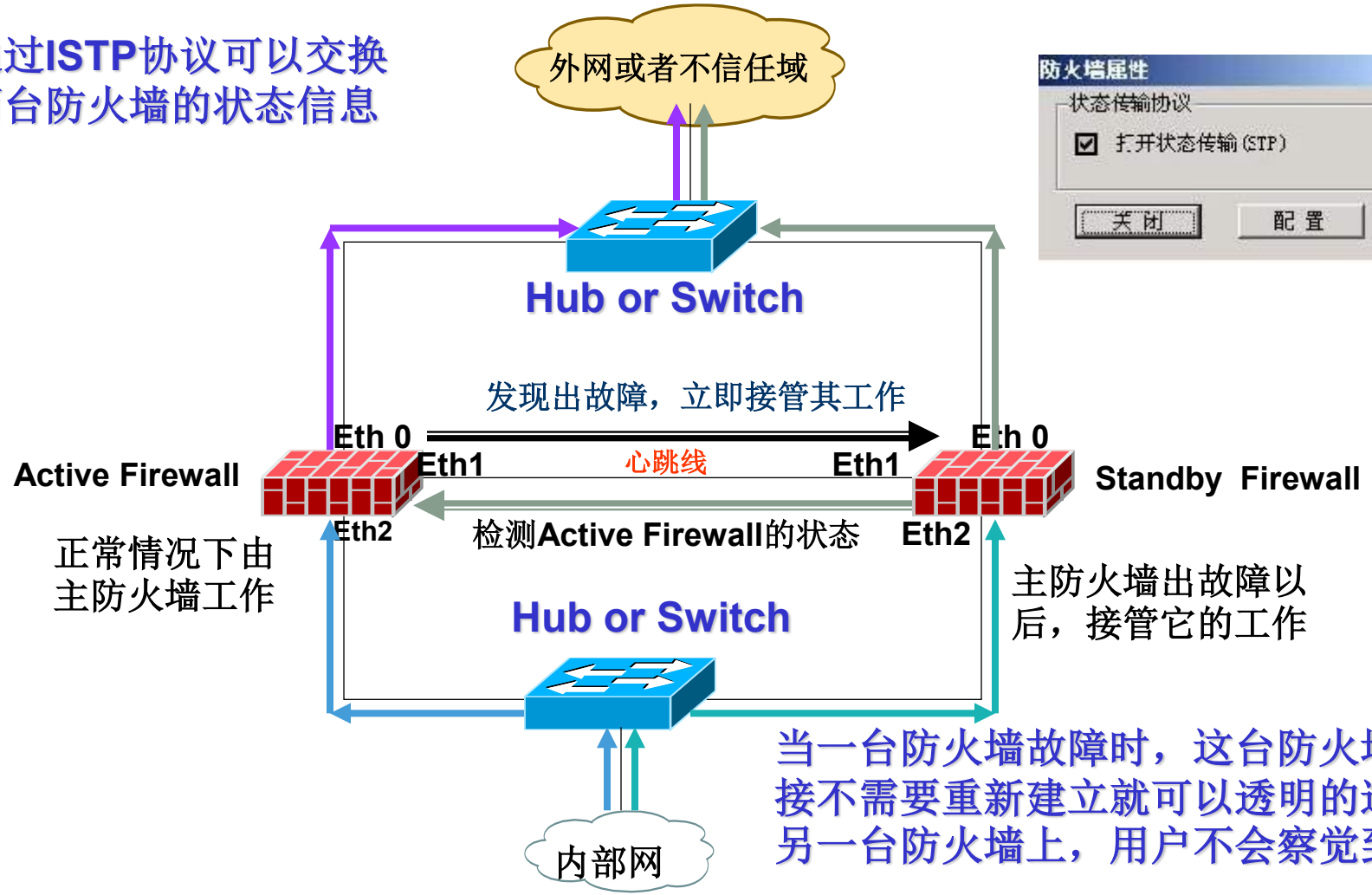


日志分析功能

1. 会话日志：即普通连接日志
   - ❖ 通信源地址、目的地址、源目端口、通信时间、通信协议、字节数、是否允许通过
2. 命令日志和内容日志：即深度分析日志
   - ❖ 在通信日志的基础之上，记录下各个应用层命令参数和内容。例如HTTP请求及其要取的网页名。
3. 提供日志分析工具
   - ❖ 自动产生各种报表，智能化的指出网络可能的安全漏洞

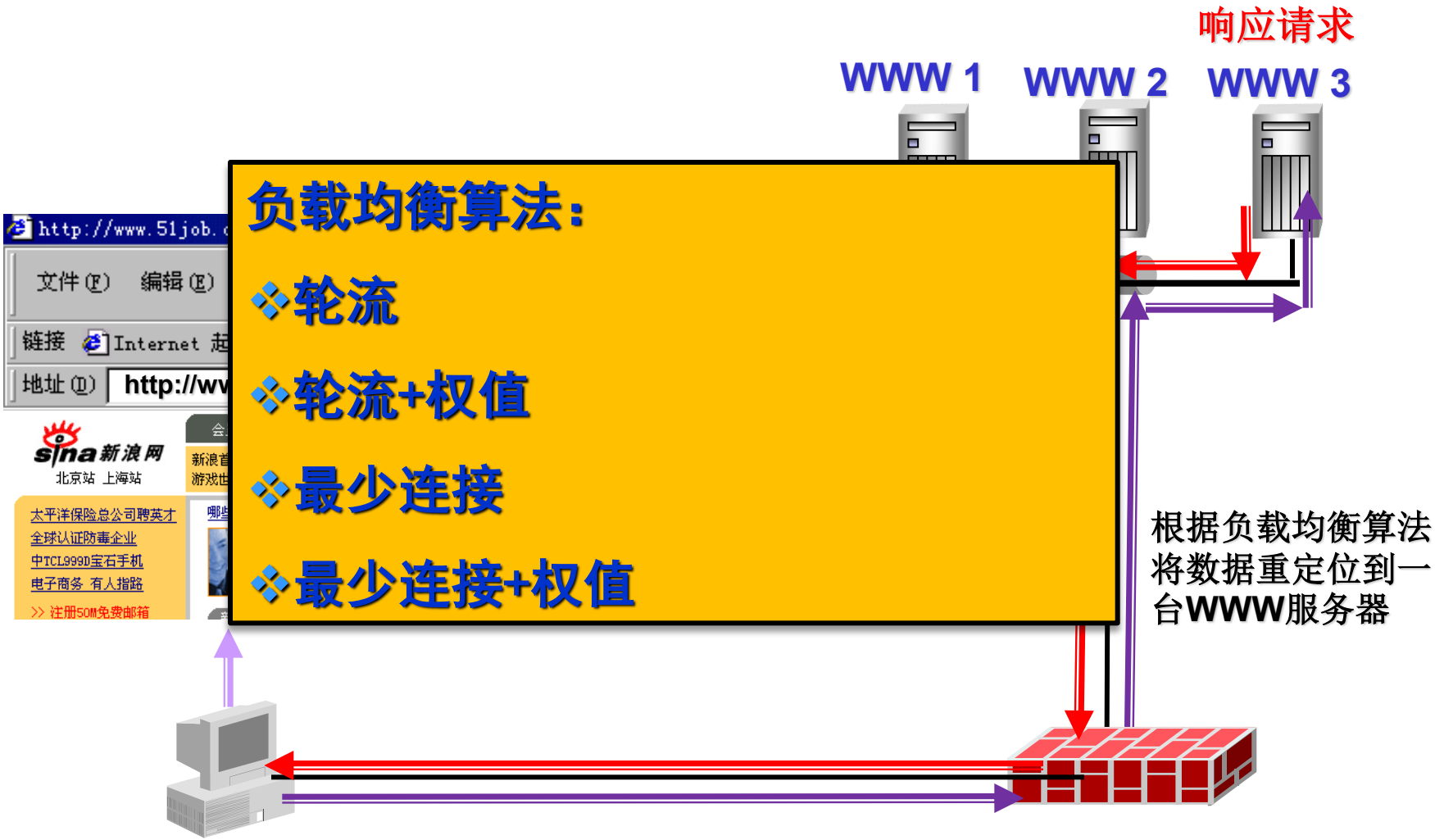
高可用性：双机热备功能

通过ISTP协议可以交换
两台防火墙的状态信息



当一台防火墙故障时，这台防火墙的连接不需要重新建立就可以透明的迁移到另一台防火墙上，用户不会察觉到

高可用性：服务器负载均衡



扩展功能-- IPSEC VPN功能

隧道设置

隧道名：		[只能输入字母、数字、'-'和'_']
隧道描述：		
IKE协商模式：	主模式	
认证方式：	预共享密钥	
预共享密钥：		
本地标识：		[填写格式:@XXX或者XXX@XXX]
对方标识：		[填写格式:@XXX或者XXX@XXX]
对方地址或域名：		
本地子网：		
本地掩码：		
对方子网：		
对方掩码：		
主动发起隧道协商：	是	

隧道设置.高级配置

高级配置： ○ 是 ◉ 否

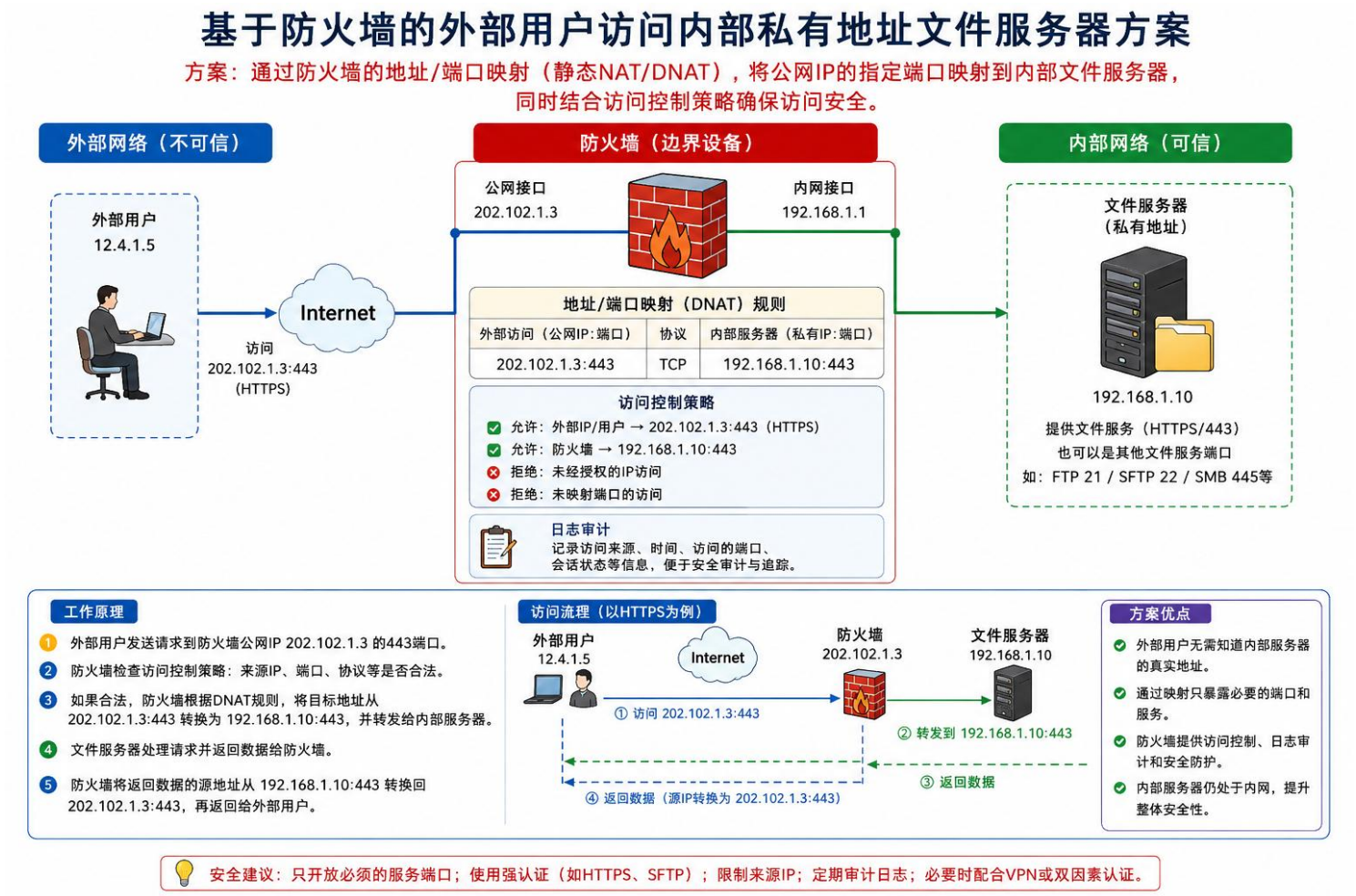
SA协商重试次数：	3	[范围:1～100,缺省:3]
ISAKMP-SA模糊比：	100	[范围:1～100,缺省:3]
ISAKMP-SA重叠时间：	540	[单位:s,范围:1～540,缺省:540]
ISAKMP-SA存活时间：	3600	[单位:s,最大:86400,缺省:3600]
IPSEC-SA存活时间：	28800	[单位:s,最大:86400,缺省:28800]
IPSEC-SA的算法提议列表：	3des-md5	[3des-md5|3des-sha1|aes-md5|aes-sha1]
IPSEC-SA的安全政策属性：	tunnel,encrypt	[pfs|tunnel|compress|encrypt|authenticate]
DPD间隔：	10	[单位:s,范围:1～20,缺省:10]
DPD超时时间：	300	[单位:s,范围:1～300,缺省:300]
DPD失败隧道操作：	clear	[缺省:clear]
NAT-T的KEEP-ALIVE间隔：	20	[单位:s,范围:1～40,缺省:20]

提交设定 取消返回

支持L2TP/PPTP VPN功能

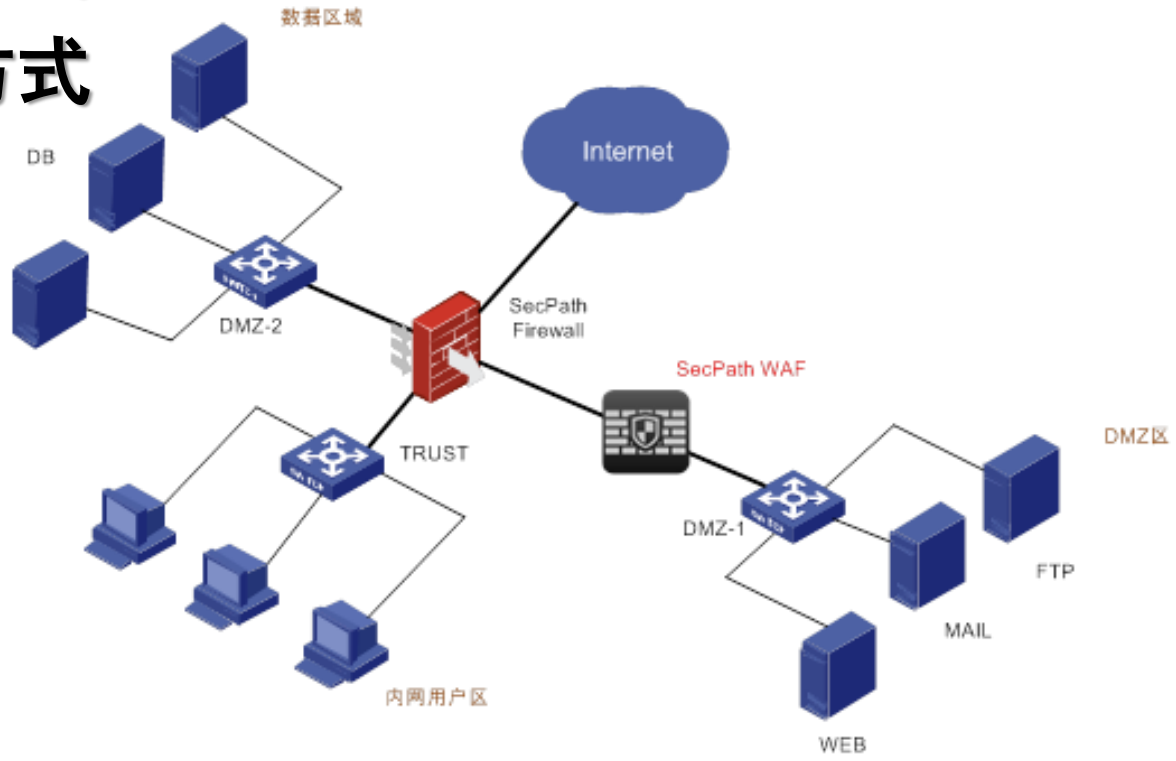
Practice

1、设计一种基于防火墙的外部用户访问内部私有地址文件服务器的方案，结合图例说明其工作原理。

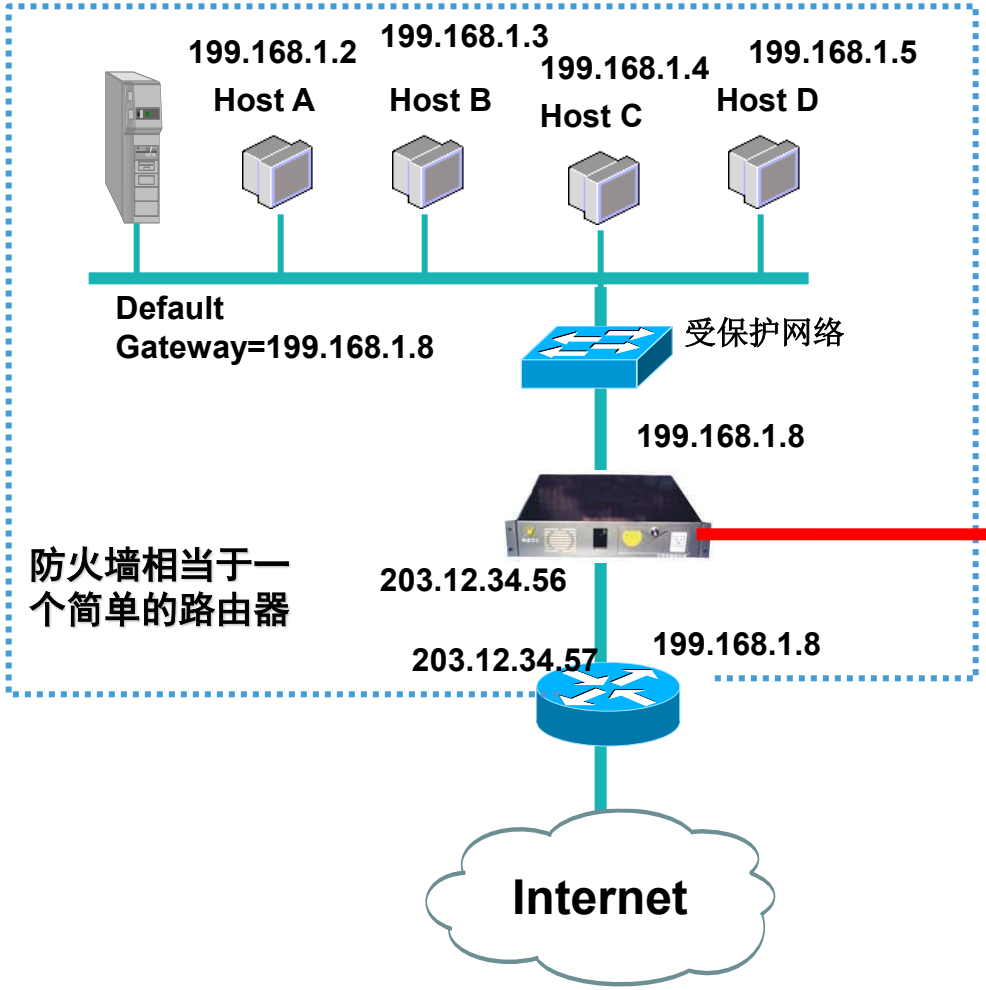


7.6 防火墙的工作接入方式

- 路由接入方式
- 透明接入方式
- 混合接入方式

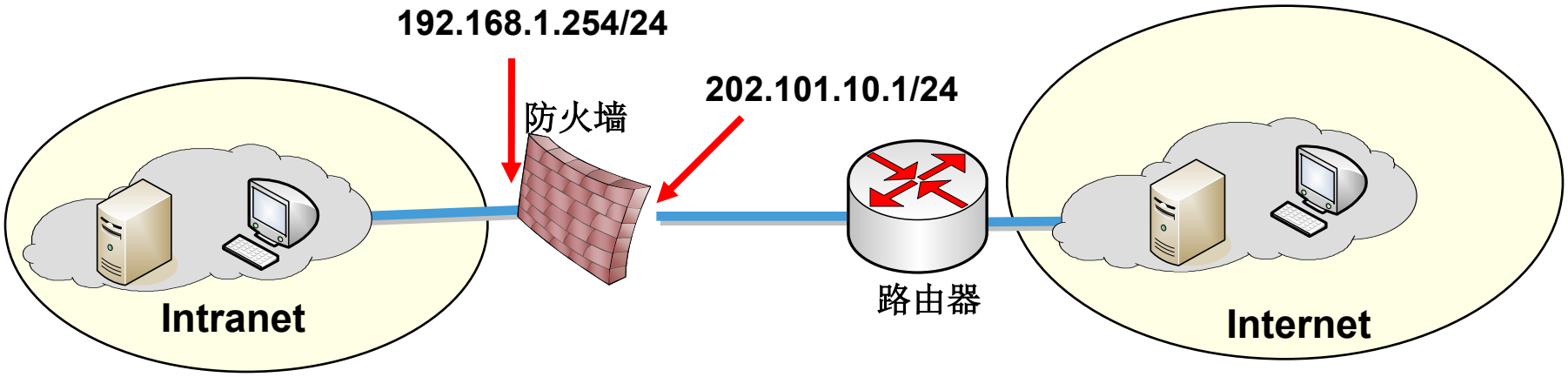


防火墙的路由接入工作模式



提供简单的
路由功能

防火墙的路由接入工作模式



内部网络

192.168.1.0/24

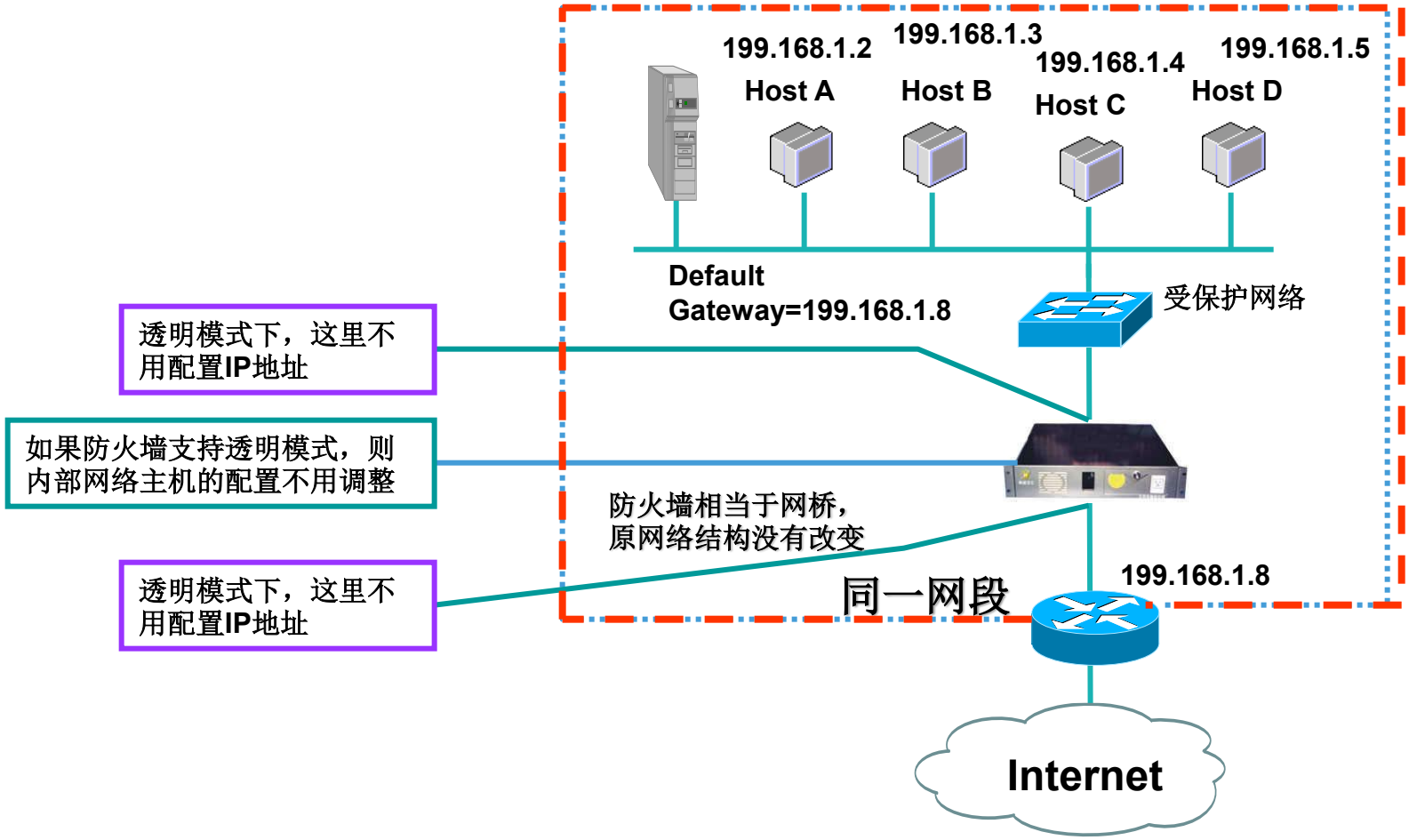
GW:192.168.1.254

外部网络

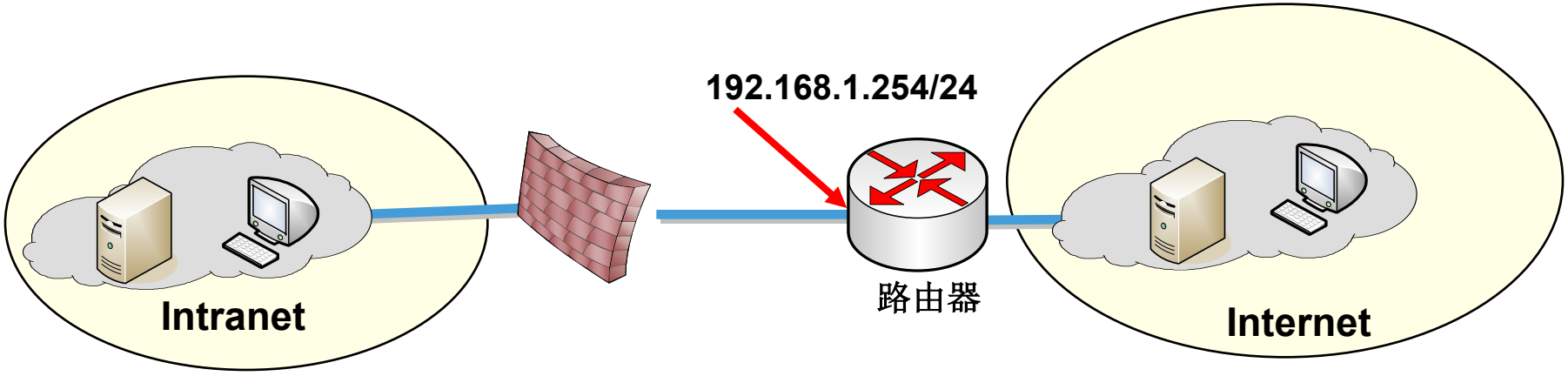
202.101.10.0/24

GW:202.101.10.1

防火墙的透明接入工作模式



防火墙的透明接入工作模式



内部网络

192.168.1.0/24

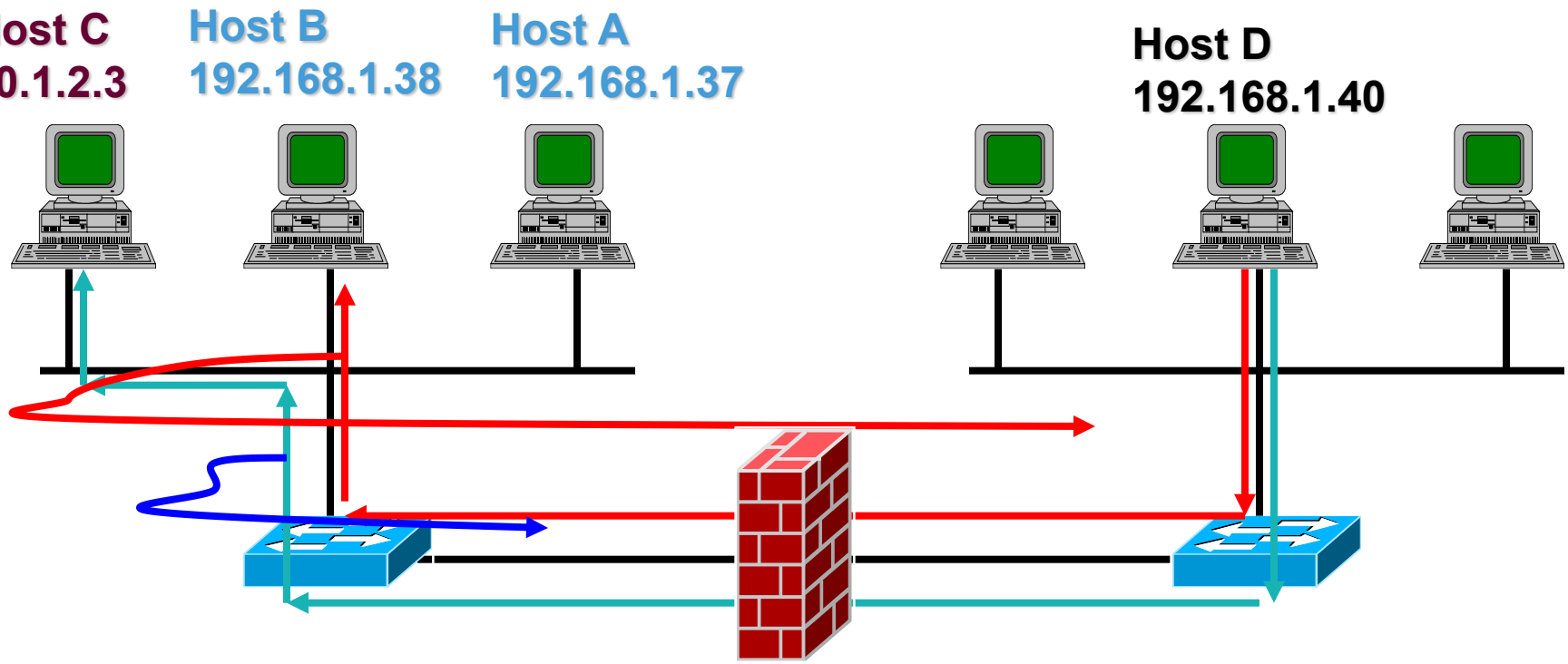
GW:192.168.1.254

外部网络

防火墙的混合接入工作模式

- 工作于透明接入模式的防火墙可以实现透明接入。
- 工作于路由模式的防火墙可以实现不同网段的连接。
- 路由接入模式的优点和透明接入模式的优点是不能同时并存的。
- 大多数的防火墙一般同时保留了透明接入模式和路由接入模式。
- 根据用户网络情况及用户需求，在使用时由用户进行选择。

防火墙的混合接入工作模式

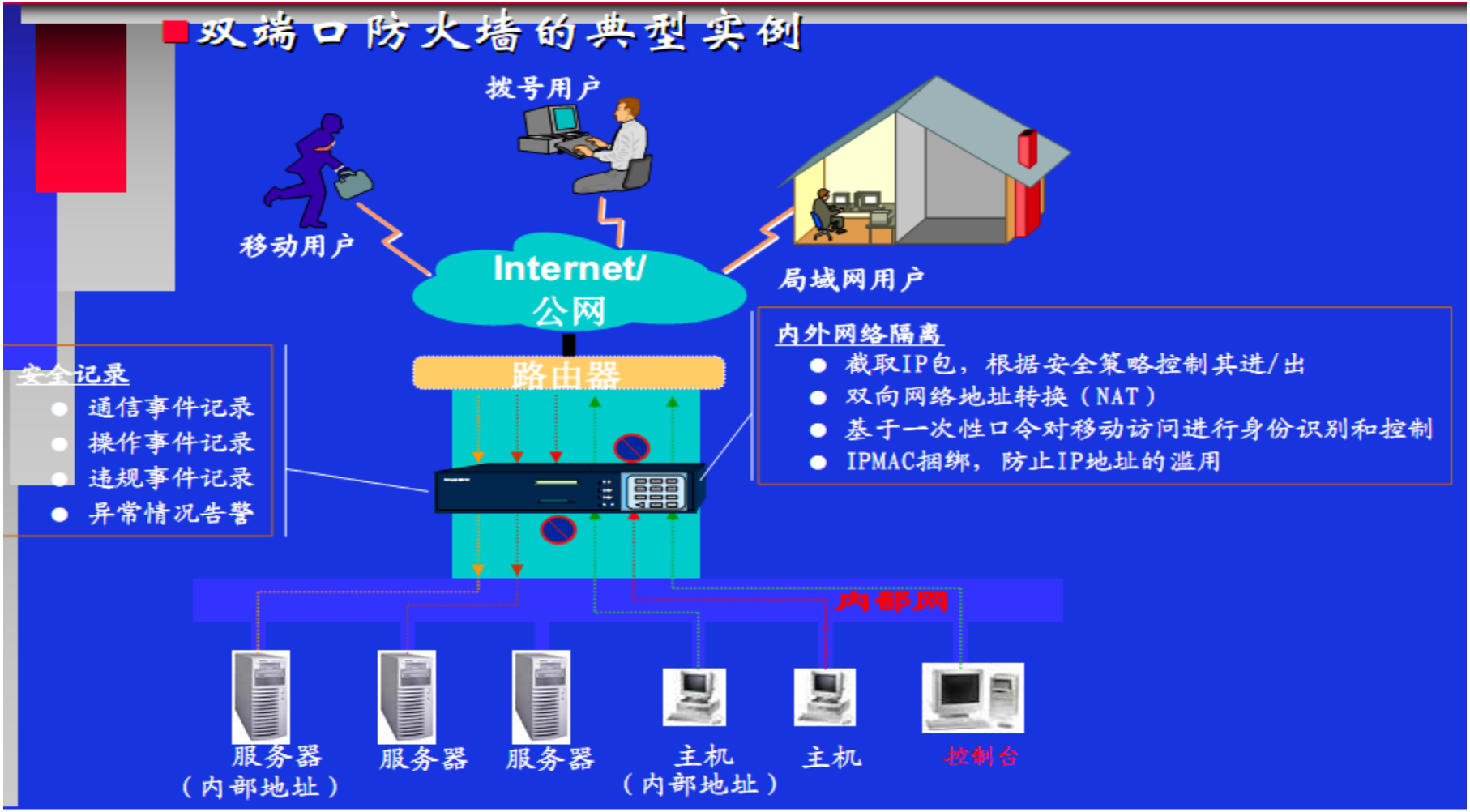


不同子网通过防火墙做静态路由进行通信

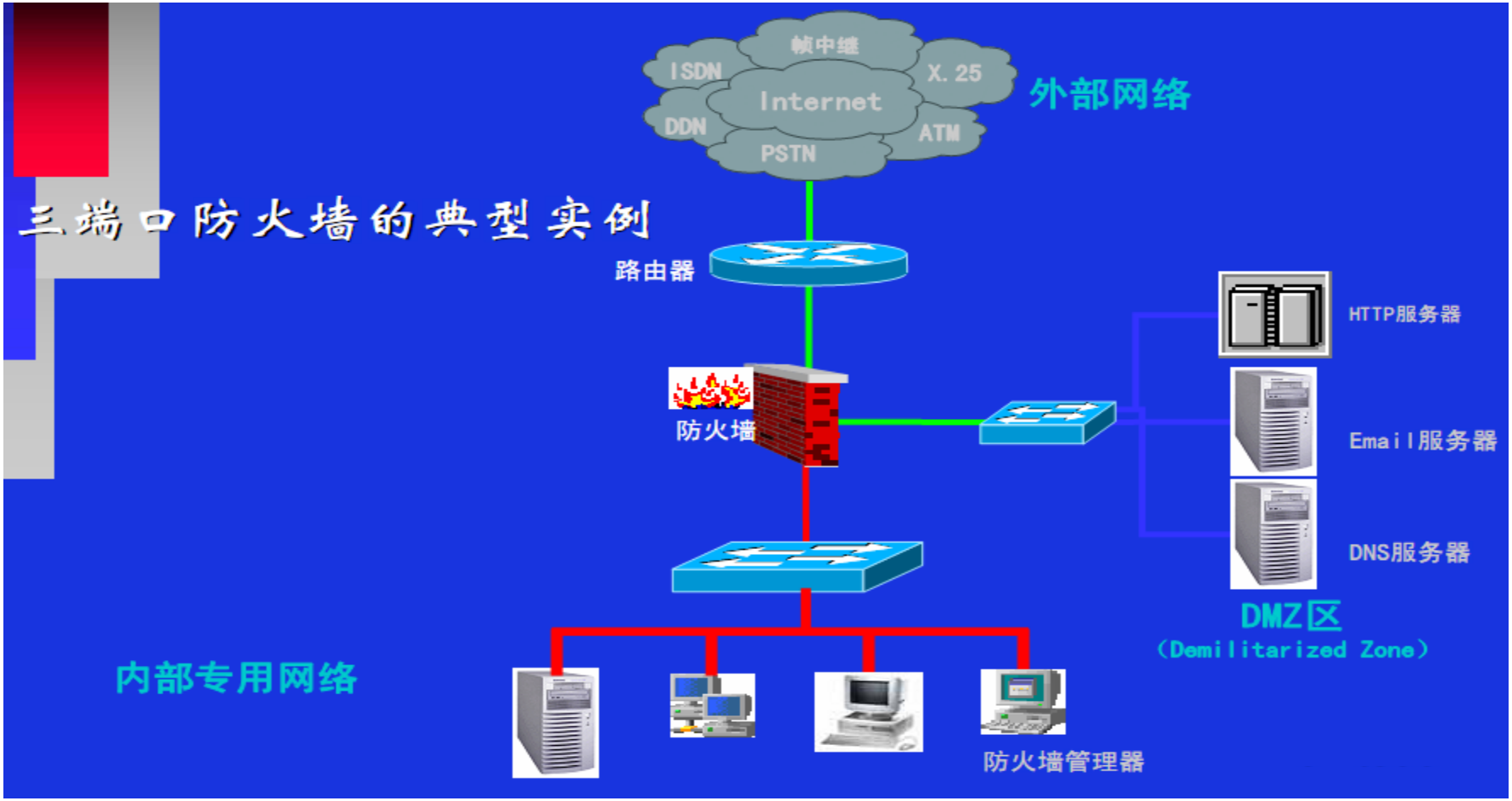
同一网段地址通过防火墙的透明模式进行通信

防火墙此时工作在混合模式下

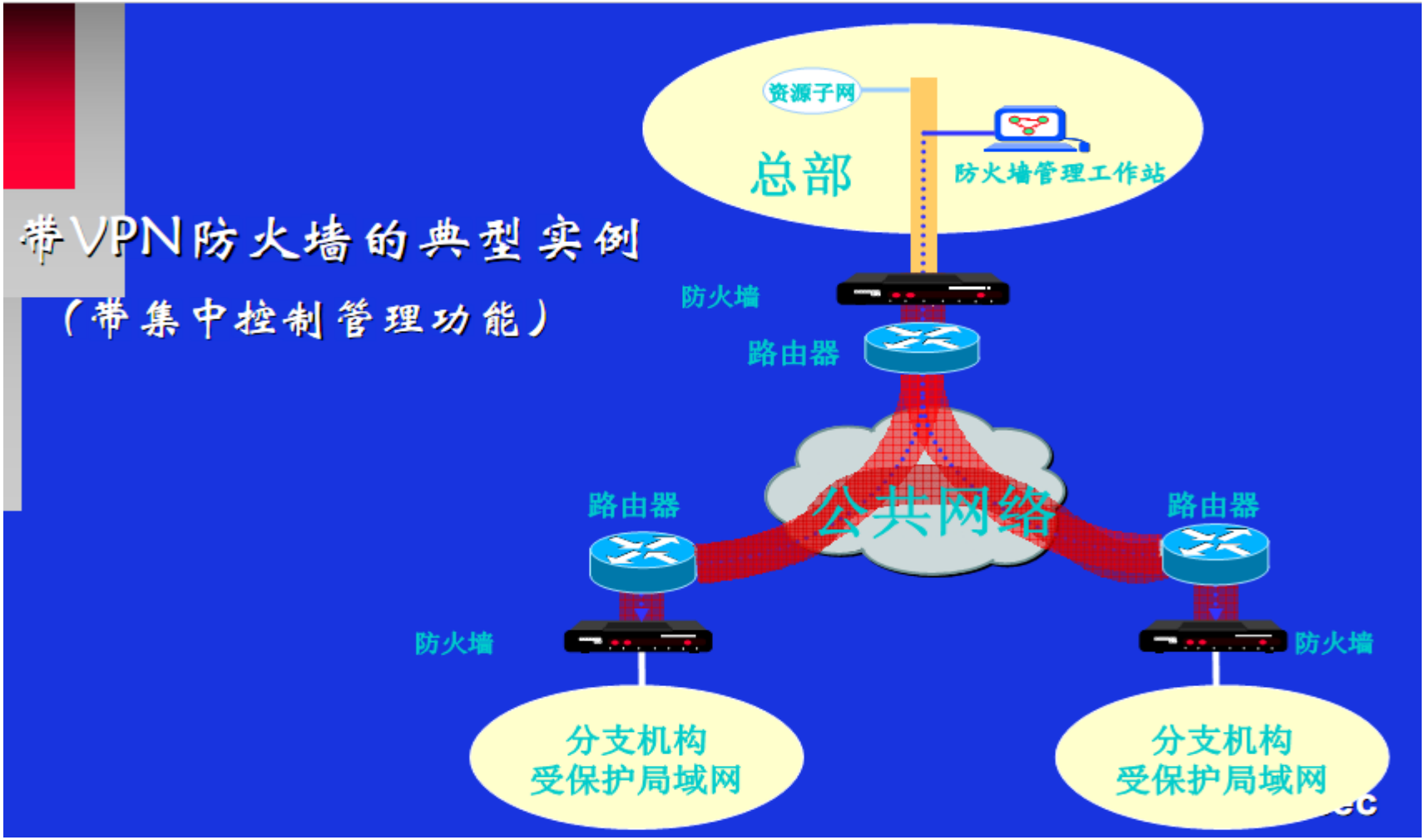
7.7 防火墙的典型应用：实例1

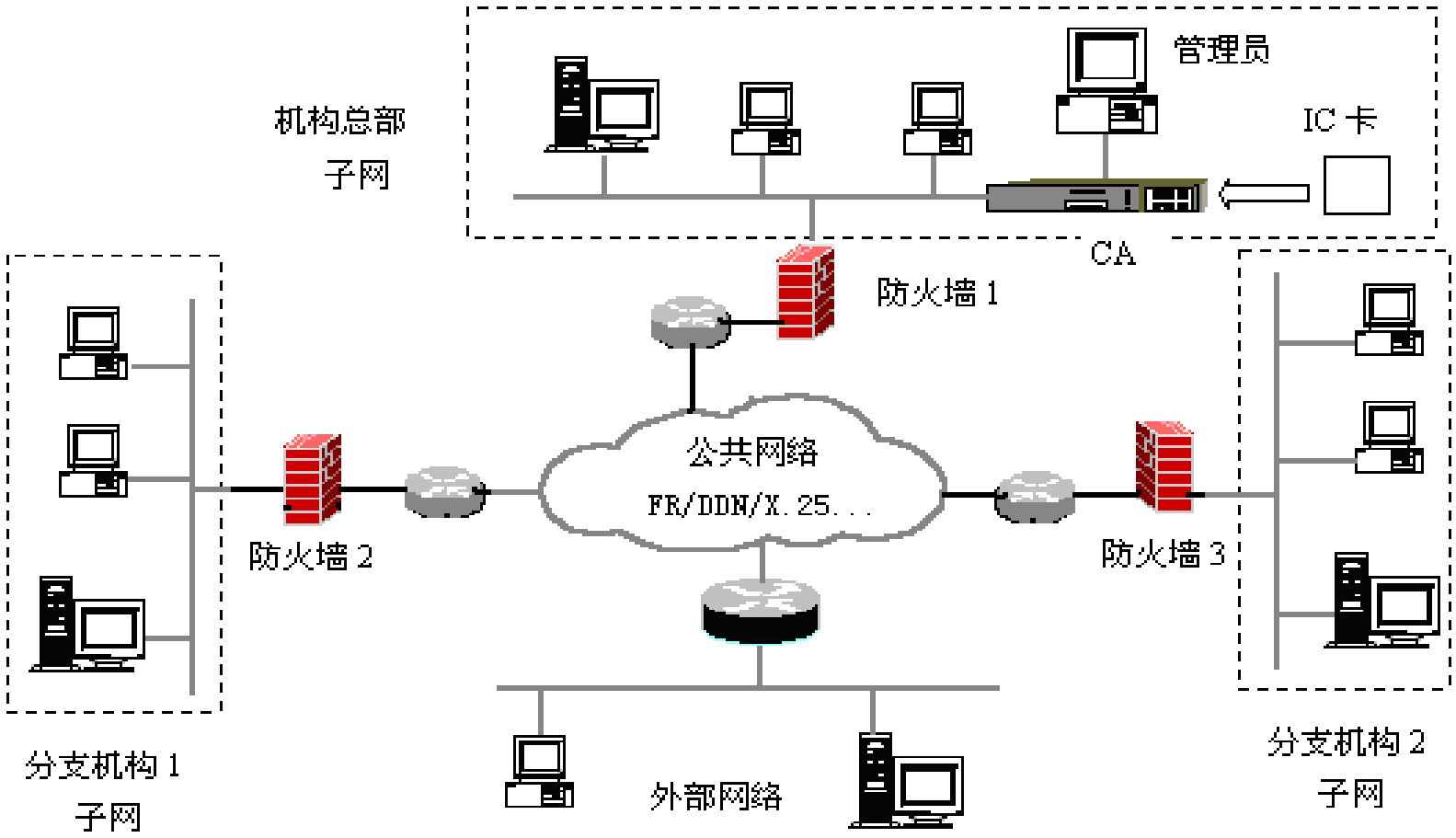


防火墙的典型应用：实例2



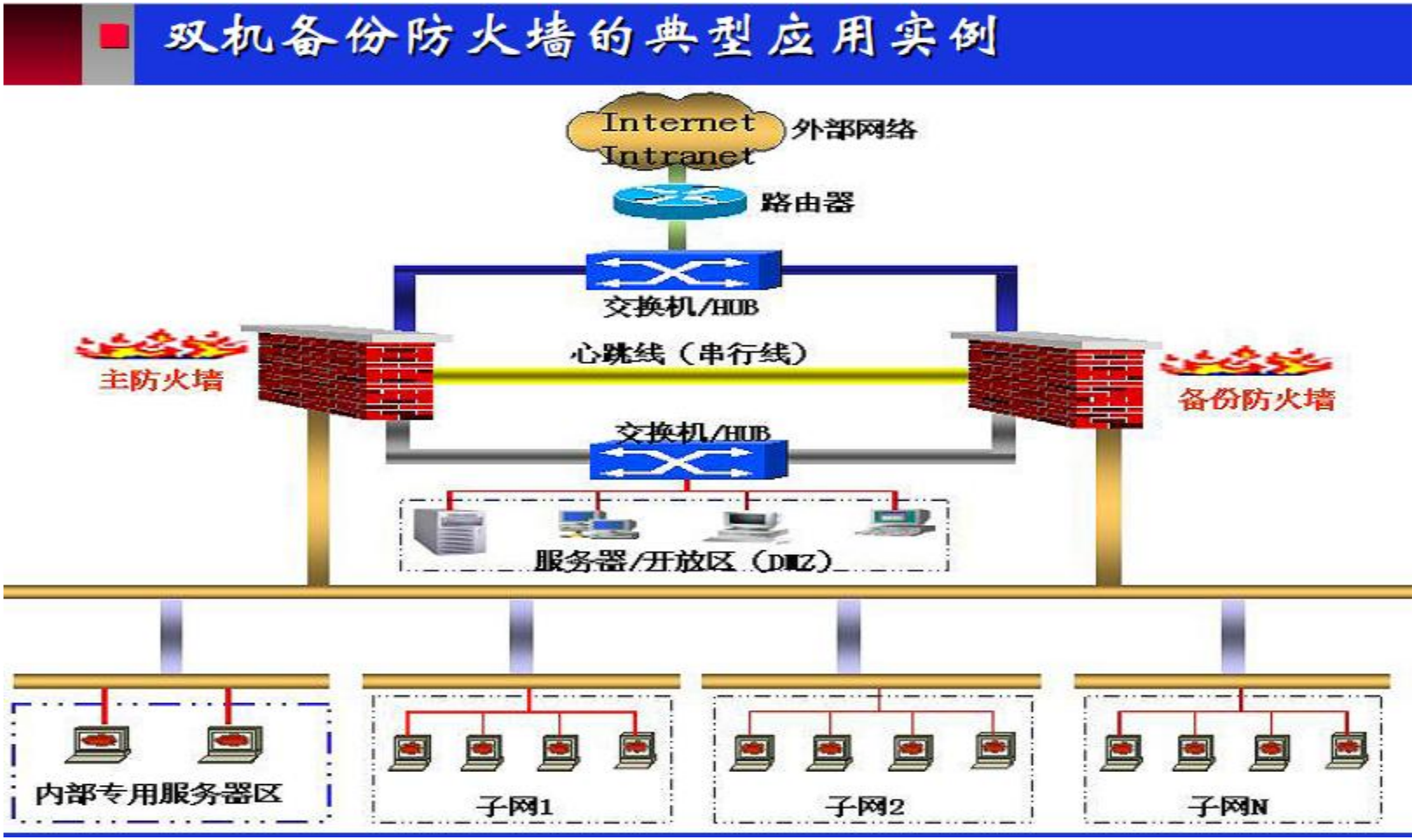
防火墙的典型应用：实例3





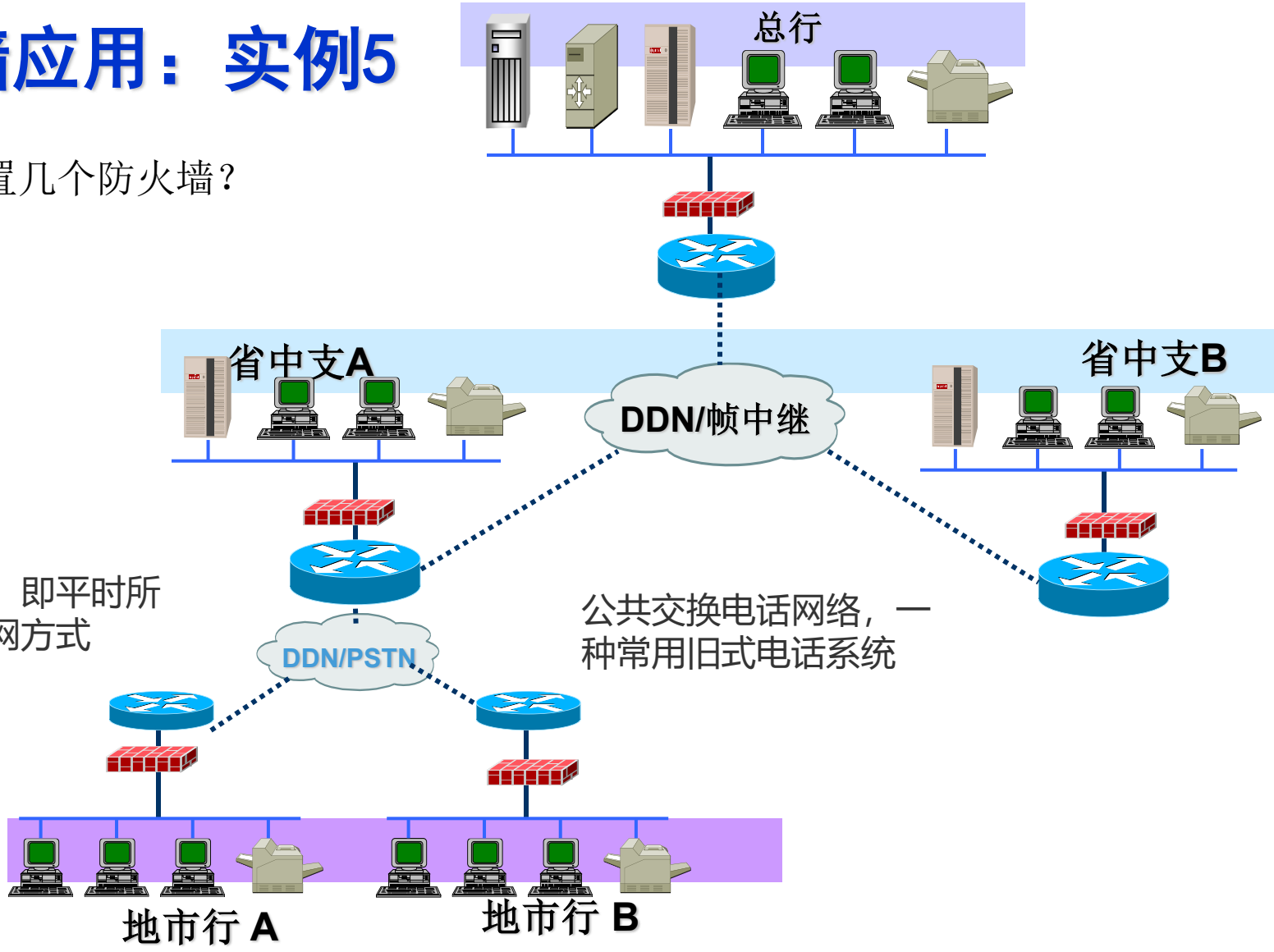
内联网防火墙配置示意图

防火墙的典型应用：实例4



防火墙应用：实例5

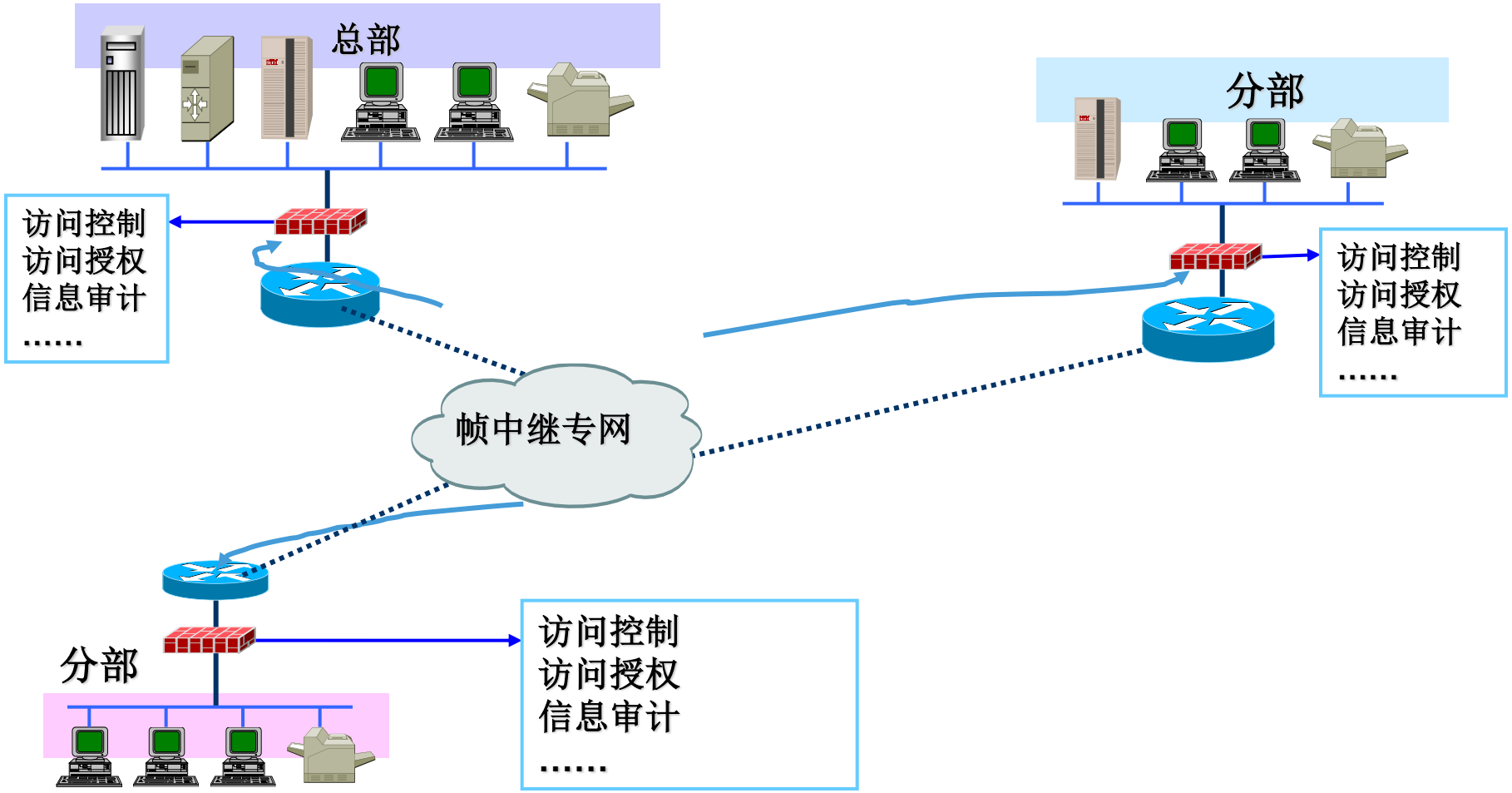
你会安置几个防火墙？



数字数据网，即平时所说的专线上网方式

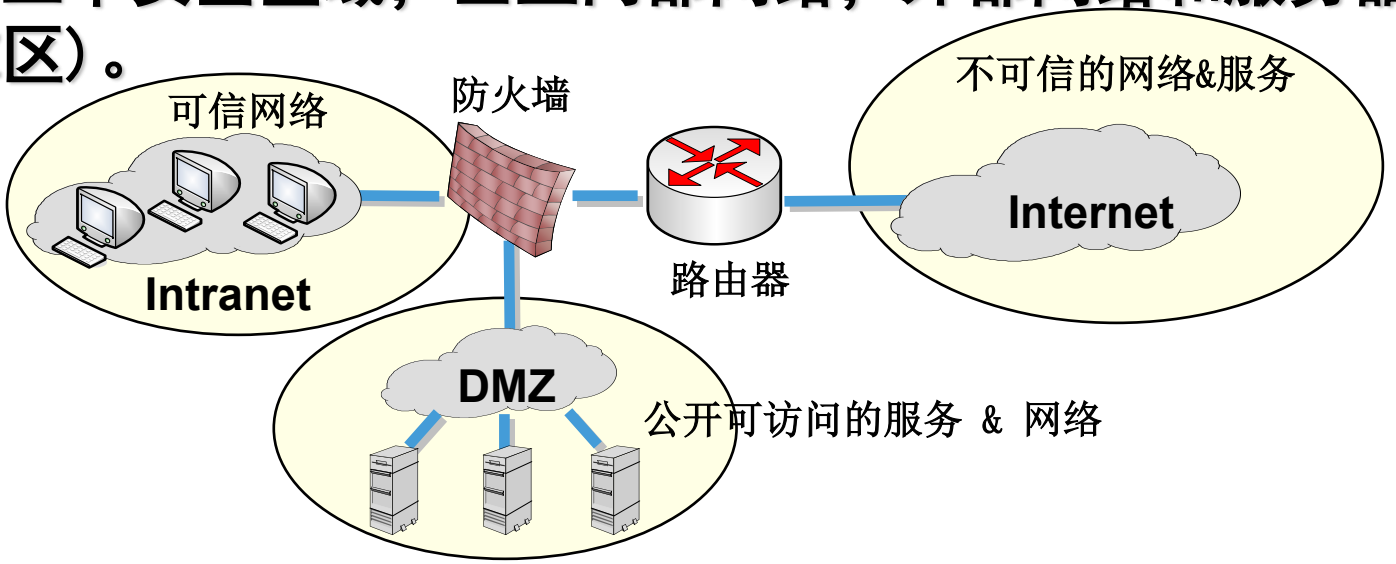
公共交换电话网络，一种常用旧式电话系统

防火墙的典型应用：实例6



企业防火墙的典型部署

这是最为普通的企业环境防火墙部署案例。利用防火墙将网络分为三个安全区域，企业内部网络，外部网络和服务器专网(DMZ区)。



内部网络一般采用私有的IP地址，DMZ的服务器可以采用公网地址，也可以采用私有地址，但是需要在防火墙上做相应的地址转换来保证外部用户对服务器的正常访问。一般常用的安全策略是：外部网络不允许访问内部网络，内部网络用户可以根据不同的权限访问Internet资源；内部用户和外部用户只允许访问DMZ区指定服务器的指定服务。（防火墙也可部署在路由器之前）

7.8 衡量防火墙性能的五大指标

1. 吞吐量：该指标直接影响网络的性能，吞吐量
2. 时延：入口处输入帧最后1个比特到达至出口处输出帧的第1个比特输出所用的时间间隔
3. 丢包率：在稳态负载下，应由网络设备传输，但由于资源缺乏而被丢弃的帧的百分比
4. 背靠背：从空闲状态开始，以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧，当出现第一个帧丢失时，发送的帧数
5. 并发连结数：并发连接数是指穿越防火墙的主机之间或主机与防火墙之间能同时建立的最大连接数

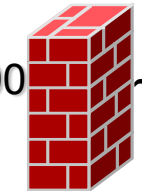
吞吐量

◆ **定义：**在不丢包的情况下能够达到的最大速率

Smartbits 6000B 测试仪

10110010100001111100101000100 0

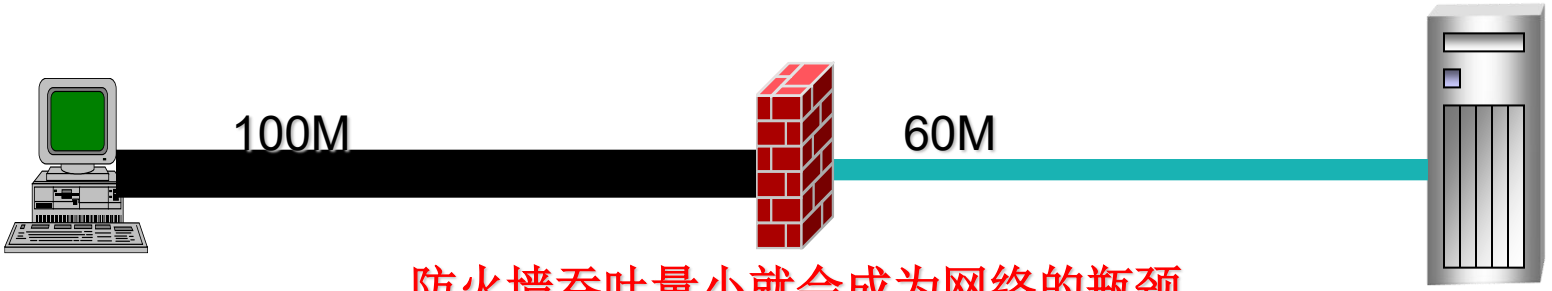
以最大速率发包



~;%#@*$^&*&^#**(&

直到出现丢包时的最大值

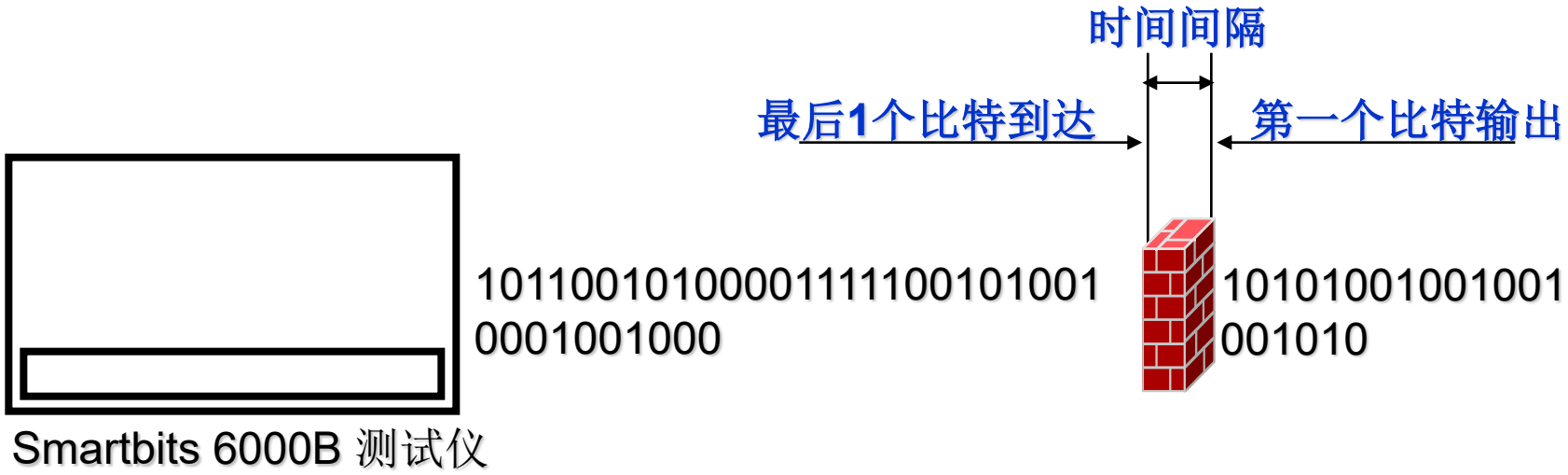
◆ **衡量标准：吞吐量越大，防火墙的性能越高**



防火墙吞吐量小就会成为网络的瓶颈

时延

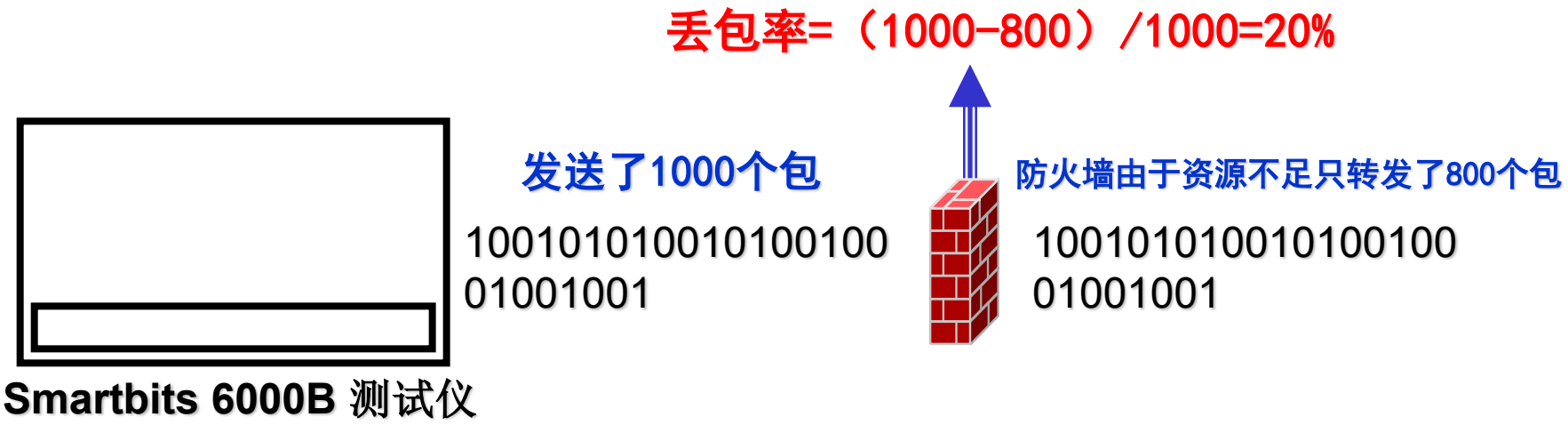
- **定义：**入口处输入帧最后1个比特到达至出口处输出帧的第一个比特输出所用的时间间隔



- **衡量标准：**延时越小，表示防火墙的性能越高
- **主要原因：**数据包排队进入防火墙并依据规则检查数据包造成数据包延迟到达目标地

丢包率

- **定义：**在连续负载的情况下，防火墙设备由于资源不足应转发但却未转发的帧百分比



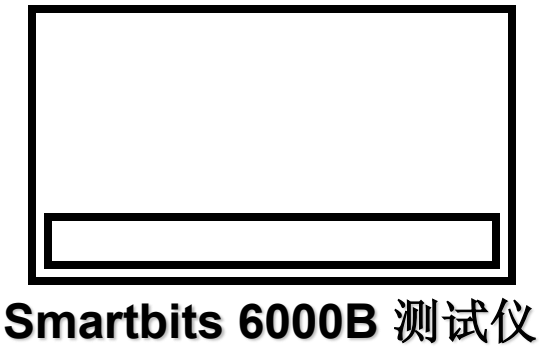
- **衡量标准：**丢包率越小，防火墙的性能越高

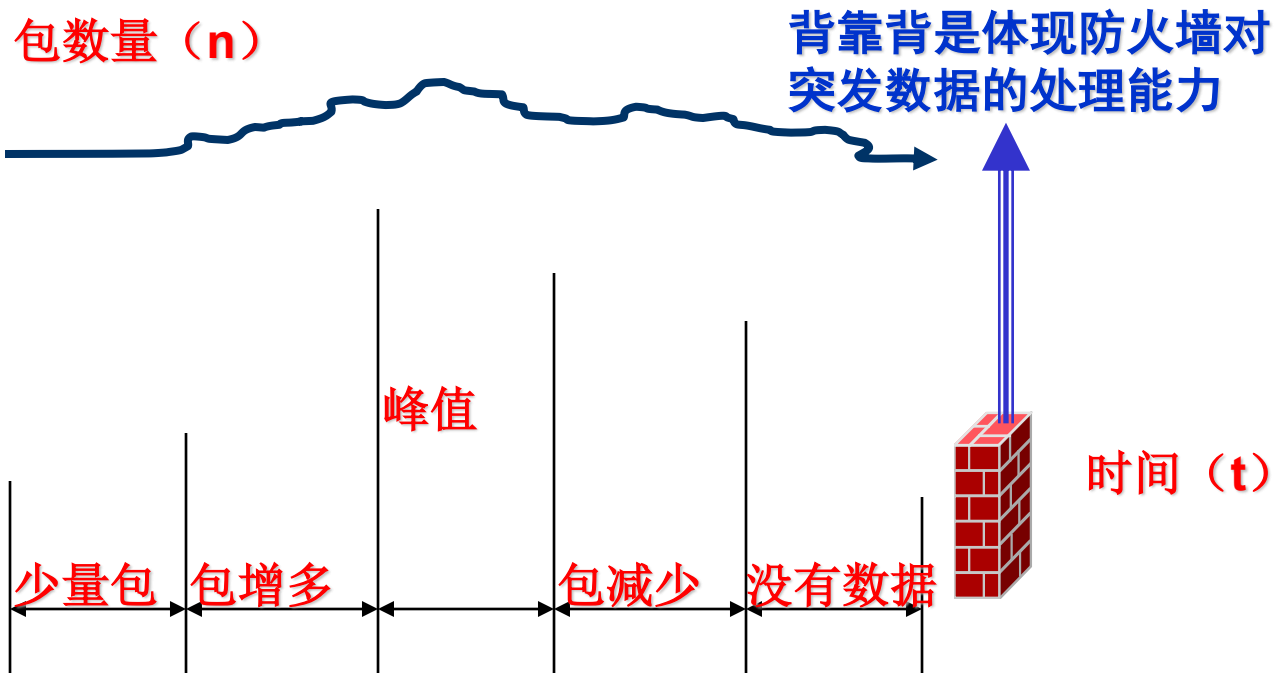
背靠背

- **定义：**从空闲状态开始，以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧，当出现第一个帧丢失时，发送的帧数。

- **衡量标准：**背对背包主要是指防火墙缓冲容量的大小，网络上经常有一些应用会产生大量的突发数据包（例如：NFS，备份，路由更新等），而且这样的数据包的丢失可能会产生更多的数据包的丢失，强大缓冲能力可以减小这种突发对网络造成的影响。

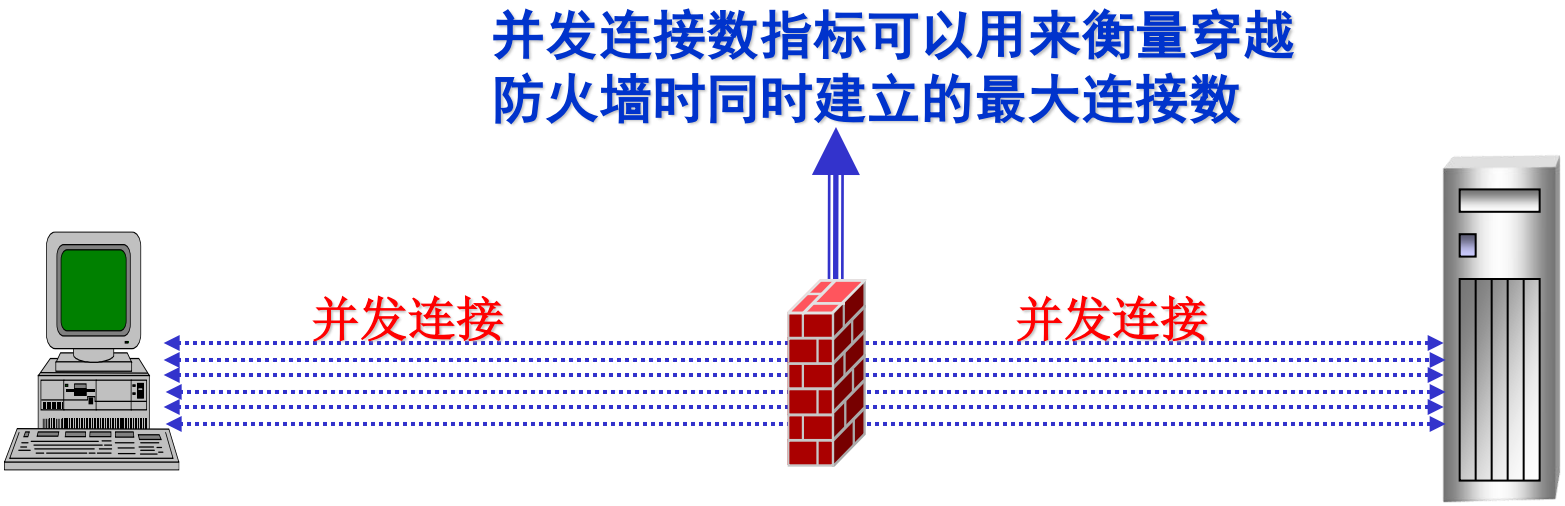
背靠背


Smartbits 6000B 测试仪


包数量（n）
背靠背是体现防火墙对
突发数据的处理能力
峰值
时间（t）
少量包
包增多
包减少
没有数据

并发连接数

- **定义：**指数据包穿越防火墙时同时建立的最大连接数。



- **衡量标准：**并发连接数主要用来测试防火墙建立和维持TCP连接的性能，并发连接数越大，防火墙的处理性能越高。

7.9 防火墙的弱点和局限性

- 防火墙防外不防内；
- 防火墙难于管理和配置，易造成安全漏洞；
- 很难为用户在防火墙内外提供一致的安全策略；
- 防火墙只实现了粗粒度的访问控制；
- 对于某些攻击防火墙也无能为力。

7.9 防火墙的弱点和局限性

防火墙虽然是保护网络安全的基础性设施，但是它还存在着一些不易防范的安全威胁。

- 首先防火墙不能防范未经过防火墙或绕过防火墙的攻击。例如，如果允许从受保护的网络内部向外拨号，一些用户就可能形成与Internet的直接连接。
- 防火墙基于数据包包头信息的检测阻断方式，主要对主机提供或请求的服务进行访问控制，无法阻断通过开放端口流入的有害流量，并不是对蠕虫或者黑客攻击的解决方案。
- 防火墙很难防范来自于网络内部的攻击或滥用。

7.10 防火墙的争议

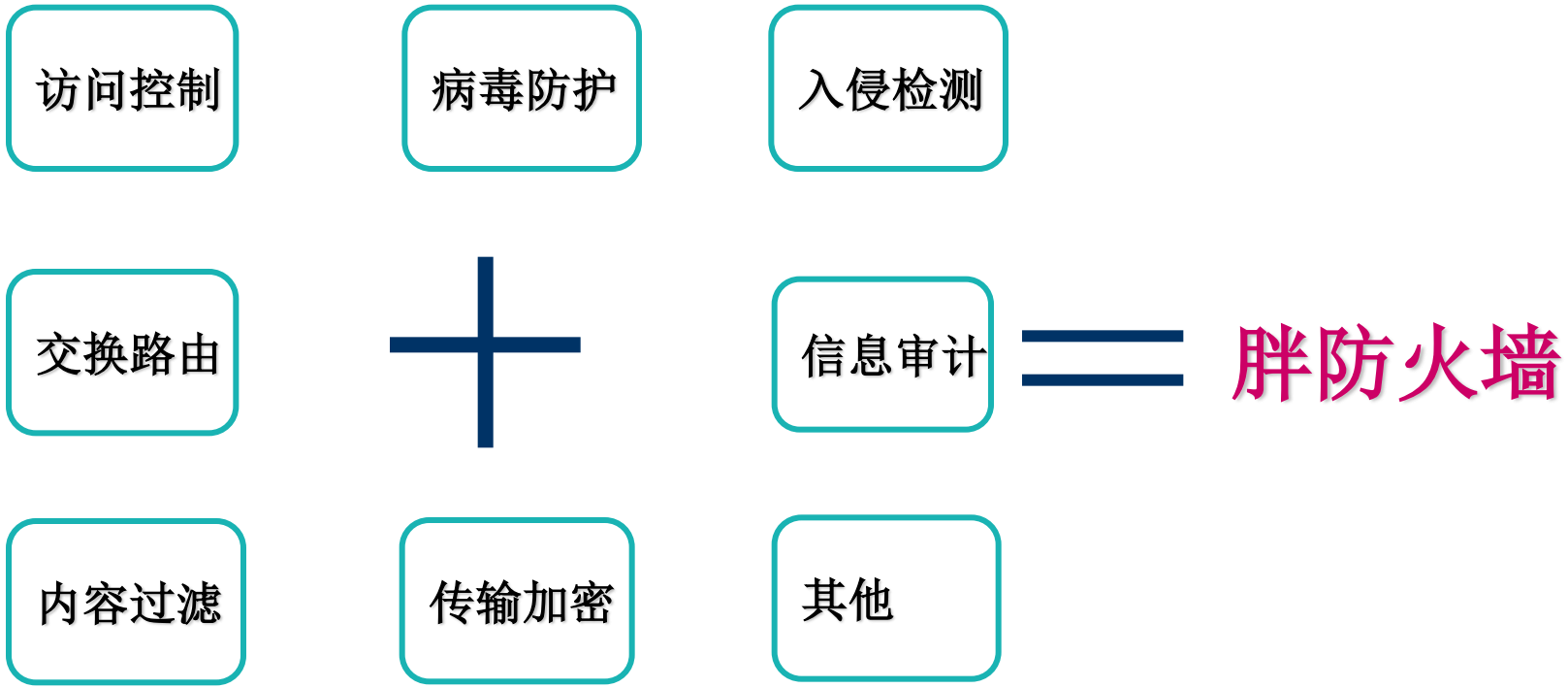
- 防火墙的胖一瘦之争
- 防火墙的硬件架构之争

防火墙的“胖”与“瘦”

由于防火墙在网络中所处的重要位置，因此，人们对防火墙可以说是寄予厚望。*现在防火墙正在不断增加各种各样的新功能，因此防火墙正在急剧“长胖”。*

胖防火墙的定义

- “胖”防火墙是指功能大而全的防火墙，它力图将安全功能尽可能多地包含在内，从而成为用户网络的一个安全平台；



胖防火墙的优势与不足

优势：

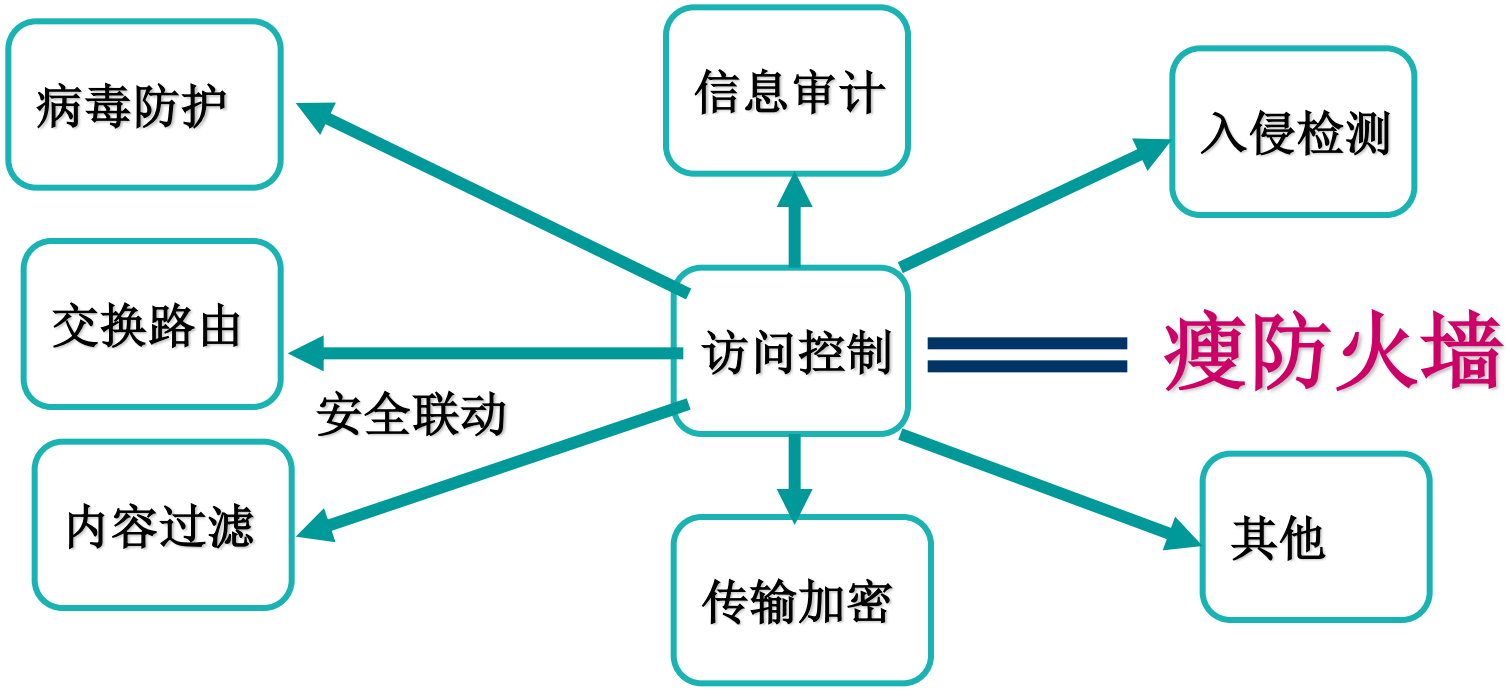
- 首先是功能全
- 其次是控制力度细
- 第三是协作能力强
- 降低采购和管理成本

不足：

- 主要表现在性能降低
- 其次是自身安全性相对较弱
- 还有专业性不强，表现为功能模块的拼凑
- 第四是稳定性不强，系统越大，BUG越多
- 最后是配置复杂，不合理的配置会带来更大的安全隐患

瘦防火墙的定义

- “瘦”防火墙是指功能少而精的防火墙，它只作访问控制的专职工作，对于综合安全解决方案，则采用多家安全厂商联盟的方式来实现。



瘦防火墙的优势与不足

优势：

- 性能高
- 注重核心功能，专业性强
- 整体安全性高
- 配置简单，简化对管理员的专业要求

不足：

- 功能单一
- 整体防护能力不能满足需求
- 整体采购成本较高

建议：构建联动、统一的动态安全防护体系

- 无论是“胖”防火墙的集成，还是“瘦”防火墙的联动，安全产品正在朝着体系化的结构发展，所谓“胖瘦”不过是这种体系结构的具体表现方式，“胖”将这种体系表现在一个产品中，而“瘦”将这种体系表现在一系列产品或是说一个整体方案中。
- 同时，不管哪种体系结构，都必须通过安全管理中心来监控、协调、管理网络中的其他安全产品和网络产品，构建联动、统一的动态安全防护体系。

7.10 防火墙的争议

- 防火墙的胖一瘦之争
- 防火墙的硬件架构之争

防火墙硬件架构

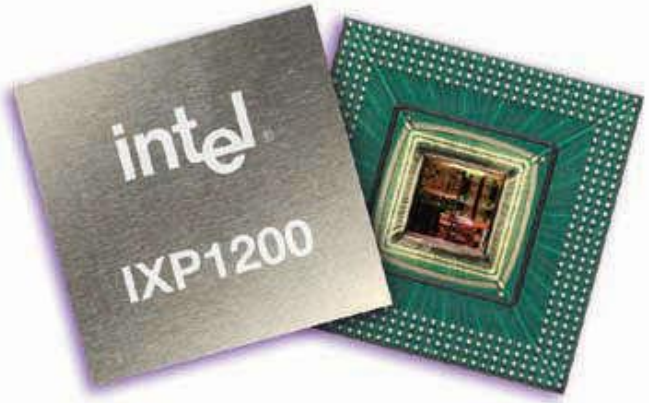
- 基于X86体系的通用CPU架构
- 基于网络处理器的NPU架构
- 基于专用处理芯片的ASIC架构

基于X86架构的防火墙

- X86架构防火墙中，其CPU具有高灵活性、高扩展性的特性；
- 通用CPU具有体系化的指令集和系统结构，容易支持复杂的运算和开发新的功能；
- 基于X86架构防火墙的处理速度和能力能够很好的适应各种百兆网络环境和一般千兆网络环境的需求；
- 基于X86防火墙由于受CPU处理能力和PCI总线的制约，在更高的千兆环境下其性能和功能则日益不能满足于需求；

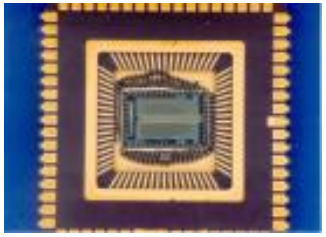
基于NPU架构的防火墙

- 网络处理器NPU则是专门为处理数据包而设计的可编程处理器，同时，其硬件体系结构的设计大多采用高速的接口技术和总线规范，具有较高的I/O能力；
- NP架构防火墙采用的是微引擎编程，在它的每一个网口上都有一个网络处理器（NPU）[illegible]个[illegible]的数据处理器。因此，NP[illegible]理来[illegible]转发。
- 在实际编[illegible]大的[illegible]验不断的总结。一般来说[illegible]可以[illegible]问题，但是这种仿真与硬件仿真还是有很大的区别的，最终也会导致NP防火墙产品综合成本较高，稳定性开发周期长，相比之下，其成熟性远不及ASIC和Intel IA 架构。



基于ASIC架构的防火墙

- 基于ASIC专用芯片架构的防火墙，通过专用数据处理芯片来工作，是公认的千兆线速防火墙，特别适用于高端千兆网络环境下。
- 传统的ASIC芯片技术的最大不足就是缺乏灵活性，开发难度大。一旦指令或计算逻辑固化到硬件中，就很难修改升级、增加新的功能。而且，ASIC设计和制造周期长，研发费用高。
- 现代的ASIC芯片技术增加了可编程性，从而能够同时满足灵活性和高性能的要求。从实现功能方面看，ASIC防火墙可以很容易地集成VPN、内容过滤和防病毒等功能。



防火墙硬件架构的发展趋势

最佳组合：

在系统控制与管理、数据高速处理转发等方面，通用CPU和可编程ASIC将各司其职，共同为防火墙系统提供灵活的服务！

7.11 WAF技术

WAF（Web Application Firewall）

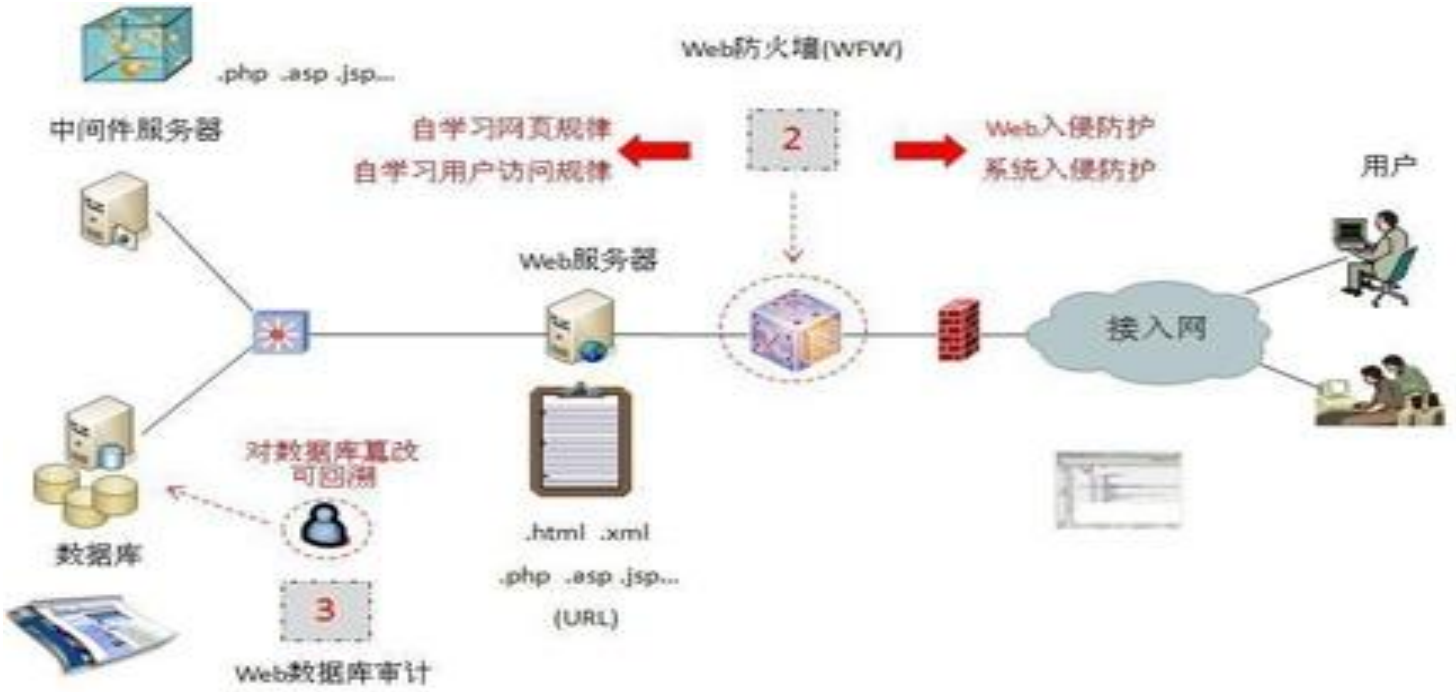
WAF的功能

对Web特有入侵方式的加强防护，如DDOS防护、SQL注入、XML注入、XSS等。由于重点是防SQL注入，也有人称为SQL防火墙。

由于是应用层而非网络层的入侵，从技术角度都应该称为Web IPS，而不是Web防火墙。

WAF的部署

Web防火墙产品部署在Web服务器的前面，串行接入，不仅在硬件性能上要求高，而且不能影响Web服务，所以HA功能、Bypass功能都是必须的，而且还要与负载均衡、Web Cache等Web服务器前的常见的产品协调部署。



WAF的技术原理

Web防火墙主要技术对入侵的检测能力，尤其是对Web服务入侵的检测，有下面几种方式：

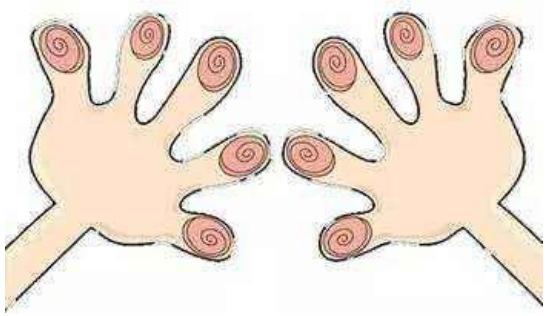
◆代理服务

代理方式本身就是一种安全网关，基于会话的双向代理，中断了用户与服务器的直接连接，适用于各种加密协议，这也是Web的Cache应用中最常用的技术。

代理方式防止了入侵者的直接进入，对DDOS攻击可以抑制，对非预料的“特别”行为也有所抑制。

◆特征识别

识别出入侵者行为特征是防护的前提。



特征就是攻击者的“指纹”，如：

◆缓冲区溢出时的Shellcode

◆SQL注入中常见的“真表达(1=1)”

◆…

应用信息没有“标准”，但每个软件、行为都有自己的特有属性，病毒与蠕虫的识别就采用此方式。

难点：每种攻击都自己的特征，数量比较庞大，相似度大，细微差别不易被辨识出来，从而导致误报的可能性也大。

虽然目前恶意代码的特征呈指数型增长，安全界声言要淘汰此项技术，但目前应用层的识别还没有特别好的方式。

https://www.bilibili.com/video/BV1Y54y1t7T7/?spm_id_from=333.337.search-card.all.click&vd_source=0991c0bfd7ce6d8c34ea5d7729eaded5

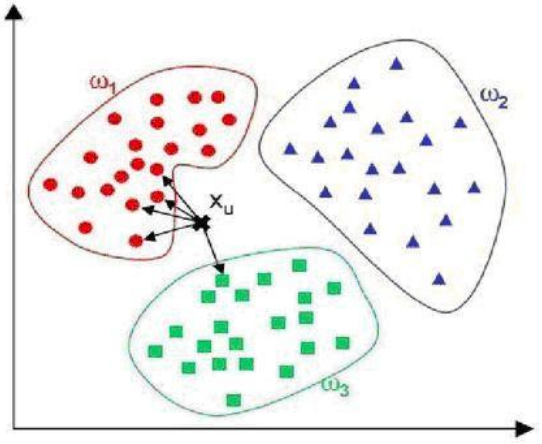
◆算法识别

问题的导出：基于特征识别的局限性

◆对攻击类型进行归类，相同类的特征进行模式化，不再是单个特征的比较，算法识别有些类似模式识别；

◆算法识别是进行语义理解，而不是靠“长相”识别。

但对攻击方式依赖性很强，如SQL注入、DDOS、XSS等都开发了相应的识别算法。



几种经典的模式识别算法

1. K-Nearest Neighbor
   http://courses.cs.tamu.edu/rgutier/cs790_w02/l8.pdf
2. Bayes Classifier
   http://www.cs.mcgill.ca/~mcleish/644/main.html
3. Principle Component Analysis
   http://blog.csdn.net/ayw_hehe/archive/2010/07/16/5736659.aspx
4. Linear Discriminant Analysis
   http://www.csd.uwo.ca/~olga/Courses//CS434a_541a//Lecture8.pdf
5. Non-negative Matrix Factorization
   http://chnfyn.blog.163.com/blog/static/269546322007516252432 95/
6. Gaussian Mixture Model
   http://neural.cs.nthu.edu.tw/jang/books/dcpr/doc/08gmm.pdf

◆模式匹配

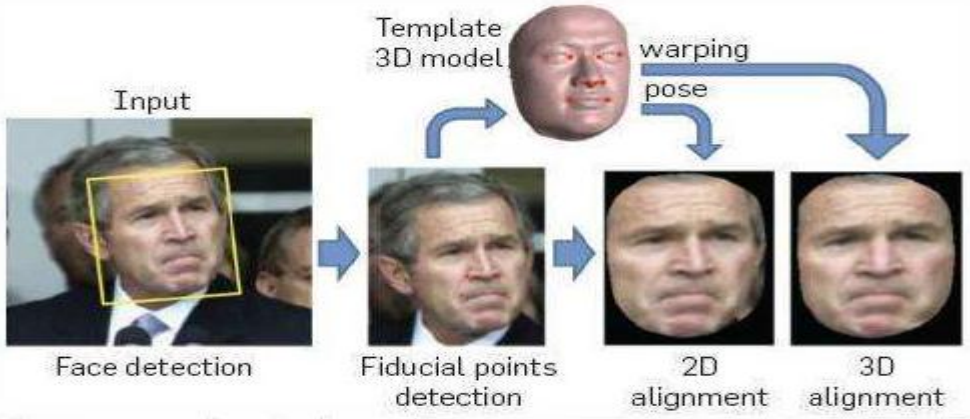
- 模式匹配是IDS中传统的技术实现方案，把攻击行为归纳成一定模式，匹配后能确定是入侵行为，当然模式的定义有一定的难度。
- 协议模式是其中简单的，是按标准协议的规程来定义模式；
- 行为模式匹配，但难度大。

Web防火墙最大的挑战

Web防火墙最大的挑战是识别率

这个指标不是一个容易测量的指标，因为绕过Web防火墙后入侵成功者一般不会大肆张扬，比如给网页挂马。

- 对于已知的攻击方式，可以给出识别率；
- 对未知的攻击方式，识别率可用性不大。



自学习技术的应用

技术原理

- **建立正常模式：**通过一段时间的用户访问，WAF记录了常用网页的访问模式，如一个网页中有几个输入点，输入的是什么类型的内容，通常情况的长度是多少等等，在学习完毕后，定义出一个网页的正常使用模式。
- **执行：**当有用户突破了所定义的正常使用模式，WAF就会根据预先定义的方式预警或阻断。
  - 一般的帐号输入不应该有特殊字符，而XML注入时需要有“<”之类的语言标记
  - 密码长度一般不超过20位，在SQL注入时加入代码会很长，同样突破了网页访问的模式

通过对B/S端双向流量来学习Web服务的用户行为模式，建立用户正常模型

7.12 基于机器学习的Web异常检测

传统Web入侵检测技术通过维护规则集对入侵访问进行拦截局限性大，且基于以往知识的规则集难以应对0day攻击。

机器学习应用于Web入侵检测也存在挑战，其中最大的困难就是标签数据的缺乏。尽管有大量的正常访问流量数据，但Web入侵样本稀少，且变化多样，对模型的学习和训练造成困难。

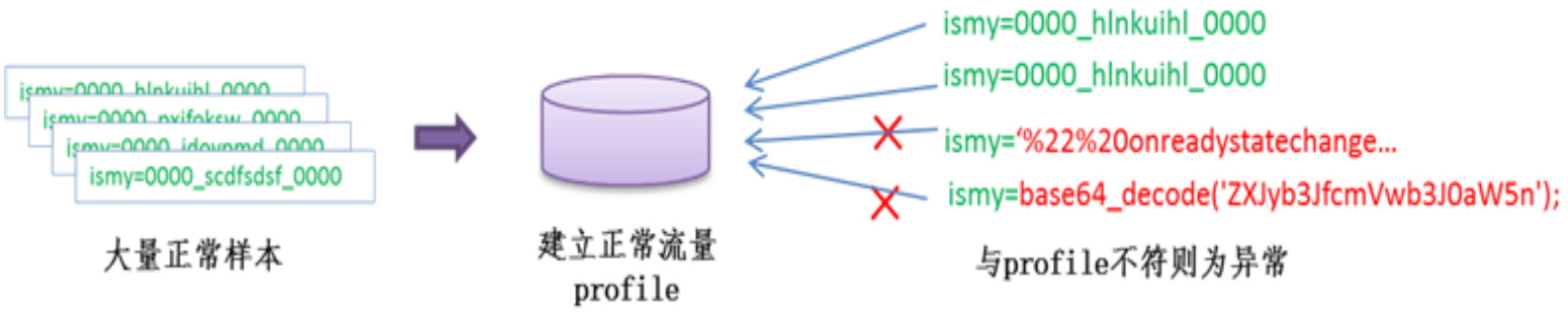
目前大多数Web入侵检测都是基于无监督的学习方法，针对大量正常日志建立模型(Profile)，而与正常流量不符的则被识别为异常。这个思路与拦截规则的构造恰恰相反。拦截规则意在识别入侵行为，因而需要在对抗中“随机应变”。

而基于Profile的方法旨在建模正常流量，在对抗中“以不变应万变”，且更难被绕过。

抓坏的 规则 模型 放好的

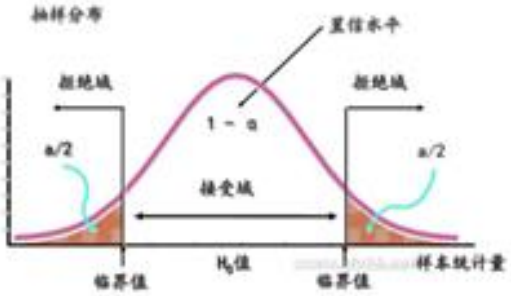
正常流量总是相似的，异常流量各有各的异常！

基于异常检测的Web入侵识别，训练阶段通常需要针对每个URL，基于大量正常样本，抽象出能够描述样本集的统计学或机器学习模型(Profile)。检测阶段，通过判断Web访问是否与Profile相符，来识别异常。



Profile的建立，主要有以下几种方案

◆基于统计学习模型

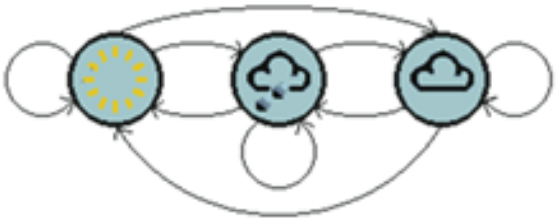


统计模型

基于统计学习的Web异常检测，通常需要对正常流量进行数值化的特征提取和分析。特征例如，URL参数个数、参数值长度的均值和方差、参数字符分布、URL的访问频率等等。接着，通过对大量样本进行特征分布统计，建立数学模型，进而通过统计学方法进行异常检测。

Profile的建立，主要有以下几种方案

◆基于文本分析的机器学习模型



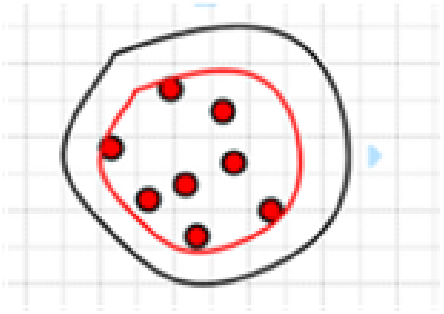
文本序列HMM

Web异常检测归根结底还是基于日志文本的分析，因而可以借鉴NLP中的一些方法思路，进行文本分析建模。

- ◆ 比较成功的是基于隐马尔科夫模型(HMM)的参数值异常检测。

Profile的建立，主要有以下几种方案

◆基于单分类模型

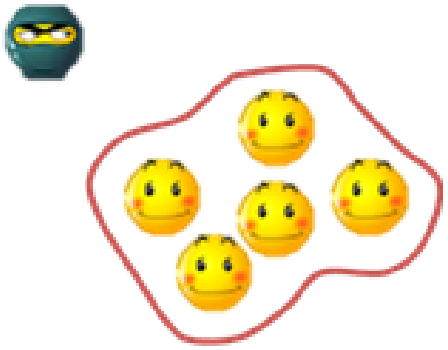


单分类模型

由于Web入侵黑样本稀少，传统监督学习方法难以训练。基于白样本的异常检测，可以通过非监督或单分类模型进行样本学习，构造能够充分表达白样本的最小模型作为Profile，实现异常检测。

Profile的建立，主要有以下几种方案

◆基于聚类模型



聚类模型

通常正常流量是大量重复性存在的，而入侵行为则极为稀少。因此，通过Web访问的聚类分析，可以识别大量正常行为之外，小簇的异常行为，判断为入侵。

基于统计学习模型

基于统计学习模型的方法，首先要对数据建立特征集，然后对每个特征进行统计建模。对于测试样本，首先计算每个特征的异常程度，再通过模型对异常值进行融合打分，作为最终异常检测判断依据。

特征1：

参数值value长度 模型：长度值分布，均值μ，方差σ2，利用切比雪夫不等式计算异常值p

切比雪夫不等式 $\Pr(|X-\mu| \geq k\sigma) \leq \frac{1}{k^2}$

意义：任意一个数据集中，位于其平均数k个标准差范围内的比例总是至少为$1-1/k^2$.

基于统计学习模型

特征2：字符分布

模型：对字符分布建立模型，通过卡方检验计算异常值p

Pearson's chi-squared test

卡方检验 $$\chi^2 = \sum_{i=1}^{n} \frac{(O_i - E_i)^2}{E_i} = N \sum_{i=1}^{n} \frac{(O_i/N - p_i)^2}{p_i}$$

意义：测试观察值的频率分布是否符合理论分布

基于统计学习模型

特征3：参数缺失

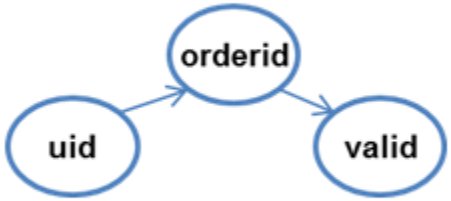
模型：建立参数表，通过查表检测参数错误或缺失

特征4：参数顺序

模型：参数顺序有向图，判断是否有违规顺序关系

1. 通过有向图表示参数顺序

uid=123&orderid=12345&valid=true



2. 求取强连图子图（SCC，Tarjan algorithm）
3. 形成顺序约束表

基于统计学习模型

特征5：访问频率（单IP的访问频率，总访问频率）

模型：时段内访问频率分布，均值 μ，方差 σ2，利用切比雪夫不等式计算异常值p

特征6：访问时间间隔

模型：间隔时间分布，通过卡方检验计算异常值p

最终，通过异常打分模型将多个特征异常值融合，得到最终异常打分

$$\sum_{m} w_m \times (1 - p_m)$$

基于文本分析的机器学习模型

URL参数输入的背后，是后台代码的解析，通常来说，每个参数的取值都有一个范围，其允许的输入也具有一定模式。例如：

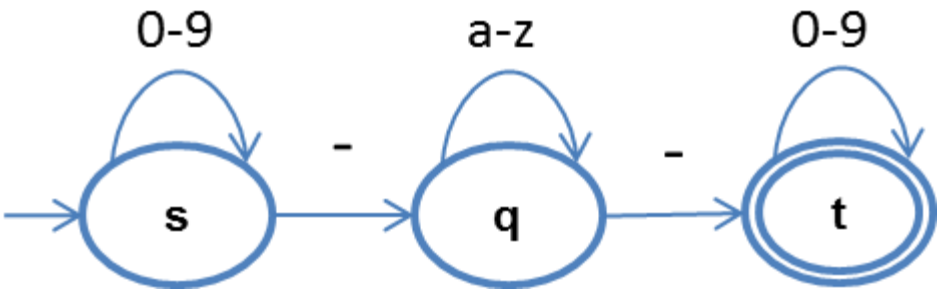
https://somedomain.com/alibaba/report?mid=6492_abc_7756
https://somedomain.com/alibaba/report?mid=1234_feagada_7680
https://somedomain.com/alibaba/report?mid=2345_hlnkl_9000
https://somedomain.com/alibaba/report?mid=base64_decode

绿色的代表正常流量，红色的代表异常流量。

由于异常流量和正常流量在参数、取值长度、字符分布上都很相似，基于上述特征统计的方式难以识别。进一步看，正常流量尽管每个都不相同，但有共同的模式，而异常流量并不符合

基于文本分析的机器学习模型

在上例子中，符合取值的样本模式为：数字 _ 字母 _ 数字，就可以用一个状态机来表达合法的取值范围

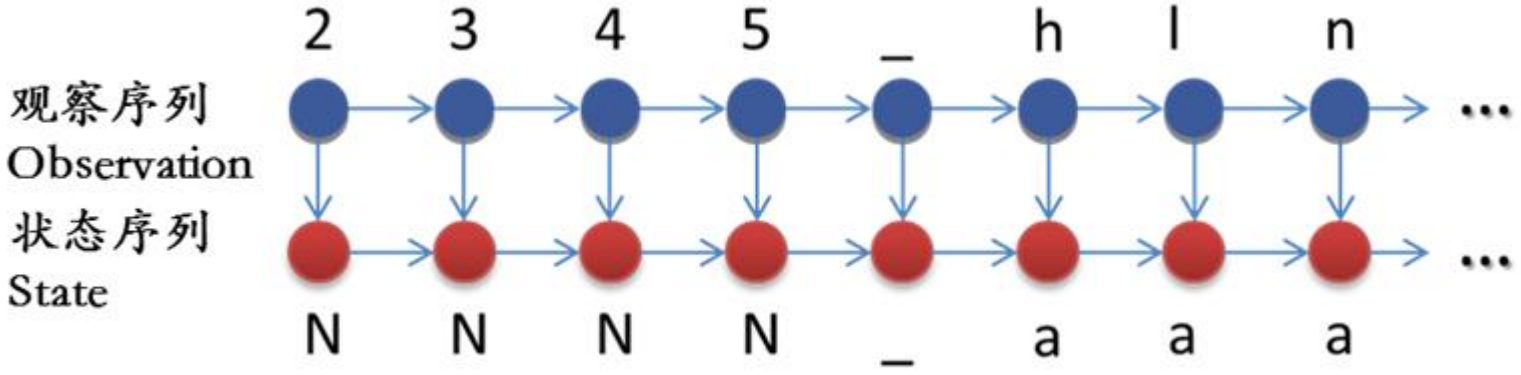


对文本序列模式的建模，相比较数值特征而言，更加准确可靠。其中，比较成功的应用是基于隐马尔科夫模型(HMM)的序列建模

基于文本分析的机器学习模型

基于HMM的状态序列建模，首先将原始数据转化为状态表示，如数字用N表示状态，字母用a表示状态，其它字符保持不变。

这一步也可以看做是原始数据的归一化(Normalization)，其结果使得原始数据的状态空间被有效压缩，正常样本间的差距也进一步减小。



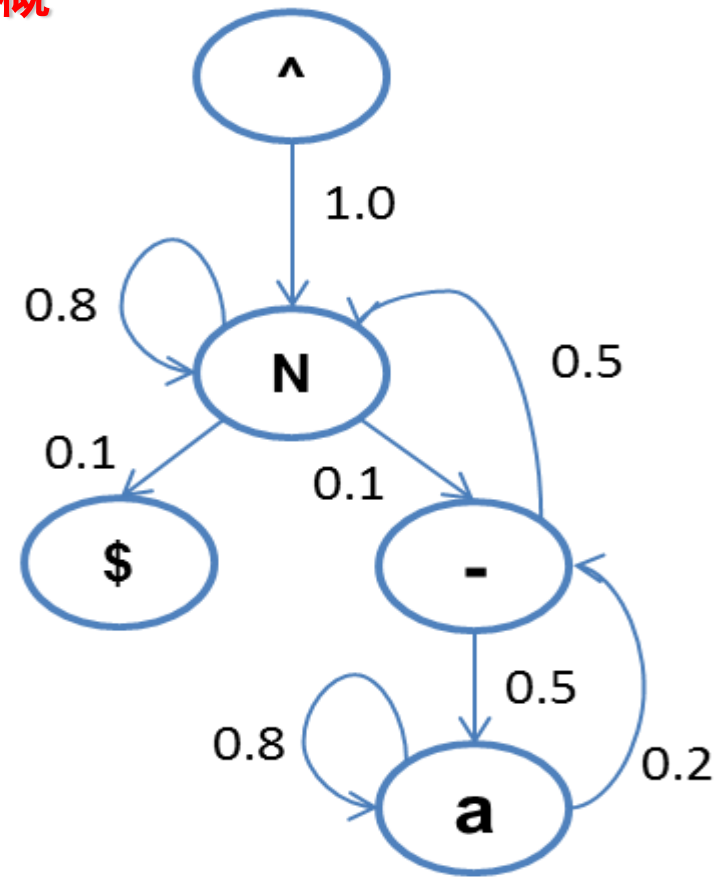
基于文本分析的机器学习模型

^NNNN_aaaa_NNNN$

下一步：对于每个状态，统计之后一个状态的概率分布。

例如，右图就是一个可能得到的结果。

- “^”代表开始符号，由于白样本中都是数字开头，起始符号(状态^)转移到数字(状态N)的概率是1；
- 接下来，数字(状态N)的下一个状态，有0.8的概率还是数字(状态N)，有0.1的概率转移到下划线，有0.1的概率转移到结束符(状态$)；
- 以此类推。



基于文本分析的机器学习模型

利用这个状态转移模型，就可以判断一个输入序列是否符合白样本的模式。

Observation ismy=2345_hlnkl_9000

State ismy=NNNN_aaaa_NNNN

$$P(w) = 1.0*(0.8)^3*0.1*0.5*(0.8)^3*0.2*(0.8)^3*0.1$$

Observation ismy=base64_decode('ZXJyb3JfcmVwb3J0aW5n');

State ismy=aaaaNN_aaaaaa('AAAaaNaaaaAaaNANaANa');

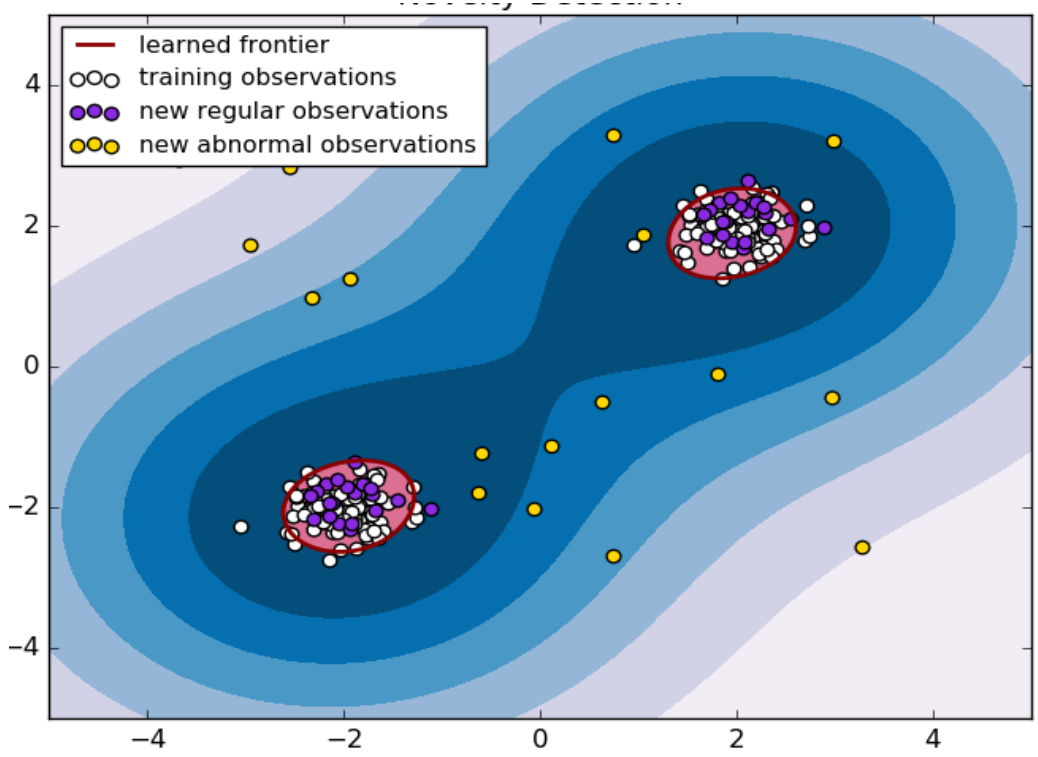
$$P(w) = 0.0*(0.8)^3*0.0*0.1*(0.8)^5*0.0...$$

正常样本的状态序列出现概率要高于异常样本，通过合适的阈值可以进行异常识

基于单分类模型

在二分类问题中，由于只有大量白样本，可以考虑通过单分类模型，学习单类样本的最小边界，边界之外的则识别为异常。

这类方法中，比较成功的应用是单类支持向量机(one-class SVM)。



基于单分类模型

成功案例：McPAD的方案

McPAD系统首先通过N-Gram将文本数据向量化，对于下面的例子

http://abc.com/test?path=/category-0001.htm
http://abc.com/test?path=/category-0002.htm

第一步：通过长度为N的滑动窗口将文本分割为N-Gram序列，例子中，N取2，窗口滑动步长为1，可以得到如下N-Gram序列。

基于单分类模型

成功案例：McPAD的方案

第二步：要把N-Gram序列转化成向量。

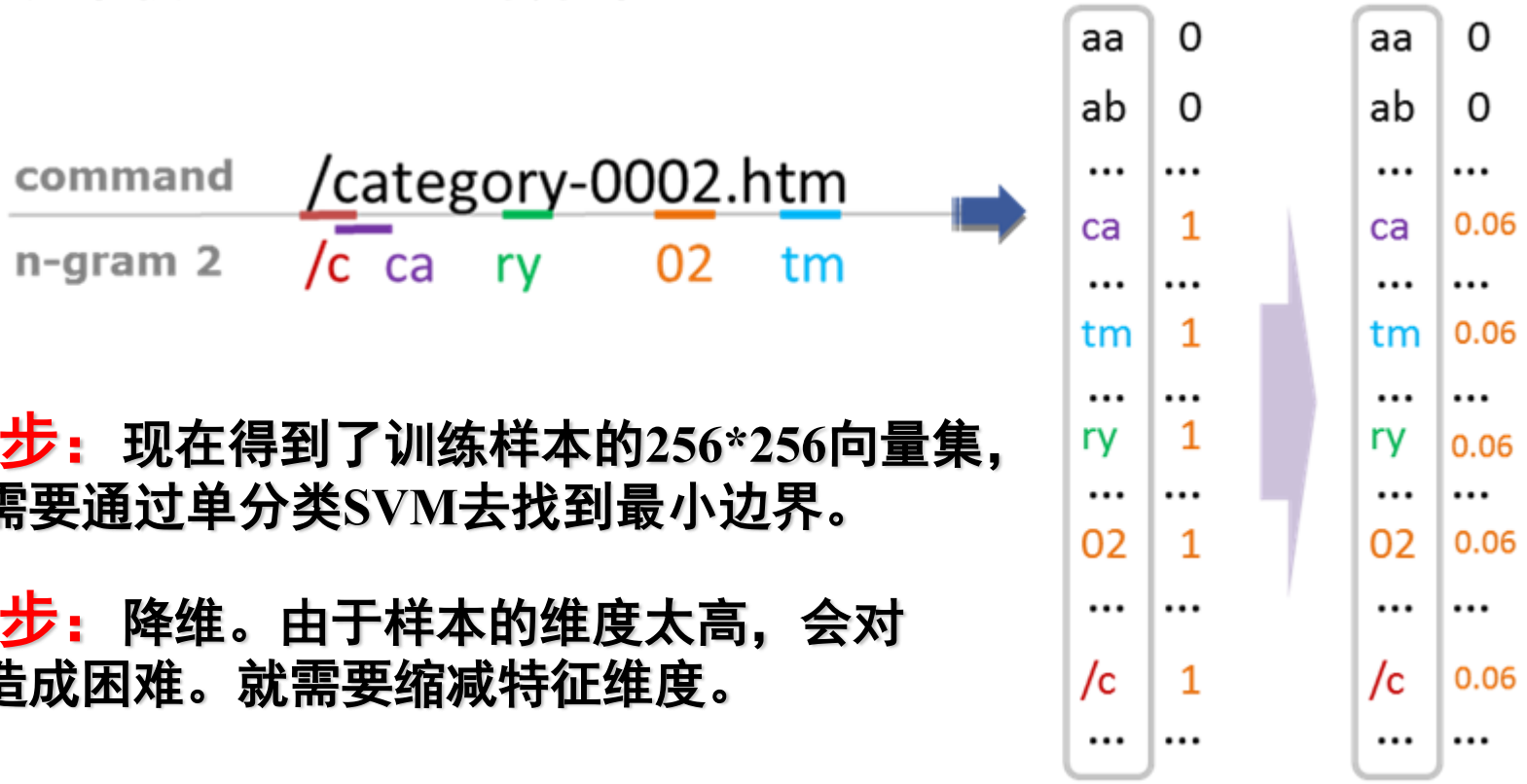
假设共有256种不同的字符，那么会得到256*256种2-GRAM的组合(如aa, ab, ac …)。我们可以用一个256*256长的向量，每一位one-hot的表示(有则置1，没有则置0)文本中是否出现了该2-GRAM。由此得到一个256*256长的0/1向量。进一步，对于每个出现的2-Gram，我们用这个2-Gram在文本中出现的频率来替代单调的“1”，以表示更多的信息：

$$f(\beta|B) = \frac{\#\text{ of occurrences of } \beta \text{ in } B}{l - n + 1}$$

至此，每个文本都可以通过一个256*256长的向量表示。

基于单分类模型

成功案例：McPAD的方案

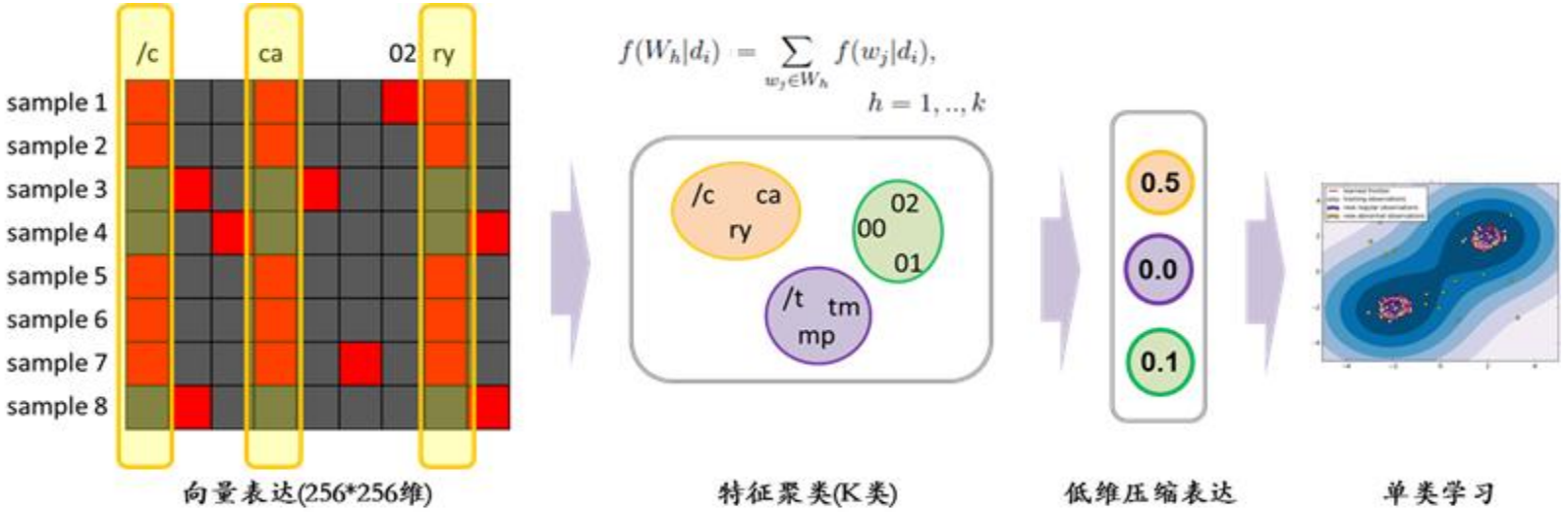


第三步： 现在得到了训练样本的256*256向量集，现在需要通过单分类SVM去找到最小边界。

第四步： 降维。由于样本的维度太高，会对训练造成困难。就需要缩减特征维度。

特征维度约减有很多方法，McPAD系统中对特征进行了聚类达到降维目的

基于单分类模型

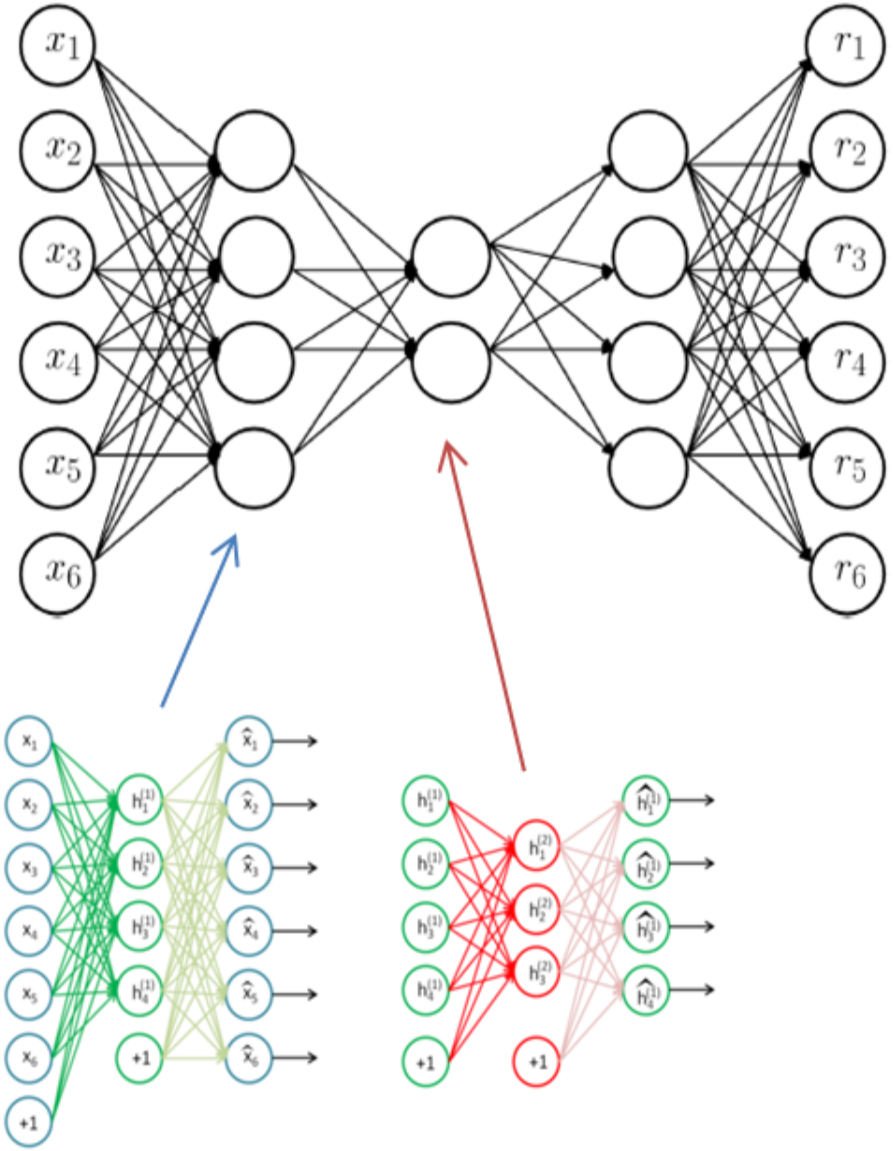


上左矩阵中黑色表示0，红色表示非零。矩阵的每一行，代表一个输入文本(sample)中具有哪些2-Gram。如果换一个角度来看这个矩阵，则每一列代表一个2-Gram有哪些sample中存在，由此，每个2-Gram也能通过sample的向量表达。从这个角度可以获得2-Gram的相关性。对于2-Gram的向量进行聚类，指定的类别数K即为约减后的特征维数。约减后的特征向量，再投入单类SVM进行进一步模型训练。

基于单分类模型

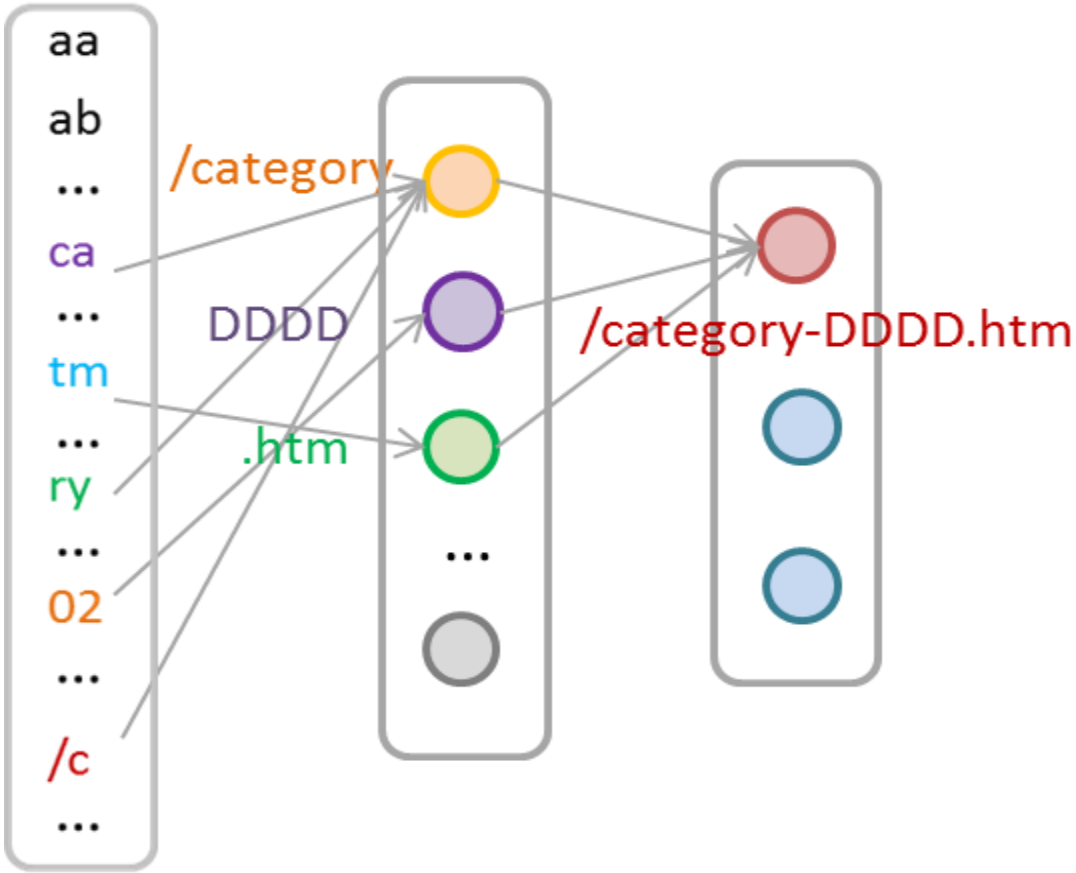
成功案例：McPAD的方案

- McPAD采用线性特征约减加单分类SVM的方法解决白模型训练的过程。
- 其实也可以被深度学习中的深度自编码模型替代，进行非线性特征约减。
- 自编码模型的训练过程本身就是学习训练样本的压缩表达，通过给定输入的重建误差，就可以判断输入样本是否与模型相符。



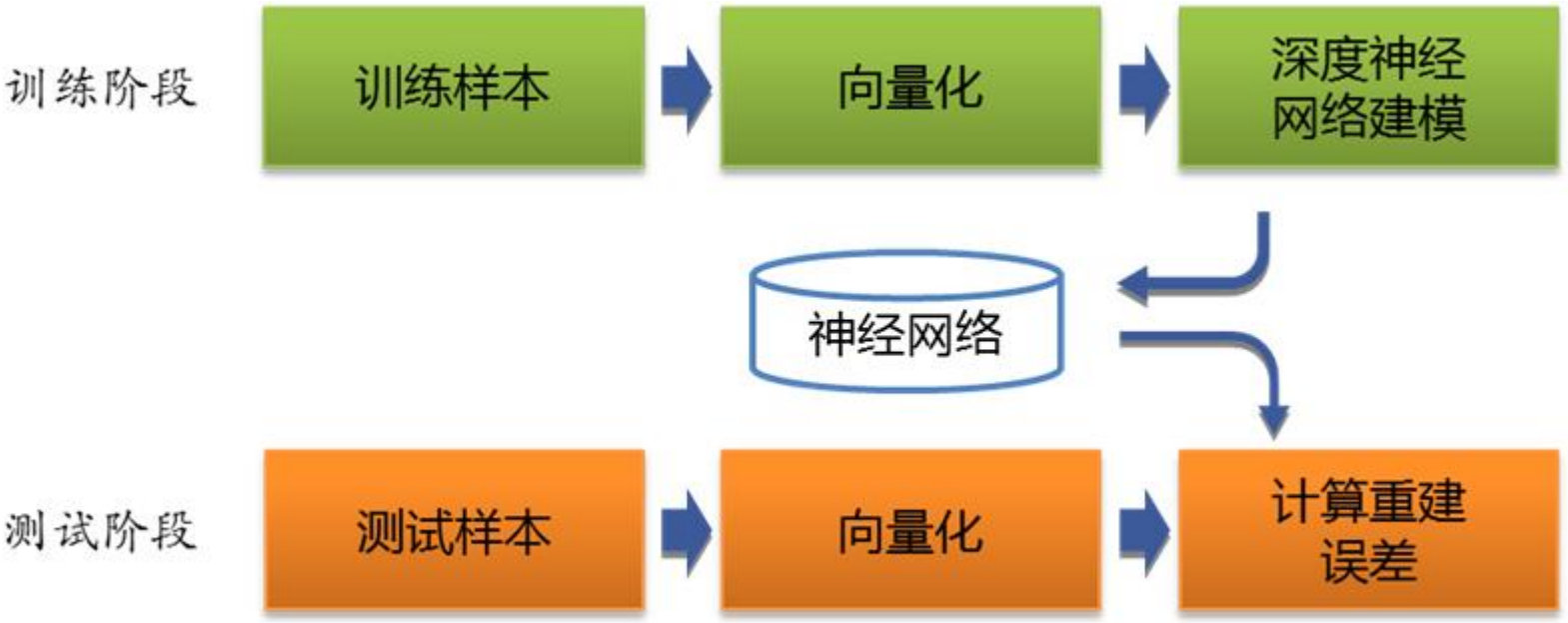
基于单分类模型

成功案例：McPAD的方案



沿用McPAD通过2-Gram实现文本向量化的方法，直接将向量输入到深度自编码模型，进行训练。测试阶段，通过计算重建误差作为异常检测的标准。

总结： WAF异常检测的基本流程



推荐阅读

- CS259D: Data Mining for CyberSecurity, URL：http://web.stanford.edu/class/cs259d/
- 楚安，数据科学在Web威胁感知中的应用，http://www.jianshu.com/p/942d1beb7fdd
- McPAD : A Multiple Classifier System for Accurate Payload-based Anomaly Detection, Roberto Perdisci
- AI2 : Training a big data machine to defend, Kalyan Veeramachaneni

中国信息安全认证中心关于防火墙产品认证

- 产品范围

《信息安全产品强制性认证实施规则 防火墙产品》所指的防火墙产品是指一个或一组在不同安全策略的网络或安全域之间实施网络访问控制的系统。

该规则适用的产品范围为：以防火墙功能为主体的软件或软硬件组合；不适用个人防火墙产品。

拟用于涉密信息系统的上述产品，按照国家有关保密规定和标准执行，不适用该规则。

- 认证依据标准

GB/T 20281《信息安全技术 防火墙技术要求和测试评价方法》

产品依据标准列表

IT 产品信息安全认证依据标准

一般产品

序号	产品名称	依据标准	标准名称
1	操作系统安全加固产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-001-2017	操作系统安全加固产品安全技术要求
2	终端安全管理系统产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-002-2017	终端安全管理系统产品安全技术要求
3	抗拒绝服务系统产品	RB/T 205-2014	抗拒绝服务系统安全评价规范
4	上网行为管理产品	RB/T 204-2014	上网行为管理产品安全评价规范
5	WEB 应用防火墙产品	GB/T 32917-2016	信息安全技术 WEB 应用防火墙安全技术要求和测试评价方法
6	统一威胁管理(UTM)产品	GB/T 31499-2015	信息安全技术 统一威胁管理产品技术要求和测试评价方法
7	入侵防御产品（IPS）	GB/T 28451-2012	信息安全技术 网络型入侵防御产品技术要求和测试评价方法
8	安全管理平台	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-007-2017	安全管理平台产品安全技术要求
9	内容分发网络(CDN)产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-010-2017	内容分发网络(CDN)产品安全技术要求
10	机关绩效综合管理信息平台	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-011-2017	机关绩效综合管理信息平台安全技术要求
11	路由器产品	GB/T 18018-2019	信息安全技术 路由器安全技术要求
12	手机云存储连接产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-013-2017	手机云存储连接产品安全技术要求
13	WEB 应用安全监测系统产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-014-2017	WEB 应用安全监测系统产品安全技术要求
14	虚拟化软件产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-015-2017	虚拟化软件产品安全技术要求
15	视频会议系统产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-016-2017	视频会议系统产品安全技术要求
16	特权帐户管理产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-017-2017	特权帐户管理产品安全技术要求
17	证券交易产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-018-2017	证券交易产品安全技术要求(通信连接部件)
18	电子版权系统产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-019-2017	电子版权系统产品安全技术要求
19	虚拟磁盘系统产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-020-2017	虚拟磁盘系统产品安全技术要求
20	WEB 应用安全扫描产品	GB/T 18336-2015	信息技术 安全技术 信息技术安全评估准则
		ISCCC-TR-021-2017	WEB 应用安全扫描产品安全技术要求

ICS 35.040
L 80

中华人民共和国国家标准

GB/T 20281—2015
代替 GB/T 20281—2006

信息安全技术　防火墙安全技术要求和测试评价方法

Information security technology—Security technical requirements and testing and evaluation approaches for firewall

2015-05-15 发布　　2016-01-01 实施

中华人民共和国国家质量监督检验检疫总局
中国国家标准化管理委员会　发布

目　　次

前言 …… Ⅲ
1　范围 …… 1
2　规范性引用文件 …… 1
3　术语和定义 …… 1
4　缩略语 …… 2
5　防火墙描述 …… 2
6　安全技术要求 …… 2
6.1　总体说明 …… 2
6.1.1　要求分类 ……
6.1.2　安全等级 ……
6.2　基本级安全要求 ……
6.2.1　安全功能要求 ……
6.2.2　安全保证要求 ……
6.3　增强级安全要求 …… 1
6.3.1　安全功能要求 …… 10
6.3.2　安全保证要求 …… 15
6.4　环境适应性要求 …… 20
6.4.1　传输模式 …… 20
6.4.2　下一代互联网支持(有则适用) …… 20
6.5　性能要求 …… 21
6.5.1　吞吐量 …… 21
6.5.2　延迟 …… 21
6.5.3　最大并发连接数 …… 22
6.5.4　最大连接速率 …… 22
7　测试评价方法 …… 22
7.1　测试环境 …… 22
7.1.1　安全功能与环境适应性测试环境 …… 22
7.1.2　性能测试环境 …… 23
7.2　基本级安全要求测试 …… 23
7.2.1　安全功能测试 …… 23
7.2.2　安全保证测试 …… 28
7.3　增强级安全要求测试 …… 32
7.3.1　安全功能测试 …… 32
7.3.2　安全保证测试 …… 40
7.4　环境适应性测试 …… 49
7.4.1　传输模式 …… 49
7.4.2　下一代互联网支持 …… 49
7.5　性能测试 …… 53
7.5.1　吞吐量 …… 53
7.5.2　延迟 …… 53
7.5.3　最大并发连接数 …… 54
7.5.4　最大连接速率 …… 54
参考文献 …… 55

西南交通大學 Southwest Jiaotong University

前　言

本标准按照 GB/T 1.1—2009 给出的规则起草。

本标准代替 GB/T 20281—2006《信息安全技术　防火墙技术要求和测试评价方法》。

本标准与 GB/T 20281—2006 的主要差异如下：

——修改了防火墙的描述；

——修改了防火墙的功能分类；

——增加了防火墙的高性能要求；

——加强了防火墙对应用层控制能力的要求；

——增加了下一代互联网协议支持能力的要求；

——级别统一划分为基本级和增强级。

本标准由全国信息安全标准化技术委员会(SAC/TC 260)提出并归口。

本标准起草单位：公安部计算机信息系统安全产品质量监督检验中心、北京启明星辰信息安全技术有限公司、华为技术有限公司、解放军信息安全测评认证中心、北京中科网威信息技术有限公司、北京网康科技有限公司、公安部第三研究所。

本标准主要起草人：俞优、陆臻、邹春明、顾健、沈亮、李毅、韦湘、王光宇、吕颖轩、王平。

本标准所代替标准的历次版本发布情况为：

——GB/T 20281—2006。

3 术语和定义

GB/T 25069—2010 界定的以及下列术语和定义适用于本文件。

3.1

防火墙 firewall

部署于不同安全域之间，具备网络层访问控制及过滤功能，并具备应用层协议分析、控制及内容检测等功能，能够适用于 IPv4、IPv6 等不同的网络环境的安全网关产品。

3.2

深度包检测 deep packet inspection

基于应用层的流量检测和控制技术，通过读取 IP 包载荷的内容并对应用层信息进行重组，从而得到整个应用程序的内容，然后按照系统定义的策略对内容进行相应处置。

3.3

深度内容检测 deep content inspection

能够对应用协议进行深入解析，识别出协议中的各种要素（如 http 协议，可具体解析到如 cookie、Get 参数、Post 表单等）以及协议所承载的业务内容（如业务系统交互中包含在协议或文件中的数据内容），并对这些数据进行快速的解析，以还原其原始通信的信息。根据这些解析后的原始信息，可以检测其是否包含威胁以及敏感内容。

3.4

SQL 注入 SQL injection

把 SQL 命令插入到 web 表单递交或者页面请求的参数中，以达到欺骗服务器执行恶意 SQL 命令的目的。

3.5

跨站脚本 cross site scripting

恶意攻击者往 web 页面里插入恶意 HTML 代码，当用户浏览该页面时，嵌入 web 页面里面的 HTML 代码会被执行，从而达到恶意攻击用户的目的。

表 1　安全功能要求等级划分表

安全功能			基本级	增强级
网络层控制	包过滤		*	**
	NAT		*	**
	状态检测		*	*
	策略路由		*	**
	动态开放端口		*	**
	IP/MAC 地址绑定		*	*
	流量会话管理	流量统计	*	*
		带宽管理	—	*
		连接数控制	*	*
		会话管理	—	*
	抗拒绝服务攻击		*	*
	网络扫描防护		*	**
应用层控制	用户管控		—	*
	应用协议控制		*	**
	应用内容控制		—	*
	恶意代码防护		—	*
	应用攻击防护		—	*

安全功能			基本级	增强级
安全运维管理	运维管理		*	**
	安全审计		*	**
	安全管理	管理接口独立	*	*
		安全支撑系统	*	*
		异常处理机制	*	*
	高可用性	双机热备	—	*
		负载均衡	—	*

注：“*”具有该要求；“**”要求有所增强；“—”不适用。

6.1.2　安全等级

本标准按照防火墙安全功能的强度划分安全功能要求的级别，按照 GB/T 18336.3—2008 划分安全保证要求的级别。安全等级分为基本级和增强级，如表 1、表 2 所示。安全功能强弱和安全保证要求高低是等级划分的具体依据。安全等级突出安全特性，环境适应性要求和性能要求不作为等级划分依据。其中，达到基本级要求的产品安全保证要求内容对应 GB/T 18336.3—2008 的 EAL2 级，推荐使用在安全保护等级为第一、二级的信息系统中；达到增强级要求的产品安全保证要求内容对应 GB/T 18336.3—2008 的 EAL4+级，推荐使用在安全保护等级为第三、四级的信息系统中。与基本级内容相比，增强级中要求有所增加或变更的内容在正文中通过“宋体加粗”表示。